Fajma

Votre santé, simplement

DOSSIER TECHNIQUE ET SÉCURITÉ

Plateforme de santé numérique du Sénégal

Version 7.7 — 14 octobre 2026

Prise de rendez-vous, téléconsultation en français et en wolof, dossier médical, ordonnances, analyses et imagerie, paiement mobile, assurances et pharmacies. Ce dossier décrit l'architecture, la sécurité, l'exploitation et les conditions d'une reprise du projet.

429 tests automatisés, SQLite et PostgreSQL	**Django 6.1** PostgreSQL 17 · React 19
0 composant sous copyleft fort	**10** chapitres + annexe des licences
WCAG AA accessibilité vérifiée (axe-core)	**Portable** aucune dépendance à un hébergeur

Destinataires : acquéreurs, investisseurs, auditeurs techniques et juridiques, équipe technique reprenant le projet.

> **Document confidentiel.** Il décrit l'architecture et les mesures de sécurité de la plateforme. À transmettre uniquement sous accord de confidentialité.

Établi le 14 octobre 2026 · fajma.sn · 10 chapitres, 74 pages

Sommaire

Chaque ligne renvoie au chapitre dans le PDF.

Dossier technique et sécurité — Fajma 3
Présentation du produit, périmètre du dossier, état d'avancement et historique des versions.

1. Architecture 12
Composants, organisation du code, fonctionnalités, modèle de données, intégrations

2. Sécurité 19
Authentification, contrôle d'accès, protections, secrets, journal d'audit, tests

3. Données personnelles et conformité 27
Inventaire des données, sous-traitants, droits des personnes, obligations au Sénégal

4. Exploitation et déploiement 31
Installation, mise en production, tâches planifiées, sauvegardes, supervision

5. Risques ouverts et plan d'action 36
Points ouverts, gravité, actions avant commercialisation

6. Informations pour une cession (due diligence) 38
Propriété, licences des composants, dépendances aux prestataires, coûts, reprise par une autre équipe

7. Inventaire des licences 41
Licence de chaque composant libre (serveur, application, outils), analyse et obligations ; annexe CSV

8. Guide fonctionnel de A à Z 46
Ce que fait chaque utilisateur, étape par étape (patient, médecin, secrétariat, pharmacie, laboratoire, administration, secours), automatismes, règles de fonctionnement, glossaire

9. Audit global du code (5 octobre 2026) 60
Réponses point par point aux quinze volets de l'audit (sécurité, créneaux, portabilité, performance, robustesse, métier, sessions, identité des médecins, paiement, SMS, confidentialité, fichiers, accessibilité, supervision, architecture), problèmes classés par gravité et correctifs

10. Que faire en cas d'incident 72
Gestes à faire, dans l'ordre, le jour de l'incident : compte compromis, attaque de mots de passe, site à terre, restauration, fuite d'une clé ; ce qui n'est pas un incident ; rythme hebdomadaire, mensuel et annuel à tenir

Dossier technique et sécurité — Fajma

Version du dossier : 7.7 — 14 octobre 2026 **Périmètre :** code source du dépôt `sante-connect-main` (backend Django, frontend React, déploiement), services tiers. **Public visé :** acquéreurs, investisseurs, auditeurs techniques et juridiques, équipe technique reprenant le projet.

Cette version remplace entièrement la version 1.x, qui décrivait un prototype bâti sur une plateforme propriétaire. Le produit a depuis été entièrement reconstruit : backend Django, base PostgreSQL maîtrisée, **aucune dépendance à une plateforme ou à un hébergeur particulier**. Le code et les données se déplacent d'un serveur à l'autre sans réécriture (§ 4.5).

---

1. Fiche d'identité

Élément	Valeur
Produit	Plateforme de santé pour le Sénégal : prise de rendez-vous, téléconsultation, dossier médical, paiement, assurances, pharmacies
Utilisateurs	Patients (et leurs proches), médecins, cliniques (responsables, secrétariat), pharmaciens, laboratoires d'analyses, administrateurs
Canaux	Site web et application installable (PWA, publiable sur le Play Store), WhatsApp, USSD (tout téléphone, sans internet)
Langues	Français, wolof (à faire relire par un locuteur natif), anglais ; SMS et menus dans la langue du patient
Backend	Python 3.13, Django 6.1, Django REST Framework ; file de tâches `django.tasks`
Frontend	React 19, TanStack Router/Start (mode SPA), Tailwind CSS 4, TypeScript
Base de données	PostgreSQL 17 en production (SQLite en développement)
Hébergement	Docker Compose sur un serveur au choix — **un hébergement au Sénégal est possible sans modification**
Paiement	PayDunya (Wave, Orange Money, Free Money, cartes) ou règlement au cabinet
Messages	Twilio : SMS et WhatsApp ; notifications push du navigateur (Web Push, gratuites)
Téléconsultation	Jitsi Meet (serveur public au démarrage, auto-hébergeable)
Assistant IA	Fournisseur configurable via une API compatible OpenAI (Google Gemini par défaut)
Qualité	429 tests automatisés de l'API ; parcours de bout en bout dans un navigateur réel pour chaque rôle ; intégration continue GitHub Actions
Taille du code	≈ 14 900 lignes Python (hors tests et migrations), ≈ 3 900 lignes de tests, ≈ 32 600 lignes TypeScript/React

2. Contenu du dossier

#	Document	Contenu
1	Architecture	Composants, organisation du code, fonctionnalités, modèle de données, intégrations
2	Sécurité	Authentification, contrôle d'accès, protections, secrets, journal d'audit, tests
3	Données personnelles et conformité	Inventaire des données, sous-traitants, droits des personnes, obligations au Sénégal

#	Document	Contenu
4	Exploitation et déploiement	Installation, mise en production, tâches planifiées, sauvegardes, supervision
5	Risques et plan d'action	Points ouverts, gravité, actions avant commercialisation
6	Informations pour une cession	Propriété, licences des composants, dépendances aux prestataires, coûts, reprise par une autre équipe
7	Inventaire des licences	Licence de chaque composant libre (serveur, application, outils), analyse et obligations ; annexe CSV
8	Guide fonctionnel de A à Z	Ce que fait chaque utilisateur, étape par étape (patient, médecin, secrétariat, pharmacie, laboratoire, administration, secours), automatismes, règles de fonctionnement, glossaire
9	Audit global du code	Réponses point par point aux quinze volets de l'audit (sécurité, créneaux, portabilité, performance, robustesse, métier, sessions, identité des médecins, paiement, SMS, confidentialité, fichiers, accessibilité, supervision, architecture), problèmes classés par gravité et correctifs
10	Que faire en cas d'incident	Gestes à faire, dans l'ordre, le jour de l'incident : compte compromis, attaque de mots de passe, site à terre, restauration, fuite d'une clé ; ce qui n'est pas un incident ; rythme hebdomadaire, mensuel et annuel à tenir

3. Synthèse pour la direction

Ce qui est en place

- **Conçu pour le Sénégal, pas adapté depuis ailleurs.** Ce qui le distingue : prise de rendez-vous **par USSD, depuis n'importe quel téléphone, sans internet** ; téléconsultation et SMS **en wolof comme en français** ; paiement par **Wave et Orange Money** ; prise en charge **IPM, mutuelles CMU et assureurs** avec tiers payant ; **entraide familiale depuis la diaspora** (un proche à l'étranger paie et suit les soins d'un parent au pays) ; **ticket virtuel d'hôpital** qui évite la file d'attente ; catalogue de médicaments fondé sur la **liste nationale des médicaments essentiels**.
- **Et tout le socle attendu d'une plateforme de santé** : réservation (site, WhatsApp, USSD), téléconsultation, dossier médical, ordonnances et certificats vérifiables par QR code, paiement mobile avec commission et reversement aux médecins, abonnements des médecins, carnet de vaccination et suivi de grossesse, ordonnances transmises aux pharmacies, secrétariat de clinique ou de cabinet, télé-expertise entre médecins, visites à domicile, séries de séances (kinésithérapie, soins), remplacements entre médecins, tableau de pilotage.
- **Chaque acteur gère lui-même ses informations** : fiche et photo du médecin, horaires et garde de la pharmacie, informations de la clinique ; l'administration dispose des outils de support (recherche de compte, suspension, réinitialisation de la double authentification, ajout de pharmacies).
- **Le contrôle d'accès est appliqué par le serveur** pour chaque requête, et vérifié par des tests automatisés (tentatives d'accès aux données d'un autre patient, d'un autre médecin, d'une autre pharmacie…).
- **Traçabilité** : chaque consultation d'un dossier par un professionnel est inscrite dans un journal inaltérable, visible par le patient concerné.
- **Argent tracé** : journal comptable non modifiable par médecin ; paiements vérifiés directement auprès de PayDunya ; remboursement automatique en cas d'annulation.
- **Sécurité des comptes** : double authentification (TOTP) **obligatoire pour tous les professionnels et administrateurs**, connexion par code SMS pour les patients, sessions HttpOnly, limites de débit, en-têtes de sécurité et politique CSP stricte.
- **Exploitation** : sauvegardes quotidiennes chiffrées avec test de restauration mensuel automatique, supervision avec alertes email, purge nocturne des données techniques selon des durées de

conservation.
- **Souveraineté** : l'ensemble de la plateforme (base, fichiers, API) peut être hébergé au Sénégal ; les seuls flux sortants sont ceux des prestataires listés (SMS, IA, vidéo si non auto-hébergée).

Ce qui doit être fait avant une commercialisation (détail : plan d'action)

1. **Réglementaire** : autorisation de la CDP pour le traitement de données de santé ; encadrement des transferts hors du Sénégal ; validation par un juriste des CGU et de la politique de confidentialité (projets fournis) ; qualification juridique de l'encaissement pour le compte des médecins.
2. **Téléconsultation** : héberger Jitsi (ou un service contractualisé) au lieu du serveur public.
3. **Validation médicale** : calendrier vaccinal (PEV) et consultations prénatales à faire valider par la Direction de la Prévention ; textes wolof à faire relire.
4. **Test d'intrusion** par un prestataire indépendant, puis exploitation sur l'infrastructure cible (HTTPS, première restauration de sauvegarde, abonnement à un moniteur de disponibilité externe).
5. **Contrats opérateurs** : Twilio (numéros, modèles WhatsApp approuvés), agrégateur USSD, PayDunya en production ; les virements aux médecins et remboursements sont aujourd'hui exécutés manuellement par l'administration, qui en saisit la référence.

4. Méthode

Dossier établi par lecture intégrale du code source, exécution de la suite de tests de l'API (429 tests) et de parcours de bout en bout dans un navigateur réel (Chrome et Edge, ordinateur et mobile) : patient, médecin, médecin remplaçant, clinique, secrétariat, pharmacien, administrateur, activation obligatoire de la double authentification, mode hors ligne sur le build de production.

Limites : les intégrations externes (PayDunya, Twilio, agrégateur USSD, service push des navigateurs, Jitsi) ont été testées avec des réponses simulées, faute d'accès réseau et de comptes de production dans l'environnement d'audit. Le déploiement Docker n'a pas pu être exécuté (composition validée par `docker compose config`) ; en revanche la base PostgreSQL réelle, la sauvegarde, la restauration et les scripts `backup.sh` / `restore-test.sh` ont été exécutés et vérifiés pour de vrai hors Docker (§ 4.5). Ces points sont signalés **« À vérifier »**.

5. Historique des versions

Version	Date	Changements
1.x	2026	Prototype initial, sur une plateforme propriétaire
2.0	29/09/2026	Reconstruction complète (Django, PostgreSQL), dossier réécrit
2.1	30/09/2026	Visites à domicile, séries de séances, remplacements ; double authentification obligatoire pour les professionnels ; outils d'administration ; fiches modifiables par chaque acteur ; supervision, test de restauration, purge des données ; chapitre 6 (cession)
2.2	30/09/2026	Agenda tenu par le cabinet (saisie et déplacement de RDV), pièces jointes dans la messagerie, exports tableur (dont bordereau de tiers payant) ; suivi à domicile (tension, glycémie, poids), rappels de médicaments, laboratoires d'analyses, disponibilité des médicaments en pharmacie, pages publiques des cliniques, « Mes médecins », messagerie avec le remplaçant
2.3	30/09/2026	Mise en service simulée avec de vrais comptes pour chaque rôle. Corrections : la mise à jour du profil ne peut plus effacer ni « garder vérifié » un numéro changé (sécurité) ; géolocalisation automatique des cabinets (recherche par quartier) ; file « À traiter » et menu de l'administration ; notifications de validation, de rattachement, de nouvelle ordonnance et de compte-rendu ; alerte « en-tête d'ordonnance incomplet » ; compte-rendu et ordonnance possibles après « Terminé » ; affichage mobile de l'espace patient et du dossier

Version	Date	Changements
2.4	30/09/2026	Renforcements avant mise en service : fichiers chiffrés sur le disque, antivirus (ClamAV), déconnexion des professionnels après 30 min d'inactivité, alerte de connexion depuis un nouvel appareil, contrôle des failles des bibliothèques serveur (pip-audit)
2.5	30/09/2026	Revue de toutes les pages. Espace médecin en onglets et vrai écran « Emploi du temps » (semaine visuelle, plages sur plusieurs jours, modification, chevauchements refusés, aperçu patient) ; aperçu d'ordonnance (spécimen) ; signature exigeant un vrai tracé ; logo Fajma sur les documents ; page publique « Tarifs » ; accueil sans données inventées (vrais médecins disponibles, allégations non vérifiables retirées) ; déconnexion dans les espaces pharmacie, laboratoire, clinique et administration ; corrections d'affichage mobile
2.6	30/09/2026	Connexion vérifiée pour chaque rôle (dont redirection de la clinique et du secrétariat vers leur agenda, redirection sans erreur au premier chargement) ; page publique « Aide et contact » (questions fréquentes, numéros d'urgence, formulaire) et suivi des demandes dans l'administration ; guide de démarrage du médecin en 7 étapes ; lanceur local `Lancer-Fajma.bat`
2.7	30/09/2026	Agenda du médecin en glisser-déposer (déplacement et durée à la souris ou au doigt, couleur par motif validée daltonisme) ; assistant de prise de notes (dictée vocale, brouillon de compte-rendu par IA ou mise en forme locale, à relire) ; nouveau risque R-19 (transfert des notes au fournisseur d'IA)
2.8	01/10/2026	Renouvellement d'ordonnance à la demande du patient (rappel avant échéance des traitements longs, décision du médecin) ; fiche d'urgence publique par QR code (informations choisies, lien révocable, consultations journalisées) ; alertes aux médecins sur les mesures à domicile dangereuses ou répétées ; animations modernisées ; logo Fajma en tête des ordonnances
2.9	05/10/2026	Chapitre 7 « Inventaire des licences » (outil `tools/inventaire_licences.py`, annexe CSV : aucun composant sous copyleft fort, composants livrés aux navigateurs tous sous licence permissive) ; rapport d'activité mensuel dans l'administration (tableur, impression PDF, sans donnée nominative) ; comptage des patients corrigé (comptes professionnels exclus)
3.0	05/10/2026	Questionnaire du médecin visible dès la réservation sur sa fiche, réponses toujours facultatives (plus de question obligatoire) ; dossier médical complet téléchargeable en PDF par le patient (export journalisé)
3.1	05/10/2026	Dossier complété de A à Z : chapitre 1 mis à jour avec toutes les fonctionnalités (emploi du temps, agenda en glisser-déposer, questionnaire, renouvellements, fiche d'urgence, alertes, assistant de notes, aide et support, tarifs, rapport d'activité, dossier en PDF), tables et intégrations (antivirus) ; nouveau chapitre 8 « Guide fonctionnel de A à Z » (parcours de chaque rôle, automatismes, règles, glossaire) ; chiffres du code actualisés
3.2	05/10/2026	Audit global (sécurité, concurrence, portabilité, performance, robustesse, métier) et correctifs : mode développement impossible par oubli en production (`DJANGO_DEBUG`) ; verrou par compte contre la force brute répartie (10 échecs en 15 min) ; recherche de médecins sans requêtes en cascade (4 requêtes quel que soit le nombre de médecins) ; base de données injoignable = réponse 503 lisible ; **historique de chaque rendez-vous** (qui l'a pris, confirmé, déplacé, annulé, quand), visible du patient, du médecin et du secrétariat ; balayage automatique des accès croisés (IDOR) et test de la contrainte anti-double réservation sous PostgreSQL
3.3	05/10/2026	Nouveau chapitre 9 « Audit global du code » : les six volets de l'audit détaillés question par question, problèmes classés (bloquant, important, mineur), correctifs et tests associés
3.4	05/10/2026	Audit, volets 7 à 15 (chapitre 9) et correctifs : numérotation légale continue des reçus ; désinscription SMS (STOP / START) ; rappels jamais envoyés deux fois ; purge des comptes inactifs avec préavis (désactivée tant que la durée légale n'est pas fixée) ; bouton « Déconnecter mes autres appareils » ; réservation idempotente et refus de réserver chez soi-même ; `/api/health` détaillé pour la supervision ; flux temps réel économe en connexions, PostgreSQL à 200 connexions ; accessibilité WCAG AA (contrastes, libellés, tablette) vérifiée avec axe-core

Version	Date	Changements
3.5	05/10/2026	Recette complète de l'interface de production (§ 9.17, 78 affichages, 7 rôles, téléphone et ordinateur) et correctifs : page blanche au rechargement répété (flux temps réel différé et fermé au départ de la page), page 404 sans erreur, retour de paiement sans référence, débordements sur téléphone, bibliothèques PDF et graphiques chargées à la demande (dossier patient 483 → 309 Ko, espace médecin 413 → 238 Ko)
3.6	05/10/2026	Base de données vérifiée sur un vrai PostgreSQL 17 (§ 4.5, § 9.18) : correction des tests PostgreSQL de l'intégration continue (en échec depuis l'origine, à tort déclarés au vert) et de deux erreurs PostgreSQL de production ; dossiers médicaux et paiements protégés contre la suppression en cascade ; secret de double authentification chiffré ; index, pagination de l'annuaire, agenda borné, requêtes regroupées ; test de volume (200 000 RDV) ; sauvegarde, restauration, transfert SQLite → PostgreSQL et déménagement vérifiés ; sauvegardes toutes les 6 h conseillées
3.7	05/10/2026	Nouveau logo lié au nom : le « f » de Fajma dessine une croix médicale (vert et or du drapeau), sur le site, les PDF, l'icône d'onglet et les icônes de l'application
3.8	05/10/2026	Logo définitif choisi parmi 8 propositions : bulle de consultation portant le « f » en croix médicale (site, PDF, icône d'onglet, icônes de l'application dont l'icône adaptative Android)
3.9	05/10/2026	Catalogue complet de 36 spécialités installé par migration (une base neuve n'en avait aucune) et affiché sur l'accueil ; vraie carte du Sénégal sur l'accueil (contours Natural Earth, médecins à leur cabinet, villes cliquables, lisible sur téléphone)
4.0	05/10/2026	Carte interactive sur l'accueil : zoom, médecins, pharmacies et pharmacies de garde, « Autour de moi » (distances, médecin le plus proche), fiche de chaque lieu avec prise de rendez-vous, itinéraire Google Maps ou Waze et appel ; itinéraires aussi sur la carte de la recherche ; fond de carte réglable pour la production
4.1	05/10/2026	Images de l'accueil remplacées : les photos génériques (applications étrangères en anglais) font place aux vrais écrans de Fajma avec des contenus sénégalais (médecin de Dakar inscrite à l'Ordre, français et wolof, francs CFA, pharmacie du Plateau, SMS de rappel), aux couleurs du drapeau ; images produites par Fajma, sans droits de tiers
4.2	05/10/2026	Étoile verte du drapeau sénégalais ajoutée au centre de la bande jaune : bande du site, PDF (ordonnances, certificats, reçus, dossier médical), images de l'accueil, couverture du dossier ; images de l'accueil simplifiées pour être lisibles en petit
4.3	05/10/2026	Nouvel en-tête des documents PDF choisi parmi 6 propositions : bandeau vert, logo blanc et phrase « Votre santé, simplement », bande tricolore avec l'étoile, titres espacés (ordonnances, certificats, courriers, reçus, dossier médical) ; nouvelle photo « Médecins vérifiés » sur l'accueil
4.4	05/10/2026	Nouveau bas de page des documents PDF choisi parmi 6 propositions : fine bande tricolore avec l'étoile, mention centrée, « fajma.sn · Page x/y » ; le dossier médical et le reçu utilisent désormais le même bas de page
4.5	05/10/2026	Aperçu d'ordonnance du médecin : filigrane Fajma (symbole et nom, vert très pâle) à la place de « SPÉCIMEN » ; l'aperçu reste un exemple (référence SPECIMEN, patient fictif, QR code non vérifiable)
4.6	05/10/2026	**Justificatifs obligatoires pour tous les professionnels** (§ 1, § 8.12) : médecin (Ordre + pièce d'identité), clinique (autorisation du ministère de la Santé, NINEA/RCCM, pièce d'identité du responsable, médecin responsable), pharmacie (autorisation d'exploitation, pharmacien titulaire inscrit à l'Ordre), laboratoire (agrément, biologiste responsable inscrit) ; dates de validité, rappels 30 jours avant et à l'échéance, publication impossible sans toutes les pièces validées et valides ; pharmacies et laboratoires partenaires désormais validés aussi par l'administration ; liste modifiable en un seul endroit. En-tête des PDF allégé à la demande du fondateur : fond blanc, bande tricolore avec l'étoile sous les informations (comme le bas de page) ; le PDF de ce dossier reprend le même en-tête et le même bas de page

Version	Date	Changements
4.7	05/10/2026	**Audit « ce qu'on ne peut pas saisir ou corriger »** sur toutes les interfaces (§ 8.13) : adresse email ajoutable et modifiable (confirmée par un lien envoyé à la nouvelle adresse, mot de passe demandé, ancienne adresse prévenue) ; correction des proches (et leur téléphone), des assurances, des lieux de consultation ; fiche du laboratoire modifiable par le laboratoire et par l'administration ; rôle du secrétariat et titre des médecins modifiables dans la clinique ; suivi de ses demandes d'aide ; correction du nom ou de la spécialité d'un médecin vérifié par l'administration (motif obligatoire, journalisé) ; passage de toutes les pages de tous les rôles dans un navigateur réel sans erreur
4.8	05/10/2026	**Ticket virtuel à l'hôpital** (§ 8.14) : le patient prend son numéro depuis chez lui (site, USSD, WhatsApp), suit sa place et l'attente estimée en direct, reçoit les SMS « c'est bientôt », « partez maintenant » (selon son temps de trajet) et « c'est votre tour, box 2 » ; l'accueil appelle les numéros, gère priorités (femme enceinte, personne âgée, urgence…), absents et tickets remis au guichet (imprimables) ; écran de salle d'attente avec annonce vocale ; bilan du jour et réglage des services pour le responsable ; établissements gérés par l'administration
4.9	05/10/2026	**Entraide familiale (diaspora)** (§ 8.15) : un proche, même à l'étranger, aide un parent au Sénégal avec son accord (code SMS donné au téléphone) ; paiement des consultations par carte bancaire ou mobile money, crédit santé prépayé (montants affichés en euros, parité fixe), remboursement automatique sur le crédit en cas d'annulation, prise de rendez-vous au nom du parent, comptes-rendus et ordonnances si le parent l'accepte (accès journalisé), nouvelles après chaque rendez-vous, alerte de crédit bas et rappel mensuel de recharge
5.0	06/10/2026	**WhatsApp en phrases libres et messages vocaux** (§ 8.16) : « Sama doom dafa am yaram », « un pédiatre à Thiès », « ticket pour l'hôpital » — écrits ou dits dans un message vocal (wolof, français, anglais), compris et menés directement à la bonne étape (spécialité, ville), réponse dans la langue de la personne ; transcription par un service au choix de l'hébergeur (compatible OpenAI, auto-hébergeable), son jamais conservé
5.1	06/10/2026	**Avis médical écrit** (§ 8.17) : sans rendez-vous ni vidéo, pour les zones à faible réseau — symptômes, mesures et photos, paiement d'avance (mobile money ou crédit santé familial), réponse écrite du médecin sous 24 ou 48 h avec ordonnance si besoin, consultation en personne ou urgence conseillée ; sans réponse à temps, annulé et remboursé automatiquement ; aucun créneau d'agenda bloqué
5.2	06/10/2026	**Relais communautaires** (§ 8.18) : les badiénou gokh et agents de santé de quartier, habilités par l'administration, suivent avec leur accord les personnes sans téléphone ni internet (rendez-vous, vaccins, tension, glycémie), avec un tableau des alertes du jour (tension ou sucre dangereux, vaccins en retard, rendez-vous proches) ; transfert complet du dossier à la personne quand elle a un téléphone (accord par code SMS)
5.3	06/10/2026	**Veille épidémiologique anonymisée** (§ 8.19) : consultations par grand syndrome (fièvre / paludisme, dengue, diarrhée, respiratoire, éruption, conjonctivite, méningite), par ville et par semaine, cases de moins de 5 masquées, signal de hausse inhabituelle (moyenne + 2 écarts-types), export tableur ; à partager avec les autorités après accord de la CDP
5.4	06/10/2026	Retrait, à la demande du fondateur, du ticket virtuel à l'hôpital (§ 8.14 supprimé, tables supprimées) et de la transcription des messages vocaux WhatsApp ; les demandes en phrases libres écrites sur WhatsApp restent (§ 8.16)
5.5	06/10/2026	**Diagnostic codé et déclaration des maladies** (§ 8.19) : dans le compte-rendu (et l'avis écrit), le médecin choisit le diagnostic principal dans une liste de 44 maladies (codes CIM-10, inspirée de la SIMR : maladies à déclaration immédiate, surveillance hebdomadaire dont hépatites A/E, B et C, VIH, tuberculose, maladies chroniques, santé de la mère), suspect / probable / confirmé et résultat du test rapide ; maladie à déclaration immédiate : consigne de déclaration au district, administration prévenue, suivi « déclaré / à déclarer » ; veille par région à partir de ce diagnostic ; rapport hebdomadaire SIMR (région × maladie, suspects / confirmés) pour les autorités

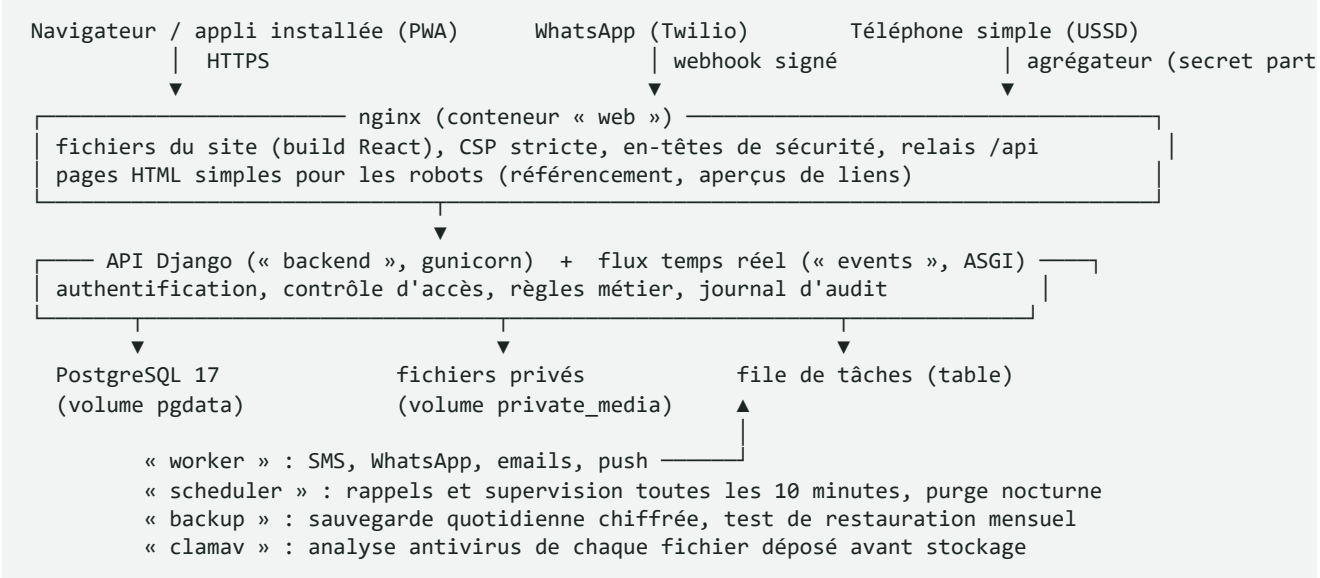
Version	Date	Changements
5.6	06/10/2026	**Partenaires et campagnes sponsorisées** (§ 8.20) : page « Nos partenaires », encarts « Sponsorisé » (accueil, recherche en encart séparé, espace patient) validés par l'administration, charte publicitaire dans les CGU (pas de médicament sur ordonnance, pas de médecin mis en avant contre paiement, ciblage par ville et langue seulement), refus automatique des textes interdits, statistiques agrégées et rapport pour l'annonceur
5.7	06/10/2026	Campagnes : grand bandeau animé en haut de l'accueil (visuel, couleur de la campagne, entrée animée, zoom lent, reflet, bouton qui attire l'œil) et carrousel de 5 campagnes au plus (7 s, points, flèches, pause au survol, ordre aléatoire) ; visuel et couleur choisis dans l'administration ; accueil : bande « Nos partenaires » (logos qui défilent) et lien « Partenaires » dans le menu
5.8	06/10/2026	**Guide d'utilisation dans l'application** (§ 8.21) : page `/guide` avec un chapitre par espace (patient, famille, médecin, clinique et secrétariat, pharmacie, laboratoire, relais, administration), étapes numérotées et astuces, sommaire, recherche dans tous les chapitres, impression ; le lien « Aide » de chaque espace ouvre son chapitre ; liens depuis « Aide et contact » et le pied de page
5.9	06/10/2026	**Fiche d'urgence complète** (§ 8.2) : alertes vitales en tête (14 : diabétique sous insuline, épileptique, drépanocytaire, sous anticoagulant, enceinte…), 3 personnes à prévenir (appel, WhatsApp, envoi de la position des secours par SMS), appareils médicaux, note pour les secours, médecin traitant, assurance, poids ; page des secours en français, wolof ou anglais avec SAMU, pompiers et police ; fiche pour chaque proche (le titulaire est toujours prévenu en premier) ; carte de portefeuille à imprimer ; SMS au titulaire à chaque consultation
6.0	06/10/2026	Fiche d'urgence : **résumé des médecins** au choix du patient (conclusions des 3 dernières consultations sur 12 mois et ordonnances en cours ; jamais les notes privées ni les diagnostics sensibles : VIH, IST, santé mentale) ; médicaments des ordonnances en cours proposés pour « Traitements en cours » (validation d'un clic) ; informations cochées mais vides signalées ; rappel SMS tous les 6 mois « votre fiche est-elle à jour ? » ; mention aux secours si la fiche date de plus d'un an ; QR code sans date d'expiration (révocable, consultation signalée par SMS)
6.1	06/10/2026	Administration réorganisée : **menu par rubriques** avec compteurs (tableau de bord, à valider, utilisateurs, réseau de soins, finances, santé publique, communication, support, système) ; file **« À valider »** (seulement ce qui attend, justificatifs à côté) ; doublons pharmacies et laboratoires fusionnés ; **recherche globale** (comptes, médecins, établissements, pharmacies, laboratoires, ordonnances, paiements) ; **fiche 360° du médecin** ; **annonces groupées** (notification, SMS, email ; nombre de destinataires avant envoi) ; page **Réglages** sans technicien (message du site, contact, USSD, numéro de déclaration, minimum de virement) ; **rôles de l'équipe** contrôlés par le serveur ; journal d'audit filtrable, paginé, exportable
6.2	06/10/2026	**Audit de la base de données** (9.21) : compte PostgreSQL de l'application sans droits d'administrateur (`fajma_app`, créé au premier démarrage, `APP_DB_PASSWORD`) ; sauvegardes obligatoirement chiffrées ; connexion chiffrée exigée vers une base distante ; un établissement n'est plus effaçable par la suppression du compte de son responsable
6.3	06/10/2026	Suite de l'audit de la base : **restauration vérifiée de bout en bout** (`deploy/restore.sh`, une commande ; le test mensuel relit la sauvegarde avec le compte de l'application, ce qui aurait détecté la panne corrigée ici) ; **annonces groupées envoyées en arrière-plan** par paquets, reprise sans doublon ; mesures des écrans d'administration sur base chargée
6.4	06/10/2026	**Sécurité de la prescription** : catalogue d'environ 100 médicaments, alertes allergies, interactions, contre-indications (grossesse, rein, asthme, G6PD…) et âge, alerte majeure à justifier par écrit ; **imagerie médicale** de bout en bout (prescription, centre qui réalise l'examen, résultats) avec alertes grossesse et rayons X, pacemaker et IRM, produit de contraste ; **nomenclature des actes** et **feuille de soins** pour les organismes ; **export du dossier au format international HL7 FHIR R4** ; audit complet de l'application (9.22) : balayage des droits sur les 190 adresses, débordement sur téléphone corrigé, accessibilité sans violation

Version	Date	Changements
6.5	07/10/2026	Règles de réservation revues : **confirmation immédiate** d'un créneau libre (un médecin peut toujours exiger de valider lui-même) ; **annulation toujours possible par le patient**, marquée « tardive » hors délai, avec alerte SMS au cabinet et créneau aussitôt libéré — mieux vaut une annulation tardive qu'une absence découverte sur place
6.6	07/10/2026	**Itinéraire vers le rendez-vous** : carte OpenStreetMap avec le cabinet, la position du patient et le trajet routier tracé (distance et temps de route, calcul OSRM auto-hébergeable), boutons Google Maps et Waze ; repli sur le trajet direct si le service est indisponible
6.7	07/10/2026	Revue des interfaces (9.23) : titre principal ajouté à la recherche de médecins (lecteurs d'écran et référencement) ; **justificatifs adaptés au métier d'un centre d'imagerie** (autorisation d'imagerie, radiologue, radioprotection seulement si rayons X) ; en-tête des espaces pharmacie et laboratoire corrigé ; **dossier du patient rangé en quatre rubriques** (10 685 → 2 639 pixels), les liens déjà envoyés continuent de fonctionner
6.8	07/10/2026	**Flèche de retour dans l'en-tête de chaque page** : revient à la page précédente, ou à la page parente quand il n'y a pas d'historique (lien reçu par SMS, favori, nouvel onglet)
6.9	07/10/2026	**Haut de page du site public** : champ de recherche permanent dans l'en-tête, rubriques sur une seconde ligne, doublon « Professionnels » / « Je suis pro » supprimé, et **menu sur téléphone** là où les rubriques disparaissaient purement et simplement en dessous de 1024 px
7.0	07/10/2026	**Générique d'ouverture** de sept secondes à la première ouverture d'une visite : tracé d'électrocardiogramme, battements qui s'accélèrent, éclat, logo, puis bascule sur la page d'accueil. Une seule fois par visite, bouton « Passer », et désactivé pour qui réduit les animations
7.1	08/10/2026	**Panneau sponsorisé de l'accueil retravaillé** (5 propositions soumises au fondateur) ; accessibilité de l'accueil public corrigée au passage (zone principale `main`, niveaux de titres) : plus aucune violation
7.2	08/10/2026	**La publicité passe sous la promesse de Fajma** : l'accueil s'ouvre sur « Votre santé, simplifiée » et la recherche ; la campagne sponsorisée suit, en bande compacte (vignette, titre, phrase, bouton aux couleurs de la campagne) de 96 pixels au lieu de 288, toujours dans le premier écran sur ordinateur. Le titre de la campagne n'est plus un titre de page, pour que le premier titre de l'accueil reste celui de Fajma
7.3	08/10/2026	**Revue de cybersécurité** (§ 2.5, § 2.9) : analyse statique du code (`bandit`) ajoutée à l'intégration continue, zéro alerte de gravité moyenne ou haute ; les adresses des services externes (IA, SMS, paiement) doivent être en `https://`, sinon l'application refuse de démarrer — un `http://` oublié aurait envoyé notes médicales et clés d'API en clair ; préchargement HSTS désormais activable ; `check --deploy` sans aucun avertissement. Quatre tests dépendaient du jour de la semaine et devenaient rouges les mercredis et jeudis : corrigés. Nouvelle section **« Ce qui n'est pas couvert, et pourquoi »** (test d'intrusion, pare-feu applicatif, détection d'intrusion, déclaration CDP…)
7.4	08/10/2026	**Clés d'accès (passkeys)** (§ 2.2) : connexion par empreinte, visage, code de l'appareil ou clé USB, à la place du code à six chiffres — seule méthode qui ferme l'hameçonnage, le vol de compte le plus courant. La clé privée ne quitte jamais l'appareil ; une base volée n'ouvre aucune session. Éprouvée par 13 tests qui rejouent une vraie attaque de relais. **Alertes de sécurité** : la supervision détecte désormais une vague de mots de passe essayés, des comptes verrouillés en série, des fiches d'urgence consultées en masse et une rafale d'actions sensibles de l'administration ; les alertes graves partent aussi par SMS (`ALERT_PHONES`)
7.5	08/10/2026	**Mises à jour des bibliothèques proposées automatiquement** (Dependabot : serveur, application, actions d'intégration continue ; corrections de sécurité sans attendre). Nouveau chapitre 10 **« Que faire en cas d'incident »**, écrit pour être lu le jour même par quelqu'un qui n'est pas ingénieur : compte de médecin compromis, attaque de mots de passe, site à terre, restauration, fuite d'une clé, et le rythme à tenir. Correction au passage : la réinitialisation par l'administration retire désormais **aussi** les clés d'accès — ne retirer que le code à six chiffres laissait la personne bloquée par une clé restée sur l'appareil perdu

Version	Date	Changements
7.6	09/10/2026	**Dossier remanié pour la lecture** : couverture refaite (titre, repères chiffrés vérifiables, destinataires, mention de confidentialité) et **sommaire avec les numéros de page**, calculés en mesurant réellement chaque chapitre plutôt qu'en les estimant ; chaque ligne renvoie au chapitre. Toute référence aux plateformes du prototype initial a été retirée du dossier : le texte dit désormais ce qui compte pour un acquéreur — aucune dépendance à une plateforme propriétaire, installation sur n'importe quel serveur Linux
7.7	14/10/2026	**Aucun nom de concurrent dans le dossier ni dans le code** : la synthèse ne se compare plus à une plateforme étrangère, elle dit ce que Fajma est — rendez-vous par USSD sans internet, wolof et français, Wave et Orange Money, IPM et mutuelles CMU, entraide familiale depuis la diaspora, ticket virtuel d'hôpital, liste nationale des médicaments essentiels. Commentaire et fichier de tests renommés en conséquence

1. Architecture

1.1 Vue d'ensemble



Services externes : PayDunya (paiement), Twilio (SMS, WhatsApp), service push des navigateurs, Jitsi (vidéo), fournisseur d'IA (assistant d'orientation ; assistant de prise de notes, désactivé par défaut en production), agrégateur USSD, fournisseur SMTP (emails). Les fichiers sont chiffrés par l'application avant d'être écrits sur le disque (clé conservée hors des sauvegardes).

1.2 Organisation du code

Dossier	Rôle
`backend/sunusante/`	Configuration, routes de l'API, outils communs (validation des entrées ; fichiers déposés : contrôle du type, antivirus, chiffrement), tableau de pilotage, rapport d'activité, exports tableur
`backend/accounts/`	Comptes, connexion (mot de passe, code SMS, double authentification), déconnexion après inactivité, alerte « nouvel appareil », profil, proches, export et suppression des données, outils d'administration
`backend/directory/`	Annuaire, fiches médecin, emploi du temps (plages, absences), guide de démarrage, avis et modération, justificatifs de tous les professionnels (liste des pièces exigées : `requirements.py`), remplacements, référencement
`backend/appointments/`	Rendez-vous, calcul des créneaux, questionnaire avant consultation, liste d'attente, téléconsultation, historique automatique de chaque rendez-vous (`history.py`)
`backend/payments/`	Paiements PayDunya, journal comptable des médecins, virements, remboursements, abonnements
`backend/insurance/`	Organismes (IPM, CMU, assureurs), couvertures des patients, tiers payant
`backend/medical/`	Comptes-rendus, ordonnances (en-tête, signature), certificats et arrêts de travail, documents, profil de santé, rappels, renouvellements d'ordonnance, fiche d'urgence (QR code), assistant de prise de notes, export du dossier en PDF
`backend/carnet/`	Carnet de vaccination (calendrier PEV), suivi de grossesse (CPN), rappels
`backend/pharmacy/`	Pharmacies partenaires, ordonnances transmises et leur préparation

Dossier	Rôle
`backend/clinics/`	Cliniques, secrétariat, agenda partagé, fichier patients et doublons
`backend/expertise/`	Télé-expertise et messagerie entre médecins
`backend/messaging/`	Messagerie patient ↔ médecin
`backend/bots/`	Menu WhatsApp et USSD (moteur commun, textes en trois langues)
`backend/notifications/`	SMS/WhatsApp, emails, notifications push, tâches en arrière-plan, rappels planifiés
`backend/care/`	Suivi à domicile (mesures, repères indicatifs, alertes aux médecins) et rappels de prise de médicaments
`backend/labs/`	Laboratoires d'analyses : prescription, choix du laboratoire, prélèvement, dépôt des résultats
`backend/support/`	Demandes d'aide envoyées depuis la page « Aide et contact », suivies par l'administration
`backend/partners/`	Partenaires (page publique, logos) et campagnes sponsorisées : charte, validation, emplacements, ciblage ville / langue, statistiques agrégées par jour
`backend/medical/medicines.py`	Catalogue des médicaments (liste nationale des médicaments essentiels du Sénégal), familles d'allergie, interactions, contre-indications selon l'état du patient, limites d'âge. Fichier unique à faire valider par la Direction de la Pharmacie
`backend/medical/safety.py`	Contrôle de sécurité d'une ordonnance et d'un examen d'imagerie : reconstitue l'état du patient (allergies, traitements en cours, maladies, grossesse, âge) et produit les alertes
`backend/medical/fhir.py`	Export du dossier au format international **HL7 FHIR R4** (Patient, Encounter, Condition, MedicationRequest, Observation, DiagnosticReport, Immunization…)
`backend/labs/imaging.py`	Types d'examens d'imagerie (radio, échographie, doppler, scanner, IRM, mammographie…), préparation et examens courants
`backend/insurance/acts.py`	Nomenclature des actes professionnels : lettres-clés et coefficients ; le tarif de base est le produit des deux
`backend/insurance/billing.py`	Codage des actes d'une consultation, calcul de la base de remboursement, feuille de soins, tarifs conventionnels
`backend/backoffice/`	Outils de l'équipe : rôles des administrateurs (contrôle unique sur toutes les adresses `/api/admin/…`, `roles.py`), réglages modifiables sans technicien (liste fermée et validée, `settings_registry.py`), annonces groupées, recherche globale, fiche 360° du médecin, journal d'audit filtrable et exportable
`backend/community/`	Relais communautaires : habilitation, personnes suivies (accord, repères), alertes, transfert générique du dossier d'un proche vers son propre compte
`backend/econsult/`	Avis médical écrit : offre du médecin (prix, délai), demandes (symptômes, mesures, photos), réponse et ordonnance, délais dépassés remboursés ; chaque demande est un rendez-vous de mode « async » sans durée
`backend/family/`	Entraide familiale : liens d'entraide (accord par code SMS, droits), crédit santé (recharges payées en ligne, journal des mouvements), paiement par un proche, nouvelles au proche
`backend/audit/`	Journal d'audit inaltérable ; commandes d'exploitation `monitor` (supervision), `purge_data` (conservation), `encrypt_files` (chiffrement et rotation de clé)
`backend/tests/`	Tests automatisés de l'API
`src/`	Interface React : `api/` (appels à l'API), `routes/` (pages), `components/`, `lib/` (traductions, dates, PDF)
`public/`	Manifeste PWA, service worker (hors ligne, notifications), icônes

Dossier	Rôle
`deploy/`	Docker Compose, images, nginx, politique CSP, variables de production, sauvegarde et test de restauration
`tools/`	`inventaire_licences.py` : inventaire des licences des composants (chapitre 7)
`docs/dossier-technique/`	Ce dossier (Markdown), son PDF et l'annexe des licences
`Lancer-Fajma.bat`	Lancement local en un double-clic (serveur et interface), pour une démonstration sous Windows

1.3 Fonctionnalités

Domaine	Détail
Recherche	Spécialité, ville, nom (sans accents), langue parlée, assurance acceptée, prix, disponibilité (aujourd'hui, semaine), téléconsultation, tri, carte (OpenStreetMap)
Réservation	Créneaux calculés par le serveur (plages, absences, délai minimal, horizon, durée du motif), multi-lieux, pour soi ou un proche, confirmation automatique ou par le médecin, anti-chevauchement garanti en base (contrainte d'exclusion PostgreSQL)
Visites à domicile	Plages horaires dédiées (trajet compris), supplément de déplacement, zone desservie, adresse + repère + position GPS facultative, itinéraire pour le médecin
Séries de séances	Motif réservable en série (kiné, pansements : 2 à 20 séances, tous les 1/2/3/7/14 jours), aperçu des dates libres, un seul message récapitulatif, annulation de la suite de la série ; le médecin ou le secrétariat peut ajouter des séances à tout rendez-vous
Remplacements	Le titulaire propose une période à un confrère vérifié, qui accepte ; l'agenda reste ouvert, le remplaçant reçoit les patients, accède au dossier pendant la période et signe à son nom (mention « remplaçant du Dr X ») ; paiements versés au titulaire
Questionnaire	Chaque médecin rédige ses questions (oui/non, choix, texte libre), par défaut ou propres à un motif ; le patient les voit dans le panneau de réservation de la fiche et y répond s'il le souhaite — **jamais obligatoire** —, ou plus tard depuis son espace ; réponses dans l'agenda du médecin
Après réservation	Déplacement, annulation (délai fixé par le médecin), fichier agenda `.ics`, rappels 24 h et 2 h, liste d'attente avec alerte
Téléconsultation	Salle d'attente, prépaiement optionnel, salle vidéo au nom aléatoire ouverte par le médecin
Dossier patient	Profil de santé, documents (PDF, images), partage explicite avec un médecin, comptes-rendus, ordonnances, certificats, journal des accès (« qui a consulté mon dossier »), **dossier complet téléchargeable en PDF**, export des données (JSON) et suppression du compte
Renouvellement d'ordonnance	Le patient demande le renouvellement d'une ordonnance de moins d'un an (message facultatif) ; rappel SMS 7 jours avant la fin des traitements longs ; le médecin prescripteur renouvelle (nouvelle ordonnance signée, mêmes médicaments) ou refuse avec un motif
Fiche d'urgence	Activée par le patient, qui choisit les informations visibles (groupe sanguin, allergies, traitements, antécédents, personne à prévenir) ; QR code à mettre en fond d'écran ; page publique pour les secours avec appel du SAMU ; lien révocable ; consultations journalisées et signalées au patient
Documents médicaux	Ordonnances, certificats, arrêts de travail, courriers : PDF signé électroniquement avec QR de vérification publique (sans contenu médical ni identité complète)
Carnet de santé	Calendrier vaccinal PEV de chaque enfant (statuts à faire / en retard / fait, dose vérifiée par le médecin), suivi de grossesse (terme, 8 consultations prénatales), déclaration de naissance qui crée le carnet du bébé, rappels SMS
Argent	Paiement mobile ou au cabinet ; commission selon l'abonnement du médecin ; solde et demandes de virement ; remboursement automatique en cas d'annulation d'un RDV payé ; reçu servant de feuille de soins

Domaine	Détail
Assurances	Couvertures du patient (numéro, taux, validité, pour un proche) ; organismes acceptés par le médecin, avec ou sans tiers payant ; part patient calculée et figée à la réservation
Pharmacies	Envoi d'une ordonnance à une pharmacie partenaire, préparation (reçue → en préparation → prête / indisponible → retirée), montant, notification du patient
Clinique	Équipe médicale, secrétariat, agenda partagé, RDV au guichet (même sans compte), fichier patients, détection et fusion des doublons, rattachement au compte du patient ; le responsable modifie les informations de l'établissement et retire un médecin qui part
Suivi à domicile	Le patient note tension, glycémie (g/L, à jeun ou après repas) et poids, pour lui ou un proche ; courbe, repères indicatifs (tension ≥ 180/110 : conseil d'appeler le 1515 ; hypoglycémie < 0,7 g/L) ; les médecins qui le suivent voient la courbe dans la fiche patient et **sont alertés** d'une valeur dangereuse ou élevée 3 fois en 7 jours (3 médecins au plus, une alerte par 24 h, désactivable par le patient)
Rappels de médicaments	Heures de prise (1 à 6 par jour), durée du traitement, pour soi ou un proche, à partir d'une ordonnance ou en saisie libre ; notification gratuite, SMS/WhatsApp en option ; envoi par le planificateur, sans doublon
Laboratoires	Le médecin prescrit des analyses pendant la consultation ; le patient choisit un laboratoire partenaire ; le laboratoire enregistre le prélèvement et dépose les résultats (PDF), qui rejoignent le dossier du patient et sont partagés avec le prescripteur ; patient et médecin prévenus
Disponibilité des médicaments	« Avez-vous ce médicament ? » : le patient interroge jusqu'à 5 pharmacies partenaires (5 demandes par jour), qui répondent sous 24 h (disponible, prix, indisponible) sans connaître son identité
Annuaire	Pages publiques des cliniques et centres de santé vérifiés, avec leurs médecins et prochains créneaux (les cabinets individuels n'y figurent pas) ; « Mes médecins » : médecins consultés et reprise de RDV en un clic
Agenda tenu par le cabinet	Le médecin (ou son secrétariat) saisit un RDV pris au téléphone ou au cabinet, pour un patient connu ou sans compte, et **déplace** un RDV (patient prévenu par SMS) ; hors plages en ligne autorisé, jamais sur un autre RDV ni pendant une absence
Exports	Tableur (CSV pour Excel) : rendez-vous, **bordereau de tiers payant** par organisme, revenus ; agenda de la clinique ; chaque export est journalisé
Messagerie	Patient ↔ médecin, y compris le remplaçant qui l'a reçu ; texte et **pièces jointes** (photo ou PDF, type réel contrôlé, 6 Mo), accessibles aux seuls participants du fil
Espace médecin	Organisé en onglets : Rendez-vous, Emploi du temps, Profil et cabinet, Ordonnances, Secrétariat et remplacements, Finances, Sécurité. Fiche publique modifiable (présentation, tarif, langues, téléconsultation, adresse) et photo ; nom et spécialité figés après vérification ; « Mon secrétariat » : un médecin seul donne l'accès à son agenda à sa secrétaire par simple email ; **guide « Bien démarrer »** en 7 étapes
Emploi du temps	Semaine type visuelle ; plage ajoutée à plusieurs jours d'un coup ; clic sur une plage pour la modifier ou la supprimer ; chevauchements refusés ; plages « visites à domicile » ; absences ; aperçu des créneaux réellement proposés aux patients
Agenda en glisser-déposer	Vue semaine : un rendez-vous se déplace (autre jour, autre heure) ou change de durée à la souris ou au doigt, par pas de 5 minutes, après confirmation ; contrôle du serveur et patient prévenu ; couleur par motif (palette validée pour les daltoniens), « à confirmer » en pointillés
Rédaction médicale	En-tête d'ordonnance (n° d'Ordre, cabinet, signature tracée, cachet) obligatoire avant toute ordonnance ; aperçu d'une ordonnance spécimen ; **assistant de prise de notes** : dictée vocale et brouillon de compte-rendu (IA si autorisée, sinon mise en forme locale), toujours relu par le médecin
Espace pharmacie	Horaires, jours d'ouverture, coordonnées et **garde** (avec date de fin, retrait automatique de la liste des pharmacies de garde) gérés par le pharmacien
Administration	Bandeau « À traiter » ; validation des médecins et établissements, justificatifs, modération, finances (virements, remboursements), rattachement des pharmaciens et laboratoires, recherche de comptes, suspension/réactivation, réinitialisation de la double authentification, ajout et correction des pharmacies, **demandes d'aide (support)**, rappels SMS, journal d'audit, **rapport d'activité mensuel** (tableur, PDF)

Domaine	Détail
Aide et contact	Page publique : numéros d'urgence, 20 questions fréquentes par profil avec recherche, formulaire de contact (limité contre les abus) ; lien « Aide » dans chaque espace
Spécialités	**Catalogue de 36 spécialités** (médecine générale, pédiatrie, gynécologie-obstétrique, sage-femme, cardiologie, ORL, psychiatrie, kinésithérapie, chirurgie dentaire, radiologie, maladies infectieuses et tropicales…), défini dans `backend/directory/specialties.py` et installé par migration sur toute base (avant, il n'existait que dans les données de démonstration : une base neuve n'avait aucune spécialité) ; toutes affichées sur l'accueil avec le nombre de praticiens ; l'assistant d'orientation choisit parmi ce catalogue
Pages publiques	Accueil (médecins réellement disponibles, sans données inventées ; **carte interactive** OpenStreetMap : zoom et déplacement, médecins, pharmacies et pharmacies de garde à leur adresse, « Autour de moi » avec distances et médecin le plus proche, fiche de chaque lieu avec prise de rendez-vous, **itinéraire Google Maps ou Waze** (trajet calculé par l'application GPS du téléphone) et appel ; carte dessinée du Sénégal, Natural Earth, si la carte ne peut pas se charger), recherche, fiche médecin (itinéraire, assurances, avis, questionnaire), spécialités, cliniques, pharmacies (ouverte/fermée, garde), **tarifs des professionnels**, vérification d'ordonnance, aide, mentions légales, CGU, confidentialité
Médecins entre eux	Télé-expertise avec dossier et documents partagés (patient informé), messagerie
Confiance	Avis après consultation, réponse du médecin, signalement, modération ; publication d'un médecin conditionnée à la validation de son inscription à l'Ordre
Canaux	WhatsApp, USSD, notifications push, messages et alertes en temps réel (Server-Sent Events), application installable, mode hors ligne, module de réservation intégrable au site du médecin
Agenda du médecin	Abonnement privé à ses RDV depuis Google Agenda / Outlook / iPhone (initiales seulement) ; import de ses occupations personnelles (adresse iCal secrète), qui bloquent les créneaux
Pilotage	Activité hebdomadaire, taux d'absence, part de téléconsultation, canaux, spécialités et villes, volumes financiers ; rapport mensuel pour un acquéreur ou un investisseur (patients, consultations, chiffre d'affaires, fidélité), sans donnée nominative
Interface	Mode clair et sombre, français / wolof / anglais, animations sobres (fondu entre les pages, désactivées si l'appareil le demande), affichage adapté au téléphone, logo Fajma sur tous les documents. **En-tête des documents PDF** (allégé à la demande du fondateur) : fond blanc, logo Fajma vert et sa phrase « Votre santé, simplement », médecin à gauche et cabinet à droite (ou patient, ou titre du reçu), fine bande tricolore avec l'étoile sous ces informations (assortie au bas de page), titre en capitales espacées ; **bas de page** (choisi parmi 6 propositions) : fine bande tricolore avec l'étoile, mention centrée, « fajma.sn · Page x/y » en vert ; communs aux ordonnances, certificats, courriers, reçus et dossier médical (`drawBrandBand` , `drawFooter` , `src/lib/pdf-common.ts`). **Logo** (choisi par le fondateur parmi 8 propositions) : une bulle de consultation verte, l'échange entre le patient et son médecin, qui porte le « f » de Fajma dessiné en croix médicale, cœur doré au centre (vert et or du drapeau) ; une seule définition (`src/lib/fajma-mark.ts`) reprise par le site, les PDF, l'icône d'onglet (`favicon.svg` , `favicon.ico`) et les icônes de l'application installée (dont l'icône adaptative Android)
Référencement	Plan du site, pages HTML pour les robots, données structurées schema.org

1.4 Modèle de données (principales tables)

Table	Contenu
`accounts_user` , `accounts_relative`	Comptes (email et/ou téléphone vérifié, langue, date du préavis de compte inactif), proches
`accounts_twofactor` , `accounts_otpcode` , `accounts_knowndevice`	Double authentification, codes SMS (empreintes uniquement), navigateurs déjà utilisés (jeton haché)

Table	Contenu
`directory_doctor`, `…_doctorlocation`, `…_doctoravailability`, `…_timeoff`, `…_consultationtype`	Fiches (photo, visites à domicile), lieux, plages (cabinet ou domicile), absences, motifs, tarifs, séries, questionnaires
`directory_replacement`	Remplacements entre médecins (période, statut)
`directory_pharmacy`	Officines (horaires, jours d'ouverture, garde et fin de garde)
`directory_review`, `directory_credential`	Avis (modération, réponse) ; justificatifs des médecins, cliniques, pharmacies et laboratoires (un seul titulaire par pièce, contrainte en base ; type, statut, date de fin de validité, contrôleur, date du rappel d'échéance)
`appointments_appointment`, `…_appointmentseries`, `…_waitlistentry`	Rendez-vous (canal, assurance figée, questionnaire, adresse de visite, médecin remplaçant, rang dans une série), séries de séances, liste d'attente
`appointments_appointmentevent`	Historique des rendez-vous : action (pris, confirmé, déplacé, annulé, terminé, absent, arrivé), auteur, ancien et nouvel horaire ou statut, motif ; écrit automatiquement à chaque modification, quelle que soit son origine
`payments_payment`, `…_refund`, `…_payout`, `…_ledgerentry`, `…_subscription`, `…_subscriptionpayment`	Paiements (avec numéro de reçu légal), remboursements, virements, journal comptable, abonnements
`payments_receiptcounter`	Compteur annuel des reçus : numérotation continue, sans trou ni doublon
`insurance_insurer`, `…_patientcoverage`, `…_doctorinsurer`	Organismes, couvertures, organismes acceptés
`medical_*`	Comptes-rendus, ordonnances, documents, partages, profils de santé (dont réglages de la fiche d'urgence et des alertes), notes privées, rappels, documents rédigés, demandes de renouvellement
`carnet_*`	Doses de vaccin, rappels envoyés, grossesses, consultations prénatales
`pharmacy_*`	Pharmaciens rattachés, ordonnances transmises
`clinics_*`, `expertise_*`, `messaging_*`	Cliniques et personnel, télé-expertise, messages
`notifications_*`	Notifications, rappels SMS, abonnements push, numéros désinscrits des SMS (`smsoptout` : STOP)
`bots_botsession`	Conversations WhatsApp/USSD en cours
`care_measurement`, `care_medicationreminder`	Mesures à domicile, rappels de médicaments
`labs_laboratory`, `…_laboratorymember`, `…_laborder`	Laboratoires, personnel rattaché, prescriptions d'analyses et résultats
`pharmacy_medicinequery`, `…_medicineanswer`	Demandes de disponibilité d'un médicament et réponses des pharmacies
`support_supportrequest`	Demandes d'aide (nom, contact, sujet, message, statut, note interne)
`medical_medicalrecord` (champs `condition_code`, `condition_status`, `test_result`), `medical_diseasenotification`	Diagnostic principal codé du compte-rendu (catalogue `medical/conditions.py`, CIM-10) ; cas de maladies à déclaration immédiate et leur déclaration au district (date, référence, sans identité du patient)
`medical_healthprofile` (alertes vitales, personnes à prévenir, appareils, note pour les secours), `medical_relativeemergencycard`	Fiche d'urgence complète, pour soi et pour chaque proche (jeton propre, informations du proche)

Table	Contenu
`econsult_asyncoffer`, `…_asyncrequest`	Offre d'avis écrit du médecin ; demandes (rendez-vous associé, symptômes, mesures, délai, réponse, conclusion) ; photos rangées dans les documents du patient et partagées avec le seul médecin
`family_carelink`, `…_credittopup`, `…_creditentry`	Liens d'entraide (proche aidant, bénéficiaire, droits, accord, retrait, rappels), recharges du crédit santé (reçu numéroté), mouvements du crédit (jamais modifiés ni supprimés, un seul débit et un seul remboursement par paiement) ; `payments_payment.payer` : proche qui a payé
`audit_auditevent`	Journal d'audit (aucune modification ni suppression possible par l'application)

Identifiants : UUID aléatoires (aucun identifiant séquentiel devinable dans les URL). Montants : entiers en francs CFA. Heures : stockées en UTC, affichées à l'heure de Dakar (UTC+0 toute l'année).

1.5 Intégrations externes

Service	Usage	Mode de sécurisation	Comportement sans configuration
PayDunya	Paiement des consultations et abonnements	Clés serveur ; statut relu auprès de PayDunya (jamais cru depuis le navigateur ou la notification)	Paiement au cabinet uniquement
Twilio	SMS, WhatsApp (rappels, codes, robot)	Jeton serveur ; webhook entrant vérifié par signature ; repli WhatsApp → SMS	Envoi désactivé (journalisé)
Agrégateur USSD	Menu USSD	Secret partagé (en-tête), numéro fourni par l'opérateur	Point d'entrée refusé
Web Push	Notifications sur le téléphone	Clés VAPID ; abonnements expirés supprimés	Fonction masquée
Jitsi	Vidéo	Nom de salle aléatoire, lien visible seulement pour le médecin et son patient	—
Agenda personnel du médecin (iCal)	Import des occupations	HTTPS uniquement, adresses internes refusées (y compris après redirection), 2 Mo et 15 s maximum, horaires seuls conservés	Fonction inactive
IA (compatible OpenAI)	Assistant d'orientation ; assistant de prise de notes	Clé serveur ; limite de débit ; aucun stockage des symptômes ; notes envoyées sans identité du patient, seulement si `AI_NOTES_ENABLED`	Orientation : « non configuré » ; notes : mise en forme locale sans IA
ClamAV (service `clamav`)	Antivirus des fichiers déposés	Analyse avant stockage ; fichier refusé s'il est infecté ou si l'antivirus est injoignable	Pas d'analyse (développement)
SMTP	Emails	Identifiants serveur	Emails affichés dans la console (développement)

1.6 Dépendances principales

Backend (`backend/requirements.txt`) : Django 6.1, djangorestframework, django-tasks-db, psycopg 3, gunicorn, whitenoise, cryptography (chiffrement des fichiers), sentry-sdk, python-dotenv, pywebpush, icalendar. Frontend livré aux navigateurs : React 19, TanStack Router/Start/Query, Leaflet, Recharts, pdf-lib, qrcode, lucide-react, sonner, zod (49 composants au total) ; construction : Vite, TypeScript, Tailwind CSS 4. Inventaire complet et licences : chapitre 7.

2. Sécurité

2.1 Principes

1. **Le serveur décide** : chaque requête est authentifiée et chaque accès à une donnée est vérifié par l'API Django, quel que soit ce qu'affiche l'interface.
2. **Le navigateur n'est jamais cru sur parole** : prix, durées, statuts, parts d'assurance, rôles, statuts de paiement et types de fichiers sont déterminés ou contrôlés par le serveur.
3. **Moindre accès aux données de santé** : un professionnel ne voit que ce qui lui est nécessaire, pour une durée et un périmètre définis (§ 2.4), et chaque consultation est tracée.
4. **Traçabilité inaltérable** : journal d'audit et journal comptable ne peuvent être ni modifiés ni supprimés par l'application.
5. **Validation systématique des entrées** : types, longueurs, formats, UUID, listes de valeurs autorisées.

2.2 Authentification

Élément	Implémentation
Méthodes	Téléphone + code SMS à 6 chiffres (méthode par défaut) ; email + mot de passe
Mots de passe	10 caractères minimum, validateurs Django (mots courants, similarité), hachage PBKDF2-SHA256
Codes SMS	Stockés sous forme d'empreinte, 10 minutes de validité, 5 essais, 3 envois par 10 minutes et par numéro
Clés d'accès (passkeys, WebAuthn/FIDO2)	Empreinte, visage, code de l'appareil ou clé USB, à la place du code à six chiffres. **Seule méthode qui ferme l'hameçonnage** : le navigateur ne présente la clé qu'au domaine qui l'a créée et signe ce domaine, donc un faux site ne peut rien en faire, même si la personne clique sur son lien. La clé privée ne quitte jamais l'appareil : seule la clé publique est en base, une base volée n'ouvre aucune session. Plusieurs appareils par compte ; le compteur d'utilisations est vérifié (une clé copiée se trahit). Le code à six chiffres reste disponible en secours, et un professionnel ne peut pas retirer sa dernière seconde étape. Réglages `PASSKEY_RP_ID` / `PASSKEY_ORIGINS`
Double authentification	TOTP (applications d'authentification), codes de secours à usage unique (empreintes), anti-rejeu du même code. **Obligatoire** pour tout compte professionnel (médecin, pharmacien, clinique, secrétariat, administrateur) : tant qu'elle n'est pas activée, l'API refuse tout sauf les routes de compte (`accounts/security.py`). La connexion par mot de passe seul de `/django-admin/` est supprimée. L'administration peut la réinitialiser (téléphone perdu), action journalisée
Comptes	Changement de mot de passe (déconnexion des autres appareils, email d'alerte) ; suspension d'un compte par l'administration (sessions coupées, fiche médecin retirée de l'annuaire), journalisée avec son motif
Session	Cookie HttpOnly, `Secure` en production, `SameSite=Lax`, 14 jours ; protection CSRF (jeton en en-tête). **Comptes professionnels : fermée après 30 minutes sans activité de l'utilisateur** (`PRO_IDLE_MINUTES`, `IdleTimeoutMiddleware`) ; les rafraîchissements automatiques de l'écran ne comptent pas (l'application transmet le temps écoulé depuis le dernier clic ou la dernière frappe) ; retour à la connexion puis à la page en cours
Nouvel appareil	Chaque navigateur reçoit un jeton aléatoire (cookie HttpOnly, conservé haché en base, oublié après 2 ans sans usage). Une connexion depuis un navigateur jamais utilisé par le compte déclenche une alerte au titulaire (email, ou SMS s'il n'a pas d'email) : vol de mot de passe, de session ou de puce téléphonique (« SIM swap ») repéré immédiatement
Réinitialisation	Lien signé à usage unique envoyé par email ; réponse identique que le compte existe ou non
Canaux sans application	WhatsApp : signature Twilio vérifiée ; USSD : secret partagé avec l'agrégateur. Le numéro, garanti par l'opérateur, identifie le patient ; seuls les comptes au numéro vérifié sont utilisés

2.3 Rôles

Rôle	Attribution
Patient	Inscription
Médecin	Fiche créée dans l'espace pro ; **publiée seulement après validation par l'administration d'une preuve d'inscription à l'Ordre**
Responsable / secrétariat de clinique	Création d'un établissement / ajout par le responsable
Secrétaire d'un médecin seul	Ajoutée par le médecin (« Mon secrétariat ») ; cabinet créé en coulisses, mêmes droits qu'un secrétariat de clinique
Médecin remplaçant	Proposé par le titulaire, accepté par le remplaçant (médecin vérifié) ; droits limités à la période et aux patients concernés
Pharmacien	Rattachement à une officine par l'administration, après vérification
Laboratoire d'analyses	Rattachement à un laboratoire par l'administration, après vérification ; ne voit que les prescriptions que les patients lui ont envoyées
Aide à la prescription	Le contrôle (allergies, interactions, contre-indications, âge) est **une aide, jamais une autorisation** : le médecin reste seul responsable. Une alerte majeure arrête l'enregistrement tant qu'une justification écrite n'est pas donnée ; cette justification est conservée avec l'ordonnance et inscrite au journal. Le contrôle est refait côté serveur : il ne peut pas être contourné depuis le navigateur. Un médicament absent du catalogue est explicitement signalé comme non vérifié
Export du dossier au format FHIR	Réservé au titulaire du compte (ses données et celles de ses proches), journalisé comme tout export ; aucune pièce jointe n'y figure (les fichiers restent chiffrés et se téléchargent séparément)
Application → base PostgreSQL	Compte `fajma_app` sans droits d'administrateur PostgreSQL (vérifié : création de base ou de compte, exécution de commandes sur le serveur, lecture de ses fichiers refusées) ; connexion chiffrée exigée si la base est sur une autre machine ; aucune requête SQL écrite à la main (pas d'injection SQL)
Administrateur	Accès donné par un super-administrateur (rubrique « Système », journalisé), avec un **rôle** : validations, support, finances, santé publique, communication ou super-administrateur. Chaque rôle n'ouvre que ses rubriques ; le serveur le vérifie deux fois (intergiciel sur toutes les adresses `/api/admin/…` et contrôle dans chaque vue) ; une adresse inconnue est réservée au super-administrateur. Un compte d'équipe sans rôle enregistré est super-administrateur (le fondateur). Personne ne modifie son propre accès

Tous les rôles autres que « patient » exigent la double authentification (§ 2.2).

2.4 Matrice des droits (données sensibles)

Donnée	Patient	Médecin	Clinique	Pharmacien	Confrère (télé-expertise)
Profil de santé	Lecture / écriture	Si RDV confirmé ou terminé avec lui	—	—	Si joint à une demande, patient informé
Documents déposés	Tous les siens	Seulement ceux que le patient lui a partagés, et s'il le suit	—	—	Seulement ceux joints à la demande
Comptes-rendus, notes privées	Comptes-rendus	Les siens	—	—	—

Donnée	Patient	Médecin	Clinique	Pharmacien	Confrère (télé-expertise)
Ordonnance	Les siennes	Celles qu'il a rédigées	—	Uniquement celle transmise à son officine, tant qu'elle est en cours	—
Carnet de vaccination	Le sien et celui de ses enfants	Inscription d'une dose lors d'un RDV confirmé	—	—	—
RDV	Les siens	Son agenda	Agenda de ses médecins	—	—
Campagnes sponsorisées	Affichage seulement	Aucune donnée transmise à l'annonceur (ciblage par ville et langue, jamais par données de santé ; statistiques agrégées)	—	—	Création, validation après contrôle de la charte
Entraide familiale	—	Le bénéficiaire voit qui l'aide et retire chaque droit à tout moment	Le proche aidant : rendez-vous et paiements ; comptes-rendus et ordonnances seulement si le bénéficiaire l'a accepté (chaque consultation journalisée, visible du patient)	—	—
Adresse email du compte	—	La sienne (changement confirmé par un lien envoyé à la nouvelle adresse, mot de passe demandé, ancienne adresse prévenue, journalisé)	—	—	—
Justificatifs (médecin, clinique, pharmacie, laboratoire)	—	Les siens	—	Le responsable de la clinique, les membres de la pharmacie ou du laboratoire, pour leur établissement	— (administration seulement ; chaque ouverture de fichier journalisée)

Donnée	Patient	Médecin	Clinique	Pharmacien	Confrère (télé-expertise)
Fiche d'urgence (QR code)	Activation et choix des informations	—	—	—	Toute personne qui scanne le QR code : nom, âge et seulement les informations choisies ; consultation journalisée, patient prévenu
Demande de renouvellement	Les siennes	Celles adressées à lui (médecin prescripteur)	—	—	—
Dossier médical complet (export PDF)	Le sien et celui de ses proches, à la demande (journalisé)	—	—	—	—
Réponses au questionnaire	Les siennes (facultatives)	Celles des RDV de son agenda	—	—	—

Médecin remplaçant : pendant la période du remplacement (de la veille jusqu'à 30 jours après la fin), il voit les RDV qu'il assure, les comptes-rendus et ordonnances du titulaire pour les patients qu'il reçoit, et les documents que ces patients ont partagés avec le titulaire ; jamais les notes privées du titulaire. Il signe ses documents à son nom et à son numéro d'Ordre, avec la mention « remplaçant du Dr X ». Le titulaire voit ce que son remplaçant a rédigé pour ses patients.

Laboratoire : nom, âge, sexe et téléphone du patient, analyses demandées et médecin prescripteur, pour les seules prescriptions que le patient lui a adressées ; dépose les résultats (type réel contrôlé) mais ne lit pas le reste du dossier ; consultation journalisée. **Pharmacie (disponibilité d'un médicament)** : nom du médicament seulement, jamais l'identité du patient. **Mesures à domicile** : mêmes règles que le profil de santé (médecin avec RDV confirmé ou terminé). **Alertes de mesures** : une mesure dangereuse (ou élevée 3 fois en 7 jours) est signalée aux médecins qui ont déjà accès aux mesures (RDV confirmé ou terminé depuis moins d'un an), 3 au plus, une fois par 24 h ; le patient peut les désactiver.

Secrétariat (clinique ou cabinet) : agenda, prise de RDV, fichier patients (noms, téléphones) ; aucun accès aux dossiers médicaux, comptes-rendus, ordonnances ni documents.

Chaque règle ci-dessus est couverte par au moins un test automatisé qui tente l'accès interdit.

2.5 Protections techniques

Menace	Protection
Double réservation	Verrou transactionnel et **contrainte d'exclusion PostgreSQL** sur les plages horaires
Manipulation des prix ou des parts d'assurance	Calcul serveur ; valeurs figées sur le RDV à la réservation
Faux paiement	Statut relu auprès de PayDunya ; montant contrôlé ; écritures comptables idempotentes
Double virement, double remboursement	Verrous en base ; une seule demande de virement en cours ; une seule écriture par paiement

Menace	Protection
Fichier piégé (HTML/SVG déguisé)	Type réel déterminé par le contenu (PDF, JPEG, PNG, WebP uniquement), 6 Mo maximum, stockage hors du dossier public, service avec `Content-Security-Policy: sandbox` et `nosniff`
Virus dans un fichier déposé	Analyse antivirus **ClamAV** (service `clamav`, signatures mises à jour automatiquement) de chaque fichier avant stockage : documents, résultats d'analyses, pièces jointes, justificatifs, photos, signatures. Fichier infecté refusé ; antivirus injoignable = dépôt refusé (jamais de fichier non inspecté) et alerte de supervision
Vol du disque, d'un volume ou d'une sauvegarde	**Chiffrement de chaque fichier sur le disque** (Fernet : AES-128-CBC + HMAC-SHA256, `sunusante/uploads.py`) avec une clé (`FILE_ENCRYPTION_KEYS`) conservée hors du serveur de fichiers et hors des sauvegardes ; fichier altéré refusé ; rotation de clé sans coupure (`encrypt_files --rotate`)
Poste de cabinet ou de clinique laissé ouvert	Déconnexion automatique des comptes professionnels après 30 minutes sans activité
Formulaire de contact détourné (spam, saturation)	Limite de 5 demandes par heure et par adresse, champ piège anti-robots, contrôle du format du contact ; message d'avertissement contre la saisie d'informations médicales détaillées
Données de santé envoyées à l'IA / « hallucinations »	Assistant de notes : seul le texte des notes part (jamais l'identité du patient), uniquement sur demande du médecin, journalisé ; consigne de ne rien inventer (ni diagnostic, ni médicament, ni dose) ; brouillon toujours relu et validé par le médecin avant enregistrement ; désactivable (`AI_NOTES_ENABLED`)
Déplacement de RDV par glisser-déposer	Même contrôle serveur qu'un déplacement classique (créneau libre, pas dans le passé), confirmation avant envoi, patient prévenu
Fiche d'urgence consultée par un tiers	Désactivée par défaut ; lien à jeton aléatoire de 256 bits, révocable (« nouveau lien ») ; informations choisies par le patient ; page non indexée, sans référent ; limite de débit ; chaque consultation journalisée et signalée au patient (une fois par jour)
Renouvellement d'ordonnance abusif	Uniquement par le médecin prescripteur, ordonnance de moins d'un an, une demande en cours à la fois ; refus motivé obligatoire ; nouvelle ordonnance avec en-tête et signature à jour (mentions obligatoires vérifiées), journalisée
Hameçonnage du mot de passe d'un professionnel (faux email « votre compte expire »), risque le plus probable en pratique	**Clés d'accès** (§ 2.2) : une clé créée pour `fajma.sn` ne produit aucune signature utilisable sur un autre domaine. Le serveur refuse toute signature dont l'origine n'est pas la nôtre — vérifié par des tests qui rejouent une attaque de relais
Attaque de mots de passe en cours, répartie sur de nombreuses adresses	Détectée par la supervision (`manage.py monitor`) : vague d'échecs de connexion, comptes verrouillés en série, fiches d'urgence consultées en masse, rafale d'actions sensibles de l'administration. Email aux responsables, **et SMS pour les alertes graves** (`ALERT_PHONES`), parce qu'un email n'est pas lu la nuit
Faille connue dans une bibliothèque	Contrôle automatique à chaque modification : `npm audit` (interface) et `pip-audit` (serveur) dans l'intégration continue. **Mises à jour proposées automatiquement** (`.github/dependabot.yml`, serveur + application + actions) : les corrections de sécurité arrivent sans attendre, déjà testées par l'intégration continue — il n'y a qu'à valider. Un serveur laissé sans mise à jour est l'une des trois causes les plus fréquentes d'intrusion
Motif dangereux introduit dans le code (commande système, secret en dur, aléatoire non sûr, XML non protégé)	**Analyse statique** `bandit` à chaque modification : toute alerte de gravité moyenne ou haute fait échouer l'intégration continue
Service externe appelé en clair par erreur de configuration	Les adresses des services externes (IA, SMS, paiement) doivent être en `https://` : sinon l'application **refuse de démarrer** (`require_https`, `sunusante/settings.py`). Sans ce contrôle, un `http://` oublié aurait envoyé des notes médicales et des clés d'API en clair

Menace	Protection
Script injecté (XSS)	React échappe les contenus ; CSP stricte sans `unsafe-inline` pour les scripts (empreintes calculées au build) ; cookie de session inaccessible au JavaScript
Clic détourné (clickjacking)	`frame-ancestors 'none'` et `X-Frame-Options: DENY`, sauf le module de réservation intégrable, qui ne contient ni connexion ni paiement
Abus et force brute	Limites de débit : connexion 10/min, codes SMS 10/h, réservations 20/h, assistant IA 15/min, recherches publiques 30/min ; **verrou par compte** : après 10 mots de passe faux en 15 minutes sur un même email (même depuis des adresses différentes), connexion refusée pendant 15 minutes ; codes SMS limités à 3 par numéro et par 10 minutes
Serveur de production lancé en mode développement	Sans réglage, le mode développement (pages de débogage, accès démo) n'est actif que pour les commandes `manage.py` sur un poste ; le serveur de production (gunicorn) démarre toujours en mode sécurisé et docker-compose impose `DJANGO_DEBUG=false`
Copie de la base ou d'une sauvegarde volée	Fichiers chiffrés, **secrets de double authentification chiffrés** (même clé `FILE_ENCRYPTION_KEYS`, conservée hors de la base et des sauvegardes) : la base seule ne permet ni de lire les documents ni de générer les codes des professionnels ; mots de passe et codes de secours hachés
Suppression accidentelle (console technique, intervention manuelle)	Rendez-vous, comptes-rendus, ordonnances, certificats, analyses, messages, notes et paiements **protégés** : la suppression d'un compte ou d'une fiche médecin qui en possède est refusée par l'application (les comptes sont anonymisés, jamais effacés)
Contestation d'un rendez-vous (« je n'ai jamais annulé »)	Historique inaltérable de chaque rendez-vous : auteur, date, ancien et nouvel horaire, motif d'annulation
Messages répétés par Twilio ou l'opérateur USSD	Réponse mémorisée par identifiant de message / saisie : aucune double réservation
Sondage d'annuaire	La recherche de doublons en clinique ne révèle jamais l'existence d'un compte pour une personne inconnue de la clinique
Faux documents médicaux	Référence aléatoire vérifiable publiquement ; la vérification n'affiche ni contenu médical ni identité complète
Interception	HTTPS obligatoire (HSTS un an) ; redirection HTTP → HTTPS
Requête forgée vers le réseau interne (SSRF) via l'import d'agenda	HTTPS seulement ; résolution DNS vérifiée (adresses privées, locales, réservées refusées), à chaque redirection ; taille et durée limitées
Fuite de l'agenda exporté	Lien à jeton aléatoire (256 bits), révocable ; initiales et motif seulement, sans téléphone ni motif libre
Données hors ligne sur un téléphone partagé	Données personnelles effacées du cache à la déconnexion ; aucune écriture hors ligne
Vol du mot de passe d'un professionnel	Double authentification obligatoire ; la console technique `/django-admin/` n'a plus de connexion par mot de passe seul
Compte compromis ou professionnel radié	Suspension immédiate par l'administration : sessions supprimées sur tous les appareils, fiche retirée de l'annuaire, republication soumise à une nouvelle validation
Usurpation d'identité d'un médecin vérifié	Nom et spécialité non modifiables en ligne après vérification
Pièce jointe piégée dans la messagerie	Même contrôle que les documents médicaux (type réel, 6 Mo, service en bac à sable) ; lecture réservée au patient et au médecin du fil, lecture par le médecin journalisée
Fuite par export tableur	Exports limités aux données du médecin ou de l'établissement, période d'un an au plus, journalisés (qui, quoi, quelle période)
Photo de profil piégée	Type réel contrôlé (JPEG, PNG, WebP), 2 Mo maximum, servie avec la même politique « bac à sable » que les documents

2.6 Journal d'audit

Inscrits dans une table inaltérable : connexions et échecs, activation/désactivation de la 2FA, changements de mot de passe, consultation d'une fiche patient, d'un document, d'une ordonnance (y compris par une pharmacie, un confrère ou un remplaçant), rédaction de comptes-rendus et certificats, modification d'une fiche médecin ou d'une officine, exports et suppressions de compte, actions d'administration (validations, virements, remboursements, modération, consultation des justificatifs, recherches de comptes, suspensions, réinitialisations de 2FA, avec leur motif). Le patient voit dans son dossier qui a consulté ses données ; l'administration voit l'ensemble. Conservation du journal : 5 ans par défaut (réglable, à valider ⚖️).

2.7 Secrets et configuration

Aucun secret dans le code source. Les clés (Django, base, PayDunya, Twilio, USSD, VAPID, IA, SMTP, Sentry) sont lues dans des variables d'environnement (`deploy/.env`, non versionné). En production, Django refuse de démarrer sans clé secrète ni clé de chiffrement des fichiers (`FILE_ENCRYPTION_KEYS`, à garder aussi dans un coffre hors du serveur : sans elle, documents et sauvegardes sont illisibles), active les cookies sécurisés, HSTS et la redirection HTTPS ; `manage.py check --deploy` est exécuté par l'intégration continue.

2.8 Tests de sécurité réalisés

- **429 tests automatisés de l'API**, dont les tentatives d'accès interdites de la matrice § 2.4 (y compris pour un remplaçant, une secrétaire, un médecin sans lien avec le patient), les manipulations de prix et de parts, les fichiers piégés, les doubles réservations, les webhooks non signés, les secrets USSD invalides, la réutilisation de session USSD par un autre numéro, les doubles notifications de paiement, le blocage des professionnels sans double authentification, la suspension de compte (sessions coupées), le chiffrement des fichiers sur le disque (et le refus d'un fichier altéré), le refus d'un fichier infecté ou non analysable, la déconnexion après inactivité (sans prolongation par les rafraîchissements automatiques) et l'alerte de connexion depuis un nouvel appareil, et le refus d'une adresse de service externe qui ne serait pas en `https://`.
- **Clés d'accès éprouvées contre une vraie attaque** (`tests/test_passkeys.py`, 15 tests) : les tests fabriquent un authentificateur logiciel (paire de clés ES256, signature réelle) plutôt que de bouchonner la bibliothèque. Sont refusés : une clé créée pour un faux domaine, une signature relayée depuis un site d'hameçonnage, une signature falsifiée, la clé d'un autre compte, un défi rejoué, et toute tentative sans mot de passe valide au préalable.
- **Alertes de sécurité** (`tests/test_operations.py`) : les seuils sonnent quand il faut et se taisent en dessous ; seules les alertes graves partent par SMS.
- **Balayage des accès croisés** (`tests/test_idor_sweep.py`) : un autre patient, un autre médecin et un visiteur tentent une quarantaine de routes sur les données d'autrui (RDV, documents, ordonnances, paiements, proches, mesures, analyses, renouvellements, assurances) : toutes refusées, rien n'est modifié.
- **Double réservation simultanée** : sous PostgreSQL, la contrainte d'exclusion refuse en base deux rendez-vous qui se chevauchent même si les contrôles applicatifs sont contournés (`tests/test_overlap_constraint.py`).
- **Parcours de bout en bout** dans un navigateur réel pour chaque rôle, sur ordinateur et mobile, dont le mode hors ligne et l'effacement des données à la déconnexion sur le build de production, et l'activation imposée de la double authentification.
- **Failles corrigées pendant les audits** :
  - le type de fichier annoncé par le navigateur était accepté tel quel pour les documents médicaux (page HTML exécutable au nom du site) : type désormais déterminé par le contenu, fichiers servis dans un bac à sable ;

- la console technique `/django-admin/` permettait une connexion par mot de passe seul, contournant la double authentification : elle passe désormais par la connexion Fajma ;
- l'ajout en double d'un membre de secrétariat provoquait une erreur serveur : contrôle préalable.

2.9 Ce qui n'est pas couvert, et pourquoi

Cette section existe pour qu'aucun acquéreur ne découvre ces limites après coup. Aucune d'elles ne relève du code : toutes dépendent de l'hébergement, du budget ou d'une démarche administrative.

Point	État	Qui doit s'en charger
Test d'intrusion externe par un tiers indépendant	Jamais réalisé	Prestataire spécialisé, avant l'ouverture au public. C'est le seul point qui peut révéler ce que ni les tests ni l'analyse statique ne voient.
Pare-feu applicatif (WAF) et protection anti-déni de service	Absent	Fourni par l'hébergeur ou un service en frontal. L'application limite déjà le débit par compte et par adresse, mais ne peut rien contre une saturation du réseau.
Détection d'intrusion et alerte en temps réel (SIEM)	Absent	Le journal d'audit enregistre tout, mais personne n'est prévenu automatiquement d'un comportement anormal.
Chiffrement de la base entière au repos	Absent	Dépend du disque et de l'hébergeur. Les documents et les secrets de double authentification sont déjà chiffrés indépendamment : la base volée seule ne les livre pas.
Rotation automatique des secrets	Manuelle	La rotation de la clé de chiffrement des fichiers est outillée (`encrypt_files --rotate`), les autres clés se changent à la main.
Déclaration à la Commission de Protection des Données Personnelles (CDP, Sénégal)	À faire ⚖️	Obligation légale pour un traitement de données de santé.
Politique de divulgation responsable (`security.txt`, adresse de contact)	Absente	Demande une boîte aux lettres réellement relevée ; à créer en même temps que le domaine.
Certification HDS / ISO 27001	Aucune	Pertinent seulement si un partenaire institutionnel l'exige ; coûteux et long.

À faire en priorité : test d'intrusion externe, revue de la configuration de l'hébergement réel, déclaration CDP.

3. Données personnelles et conformité

> Cette section décrit les faits techniques utiles à l'analyse juridique. **Elle ne constitue pas un avis juridique.** Les points marqués ⚖️ doivent être validés par un juriste spécialisé en droit du numérique et de la santé au Sénégal.

3.1 Cadre applicable (à confirmer ⚖️)

- **Loi n° 2008-12 du 25 janvier 2008** sur la protection des données à caractère personnel et son décret d'application ; autorité de contrôle : **CDP**. Vérifier l'état de la réforme de cette loi au moment de la cession.
- Les données de santé sont des **données sensibles** : leur traitement relève en principe d'une **autorisation préalable de la CDP**.
- **Transferts hors du Sénégal** : encadrés (pays adéquat ou autorisation). Voir § 3.3.
- Exercice de la médecine, téléconsultation, ordonnance et certificat électroniques, télé-expertise : règles de l'Ordre national des médecins et du ministère de la Santé.
- Pharmacies : transmission d'ordonnances à une officine choisie par le patient (règles de l'Ordre des pharmaciens).
- Encaissement pour le compte des médecins et prélèvement d'une commission : qualification juridique à établir (mandat d'encaissement, statut au regard de la réglementation des paiements de l'UEMOA).
- Assurances : tiers payant et échange d'informations avec les organismes (IPM, mutuelles, assureurs) à encadrer par convention.

3.2 Inventaire des données

Catégorie	Données	Personnes	Finalité
Identité et contact	Nom, email, téléphone (vérifié), ville, langue	Tous les utilisateurs	Compte, rappels
Proches	Nom, lien, date de naissance, téléphone	Enfants et proches	Prise de RDV, carnet de vaccination
Rendez-vous	Médecin, date, motif libre, réponses au questionnaire, canal	Patients	Organisation des soins
Santé	Profil (groupe sanguin, allergies, antécédents, traitements), comptes-rendus, ordonnances, certificats, arrêts de travail, documents déposés, messages, vaccins, suivi de grossesse	Patients, enfants	Suivi médical
Santé	Symptômes décrits à l'assistant IA	Visiteurs	Orientation — **non conservés**
Santé	Mesures à domicile (tension, glycémie, poids), rappels de médicaments, prescriptions et résultats d'analyses	Patients, proches	Suivi médical
Santé	Fiche d'urgence (réglages : informations choisies, lien), demandes de renouvellement d'ordonnance et réponses du médecin	Patients	Secours, suivi des traitements longs
Santé	Réponses facultatives au questionnaire du médecin (données en réservant ou ensuite)	Patients, proches	Préparation de la consultation
Demandes aux pharmacies	Nom du médicament, précision, réponses (sans identité transmise à la pharmacie)	Patients	Éviter les déplacements inutiles

Catégorie	Données	Personnes	Finalité
Assurance	Organisme, numéro d'adhérent, taux de prise en charge	Patients	Tiers payant, feuille de soins
Paiement	Montant, moyen, références de transaction et de virement	Patients, médecins	Encaissement, reversement
Professionnels	Fiche, tarifs, disponibilités, justificatifs (diplôme, inscription à l'Ordre, pièce d'identité)	Médecins	Annuaire, vérification
Patients sans compte	Nom, téléphone saisis par le secrétariat	Patients au guichet	RDV, rappels
Techniques	Journal d'audit (adresse IP, navigateur), journaux serveur	Tous	Sécurité, preuve des accès

3.3 Sous-traitants et flux hors du Sénégal

Prestataire	Rôle	Données transmises	Localisation
Hébergeur (au choix)	Serveur, base, fichiers	**Toutes**	**Au choix — hébergement au Sénégal possible**
Twilio / Meta (WhatsApp)	SMS, WhatsApp, robot WhatsApp	Numéro, nom, médecin, date ; messages du robot	États-Unis
Agrégateur USSD	Menu USSD	Numéro, saisies du menu	Selon contrat (opérateurs sénégalais)
PayDunya	Paiement	Montant, référence	Sénégal
Service push des navigateurs (Google, Apple, Mozilla)	Notifications	Titre et court texte de la notification (chiffrés de bout en bout)	Hors Sénégal
Jitsi `meet.jit.si` (tant qu'il n'est pas auto-hébergé)	Vidéo	**Flux audio/vidéo de la consultation**	Hors Sénégal, sans contrat
Fournisseur IA (Google Gemini par défaut)	Assistant d'orientation	Symptômes saisis	Hors Sénégal
Fournisseur IA (Google Gemini par défaut)	Assistant de prise de notes des médecins (si activé : `AI_NOTES_ENABLED`)	**Texte des notes de consultation** (sans nom, téléphone ni identifiant du patient), à la demande du médecin	Hors Sénégal ⚖️ — à désactiver tant que ce transfert n'est pas autorisé ; une mise en forme locale sans IA reste disponible
OpenStreetMap	Fonds de carte	Adresse IP du visiteur	Hors Sénégal
Google Fonts	Polices	Adresse IP du visiteur	Hors Sénégal
Sentry (facultatif)	Suivi des erreurs	Traces techniques (sans données personnelles : option désactivée)	Selon compte

⚖️ Pour les données de santé, la voie la plus simple est l'hébergement au Sénégal (base et fichiers) et une instance Jitsi locale ; les autres transferts portent sur des données limitées (SMS, notifications) et doivent être couverts par les contrats et autorisations.

3.4 Droits des personnes

Droit	Mise en œuvre
Information	Projets de CGU et de politique de confidentialité intégrés au site (à valider ⚖️) ; mention à chaque partage de dossier (pharmacie, confrère)
Accès	Dossier complet consultable ; **journal des accès** montrant quel professionnel a consulté quoi
Rectification	Profil, profil de santé, proches, assurances, carnet modifiables
Portabilité	Export complet des données en JSON depuis le dossier ; dossier médical lisible en PDF (« Télécharger mon dossier ») à remettre à un autre médecin
Effacement	Suppression du compte en libre-service (anonymisation des données qui doivent être conservées) ; anonymisation automatique des comptes inactifs, après préavis par email (durée à fixer ⚖️, désactivée par défaut)
Opposition aux SMS	Réponse STOP (SMS ou WhatsApp) : plus aucun SMS automatique ; START pour les réactiver
Maîtrise du partage	Partage des documents document par document et médecin par médecin ; envoi d'ordonnance à une pharmacie choisie ; information préalable du patient pour la télé-expertise
Langue	Interface, SMS et menus en français, wolof ou anglais

3.5 Conservation

Purge automatique chaque nuit (`purge_data`, durées réglables par variables d'environnement) :

Donnée	Durée par défaut	Traitement
Sessions expirées	À expiration	Suppression
Codes SMS de connexion	1 jour	Suppression
Conversations WhatsApp / USSD	30 jours	Suppression
SMS envoyés (numéro et texte)	1 an	Suppression
Notifications de l'application	1 an	Suppression
Occupations importées des agendas personnels	7 jours après la date	Suppression
Identité des patients sans compte (saisis au guichet)	5 ans après le RDV	Anonymisation (le RDV reste pour les statistiques)
Appareils de connexion connus (alerte « nouvel appareil »)	2 ans sans utilisation	Suppression
Demandes d'aide traitées (nom, contact, message)	2 ans après traitement	Suppression (et dès la suppression du compte)
Journal d'audit	5 ans ⚖️	Suppression
Comptes patients inactifs (ni connexion ni rendez-vous)	Désactivé par défaut (`RETENTION_INACTIVE_ACCOUNT_DAYS`, ex. 3 ans) ⚖️	Préavis par email, puis anonymisation 30 jours après sans reconnexion
Données médicales (dossiers, comptes-rendus, ordonnances, certificats, documents, carnets)	**Aucune purge automatique**	Durée légale à fixer ⚖️
Données de paiement et journal comptable	Aucune purge automatique	Obligations comptables à fixer ⚖️

Un compte supprimé par son titulaire est anonymisé immédiatement (documents déposés effacés, identité remplacée). Les données médicales et comptables sont protégées au niveau de la base : aucune suppression de compte ou de fiche médecin ne peut les emporter « en cascade ».

3.6 Points d'attention dans l'application

- **Allégations commerciales** : les chiffres de la page d'accueil (médecins, villes, praticiens par spécialité, note moyenne) sont calculés à partir de la base ; la note moyenne n'est affichée qu'à partir de 20 avis.
- **Calendriers médicaux** : le calendrier vaccinal (PEV) et le rythme des consultations prénatales (8 contacts OMS) sont des références à faire valider ; l'application précise qu'elle complète le carnet papier.
- **Certificats et arrêts de travail** : un arrêt ne peut pas débuter plus de 2 jours avant la consultation ; la vérification publique ne révèle que les initiales du patient.
- **Chiffrement** : transport (HTTPS) garanti ; **fichiers (documents médicaux, résultats, pièces jointes, justificatifs, signatures) chiffrés par l'application** avant écriture sur le disque, donc aussi dans les sauvegardes ; sauvegardes elles-mêmes chiffrées (AES-256). La base de données reste à chiffrer au niveau de l'hébergement (disque chiffré) — **à vérifier** sur l'infrastructure retenue.

4. Exploitation et déploiement

4.1 Environnements

Environnement	Composition
Développement	Django (`runserver`) + Vite ; SQLite ; envois exécutés immédiatement ; codes SMS affichés à l'écran
Production	Docker Compose : PostgreSQL 17, API (gunicorn), worker (file de tâches), planificateur, nginx
Recette (recommandée)	Même composition que la production, données de démonstration (`seed_demo --accounts --activity`)

4.2 Installation locale

Voir le `README.md` à la racine : environnement Python, `migrate`, `seed_demo`, `runserver`, puis `npm run dev`. Sous Windows, `Lancer-Fajma.bat` (à la racine) démarre le serveur et l'interface en un double-clic et ouvre la page de connexion ; les boutons « Accès démo » n'existent qu'en développement (`DEBUG`).

4.3 Mise en production

```
cp deploy/.env.example deploy/.env      # base, clé secrète, domaine, PayDunya, Twilio, USSD, push, Jit
docker compose -f deploy/docker-compose.yml --env-file deploy/.env up -d --build
docker compose -f deploy/docker-compose.yml exec backend python manage.py createsuperuser
docker compose -f deploy/docker-compose.yml run --rm backend python manage.py vapid_keys   # une fois
```

- Les migrations s'appliquent au démarrage de l'API ; la liste des organismes d'assurance est créée par migration.
- **Calcul des itinéraires** : OSRM, serveur public de démonstration par défaut (usage léger). Pour la production, héberger son propre OSRM ou choisir un fournisseur, régler `VITE_ROUTING_URL` au moment de la compilation et remplacer l'adresse dans `connect-src` de `deploy/security-headers.conf`. Sans ce service, la carte trace le trajet direct : aucune panne bloquante.
- **Fond de carte** (accueil, recherche) : tuiles OpenStreetMap par défaut, gratuites mais réservées à un usage modéré (règles d'utilisation d'OpenStreetMap). Avec beaucoup de visiteurs, prendre un fournisseur de tuiles (MapTiler, Stadia, Thunderforest… ou un serveur de tuiles auto-hébergé) : régler `VITE_MAP_TILE_URL` et `VITE_MAP_TILE_ATTRIBUTION` au moment de la compilation, et ajouter son adresse à `img-src` dans `deploy/security-headers.conf`. Les itinéraires sont calculés par Google Maps ou Waze : rien à héberger.
- HTTPS : répartiteur TLS en amont (transmettant `X-Forwarded-Proto`) ou certificats dans nginx. Activer **HTTP/2** sur ce point d'entrée (`listen 443 ssl; http2 on;` ou option du répartiteur) : les connexions temps réel n'occupent alors plus les 6 connexions par site du HTTP/1.1.
- Webhooks à déclarer : PayDunya (`/api/payments/paydunya/webhook`), Twilio statut SMS (`/api/notifications/twilio-status?token=…`), Twilio SMS entrant pour STOP/START (`/api/notifications/twilio-inbound`), Twilio WhatsApp entrant (`/api/bots/whatsapp`), agrégateur USSD (`/api/bots/ussd` , en-tête `X-Ussd-Secret`).
- Application Android : génération Trusted Web Activity (`twa-manifest.json` , Bubblewrap) et empreinte de la clé de signature dans `public/.well-known/assetlinks.json` .
- **Premier administrateur** : `createsuperuser` , puis connexion sur le site ; l'activation de la double authentification est imposée dès la première connexion.
- **À vérifier** : exécution effective de la composition Docker sur le serveur cible (validée par `docker compose config` seulement). La base PostgreSQL, la sauvegarde et la restauration ont été vérifiées pour de vrai

hors Docker (§ 4.5) ; refaire `docker compose exec backup sh /restore-test.sh` sur le serveur.

4.4 Tâches en arrière-plan

Tâche	Fréquence	Rôle
`worker` (`manage.py db_worker`)	Continu	SMS, WhatsApp, emails, notifications push, sans ralentir les requêtes
`scheduler` (`manage.py send_reminders`)	10 minutes	Rappels de RDV (24 h, 2 h), rappels des médecins, vaccins des enfants, consultations prénatales, prises de médicaments, ordonnances de traitements longs bientôt expirées (renouvellement)
`scheduler` (`manage.py sync_calendars`)	10 minutes	Relecture des agendas personnels des médecins
`scheduler` (`manage.py monitor`)	10 minutes	Supervision et alertes email (§ 4.6)
`scheduler` (`manage.py purge_data`)	Chaque nuit vers 3 h	Purge des données techniques (§ 4.6 bis)
`backup` (`backup.sh`, `restore-test.sh`)	Chaque jour / le 1er du mois	Sauvegarde chiffrée / test de restauration
`clamav` (clamd + freshclam)	Continu	Analyse antivirus des fichiers déposés ; signatures mises à jour plusieurs fois par jour. Prévoir ≈ 2 Go de mémoire

4.5 Base de données PostgreSQL

Vérifié le 05/10/2026 sur un vrai PostgreSQL 17.6 (binaires officiels, sans Docker), avec un utilisateur **sans droits d'administration**, comme chez la plupart des hébergeurs :

Point	Résultat
Création complète d'une base vide (`migrate`)	20 s ; 78 tables, 312 contraintes, 310 index ; l'extension `btree_gist` (anti-double réservation) s'installe sans droits d'administration
Conformité	72 modèles sur 72 identiques au schéma (colonnes, tables de liaison), aucune migration en attente
Tests automatisés	429 tests au vert sur PostgreSQL comme sur SQLite
Volume	20 500 comptes, 500 médecins, 200 000 rendez-vous, 150 000 comptes-rendus, 75 000 ordonnances, 50 000 paiements (712 000 lignes, 251 Mo) : pages patient et médecin entre 4 et 40 ms ; annuaire 45 à 115 ms par page de 60 médecins ; rapport d'activité annuel 1,3 s
Sauvegarde / restauration	48 Mo en 10 s / 24 s ; copie **identique** (nombre de lignes et somme de contrôle de chaque table, contraintes, index) ; application et anti-double réservation fonctionnels sur la base restaurée ; restauration par écrasement (`--clean`) identique aussi
Scripts `backup.sh` et `restore-test.sh` exécutés pour de vrai	Archive chiffrée AES-256, test de restauration réussi (20 508 comptes, 200 000 RDV, fichiers) ; mauvaise phrase secrète ou outil absent : échec signalé

Exigences pour l'hébergeur : PostgreSQL 15 ou plus récent (17 conseillé), encodage UTF-8, un utilisateur propriétaire de la base (droits d'administration inutiles), 200 connexions (`max_connections`, réglé dans `docker-compose.yml`). Taille : environ **1,3 Go par million de rendez-vous** (avec comptes-rendus, ordonnances, paiements, journal), plus les fichiers des patients (6 Mo au plus par document).

Outil de test de volume : `python manage.py seed_volume [--doctors 500 --patients 20000 --per-doctor 400]` remplit une base de développement avec des données fictives (refusé hors mode développement). Le chronométrage de référence se refait avant chaque grosse évolution.

Index ajoutés sur une grosse base : la création d'un index bloque les écritures de la table le temps de sa construction (moins d'une seconde pour 200 000 lignes). Au-delà de plusieurs millions de lignes, appliquer les migrations d'index en heure creuse.

Transférer les données de SQLite vers PostgreSQL (mise en ligne)

Procédure vérifiée sur la base de démonstration (1 121 objets : aucun manquant, aucun en trop, aucune différence) :

```
# 1. Sur le poste, base SQLite (sans DATABASE_URL) : export
python -X utf8 manage.py dumpdata --natural-foreign --natural-primary --exclude contenttypes \
    --exclude auth.permission --exclude admin.logentry --exclude sessions --indent 0 -o export.json
# 2. Sur la nouvelle base PostgreSQL (DATABASE_URL=postgres://...) : tables, puis vidage, puis chargeme
python manage.py migrate --noinput
python manage.py flush --noinput      # retire les lignes créées par les migrations (organismes d'assur
python -X utf8 manage.py loaddata export.json
```

Sans l'étape `flush`, le chargement échoue (doublon sur la liste des assurances). Le chargement n'invente aucun historique de rendez-vous (corrigé et testé). Copier aussi le dossier des fichiers et garder la même `FILE_ENCRYPTION_KEYS` (voir ci-dessous).

Déménager vers un autre serveur ou un autre hébergeur

1. Arrêter l'API (`docker compose stop api events worker scheduler`) pour figer les données.
2. Base et fichiers : reprendre la dernière archive de `deploy/backups` et, sur le nouveau serveur, `docker compose run --rm backup sh /restore.sh /backups/fajma-XXXX.tar.gz.enc` — une seule commande, qui déchiffre, restaure et rend les objets au compte `fajma_app` (sans quoi l'application restaurée ne pourrait plus lire ses propres données ; vérifié chaque mois par `restore-test.sh`).
3. Fichiers : copier le volume `private_media` tel quel (les fichiers restent chiffrés pendant le transfert).
4. Réglages : reprendre le fichier `.env` ; **`FILE_ENCRYPTION_KEYS` doit être identique**, sans elle les documents et les secrets de double authentification sont illisibles (vérifié par un test). `DJANGO_SECRET_KEY` peut changer : seules les sessions ouvertes et les codes SMS en cours (10 min) sont perdus.
5. `docker compose up -d`, puis `docker compose exec backup sh /restore-test.sh` et un essai de connexion.

4.5 bis Sauvegardes et reprise

- Automatique : le service `backup` (`deploy/backup.sh`) produit toutes les `BACKUP_INTERVAL_HOURS` heures (24 par défaut, **6 conseillé** dans `.env.example`) une archive de la base (`pg_dump`) et du volume `private_media` (documents médicaux, justificatifs, signatures et cachets des médecins) dans `deploy/backups`, chiffrée en AES-256 avec `BACKUP_PASSPHRASE` (obligatoire : le service refuse de démarrer sans elle), conservée 30 jours.
- **Comptes PostgreSQL** : `POSTGRES_PASSWORD` (administration : sauvegardes, maintenance) et `APP_DB_PASSWORD` (application, créé au premier démarrage par `deploy/postgres-init/10-app-role.sh`, sans droits d'administrateur). Base hébergée ailleurs : connexion chiffrée exigée par défaut (`DATABASE_SSLMODE=require`).
- À faire par l'exploitant : copier chaque nuit `deploy/backups` hors du serveur (rclone, scp…), garder la phrase secrète **et la clé** `FILE_ENCRYPTION_KEYS` dans un coffre séparé : les fichiers de la sauvegarde sont chiffrés par l'application et ne peuvent être relus qu'avec cette clé.

- Mise en service sur des données existantes : `python manage.py encrypt_files` chiffre les fichiers encore en clair (sans risque à relancer) ; après un changement de clé, `encrypt_files --rotate`.
- Test de restauration automatique le 1er de chaque mois (`deploy/restore-test.sh`) : la dernière sauvegarde est restaurée dans une base temporaire, vérifiée (comptes, rendez-vous, fichiers) puis effacée. Lancement manuel : `docker compose exec backup sh /restore-test.sh`. La supervision (`monitor`) alerte si aucun test de restauration n'a réussi depuis plus de 35 jours.
- Objectifs recommandés : perte de données maximale 6 h (`BACKUP_INTERVAL_HOURS=6` ; 1 h avec archivage continu PostgreSQL), reprise en 4 h.

4.6 Supervision

- `/api/health` : vérifie l'API et la base (utilisé par le contrôle de santé du conteneur). Avec `?token=HEALTH_TOKEN` (supervision externe) ou pour l'équipe Fajma connectée : état de chaque composant (base, antivirus, rappels en retard, échecs SMS, sauvegarde, disque, SMS et paiement configurés).
- Erreurs serveur et navigateur : Sentry (facultatif, `SENTRY_DSN`), sans données personnelles.
- Administration : SMS en échec avec relance, file des remboursements et virements, justificatifs à vérifier, avis à modérer, tableau de pilotage.
- `python manage.py monitor` (planificateur, toutes les 10 min) : base, rappels SMS en retard, taux d'échec SMS, âge et taille de la dernière sauvegarde, espace disque. Email aux adresses `ALERT_EMAILS` (une fois par problème toutes les 6 h, puis « résolu »).
- **À faire par l'exploitant** : un service de surveillance externe (UptimeRobot, Better Stack — gratuits) qui appelle `https://www.fajma.sn/api/health` chaque minute et prévient par SMS/email : si le serveur entier tombe, la supervision interne ne peut plus rien envoyer.

4.6 bis Conservation des données

`python manage.py purge_data` (chaque nuit vers 3 h, `--dry-run` pour simuler) supprime les données techniques au-delà des durées de `RETENTION_DAYS` (réglables par variables d'environnement) : sessions expirées, codes SMS (1 j), conversations WhatsApp/USSD (30 j), SMS envoyés et notifications (1 an), créneaux d'agendas importés (7 j), journal des accès (5 ans), identité des patients sans compte sur les RDV passés (anonymisée après 5 ans). Comptes inactifs : avec `RETENTION_INACTIVE_ACCOUNT_DAYS` > 0, préavis par email puis anonymisation 30 jours après (désactivé par défaut). **Aucune donnée médicale n'est purgée automatiquement** : durées légales à fixer avec un juriste et la CDP ⚖️.

4.7 Performance et montée en charge

- gunicorn (3 processus par défaut, à ajuster) ; fichiers du site servis et mis en cache par nginx.
- Annuaire : la prochaine disponibilité de tous les médecins affichés est calculée en 4 requêtes au total (plages, rendez-vous, absences, remplacements chargés d'un coup). Un test vérifie que le nombre de requêtes des listes principales (recherche, RDV du patient, agenda du médecin) ne grandit pas avec le nombre de lignes. Au-delà de quelques milliers de médecins, prévoir un cache de quelques minutes.
- Base de données arrêtée ou injoignable : l'API répond 503 « Service momentanément indisponible » (et non une page d'erreur) ; l'interface affiche ce message ; le détail part dans les journaux.
- Réseau mobile lent : application mise en cache sur le téléphone, lectures récentes disponibles hors ligne.

4.8 Qualité du code

Contrôle	Outil	État
Tests de l'API	`python manage.py test` (SQLite et PostgreSQL, en local et en CI)	429 tests, tous au vert

Contrôle	Outil	État
Parcours de bout en bout	Navigateur piloté (Edge), 17 parcours, 104 étapes	Tous au vert
Typage	`tsc --noEmit`	Sans erreur
Lint / format	ESLint + Prettier	0 erreur
Sécurité Django	`manage.py check --deploy`	Sans erreur
Dépendances	`npm audit` en CI	À surveiller à chaque version

4.9 Régénérer les documents du dossier

Deux outils, à relancer avant toute transmission, pour que les documents remis correspondent au code livré.

```
# Inventaire des licences (chapitre 7 et annexe CSV) : exige un build récent avec sourcemaps.
npx vite build --sourcemap
python tools/inventaire_licences.py

# Le PDF du dossier : couverture, sommaire numéroté, chapitres. Le nom du fichier et la version affiché
# suivent le « Version du dossier » du README : c'est le seul endroit à modifier.
npm i --no-save puppeteer marked pdfjs-dist
node tools/dossier-pdf.mjs
node tools/dossier-pdf-verifie.mjs   # relit le PDF : chaque chapitre est-il à la page annoncée ?
```

Les numéros du sommaire sont **mesurés**, pas estimés : chaque chapitre est d'abord rendu seul pour compter ses pages. Le générateur s'arrête en erreur si le total annoncé ne correspond pas au PDF produit, et le second outil relit le document fini pour le confirmer. Un sommaire faux ne peut donc pas partir chez un acquéreur.

Ne gardez qu'un seul PDF dans `docs/dossier-technique/` : supprimez l'ancien après avoir généré le nouveau.

5. Risques ouverts et plan d'action

Gravité : 🔴 bloquant pour la commercialisation · 🟠 à traiter avant la montée en charge · 🟡 amélioration. ⚖️ : volet juridique ou réglementaire.

5.1 Registre des risques

Réf.	Gravité	Risque	Action recommandée
R-01	🔴 ⚖️	Pas encore d'autorisation CDP pour le traitement de données de santé	Constituer et déposer le dossier (ce dossier technique en fournit la matière)
R-02	🔴 ⚖️	Transferts hors du Sénégal (§ 3.3) non encore encadrés	Hébergement au Sénégal ; contrats et autorisations pour les flux restants
R-03	🔴	Téléconsultation sur le serveur public `meet.jit.si`	Instance Jitsi auto-hébergée (paramètre `JITSI_DOMAIN`) ou service contractualisé
R-04	🔴 ⚖️	CGU, politique de confidentialité et contrats (médecins, cliniques, pharmacies, organismes d'assurance) à l'état de projet	Rédaction et validation juridique ; conventions de tiers payant
R-05	🔴 ⚖️	Encaissement pour le compte des médecins et commission : qualification juridique	Avis juridique ; convention avec PayDunya
R-06	🔴	Aucun test d'intrusion externe	Test d'intrusion sur l'environnement de recette avant ouverture
R-07	🟠	Virements aux médecins et remboursements exécutés manuellement par l'administration (le suivi est automatisé, pas le transfert)	API de décaissement (PayDunya Disburse, Wave Business) après validation juridique
R-08	🟠	Calendrier vaccinal PEV et rythme des consultations prénatales non validés par une autorité sanitaire	Validation par la Direction de la Prévention ; mise à jour de `backend/carnet/schedules.py`
R-09	🟠	Textes wolof non relus par un locuteur natif	Relecture par un traducteur médical (`src/lib/i18n/wo.ts`, `backend/bots/texts.py`, SMS)
R-11	🟠	WhatsApp : Meta exige des modèles approuvés pour un premier message	Faire approuver les modèles ; repli SMS automatique en attendant
R-12	🟠 ⚖️	Durées de conservation des données médicales non fixées	Fait : purge nocturne des données techniques (`purge_data`). Reste : fixer avec un juriste les durées médicales et celles du journal (5 ans par défaut)
R-13	✅	~~Double authentification facultative pour les professionnels~~	Traité le 30/09/2026 : obligatoire pour médecins, cliniques, secrétariats, pharmaciens et administrateurs (`MFA_REQUIRED_FOR_PROS`) ; la console `/django-admin/` passe par la même connexion

Réf.	Gravité	Risque	Action recommandée
R-14	🔴	Surveillance externe à abonner	Fait : supervision interne avec alertes email (`monitor`, dont alerte si aucun test de restauration réussi depuis 35 jours), test de restauration mensuel automatique ; sauvegarde et restauration exécutées et vérifiées sur PostgreSQL réel (copie identique, § 4.5) ; `/api/health` détaillé avec `HEALTH_TOKEN`. Reste : créer le moniteur externe sur `/api/health`, renseigner `ALERT_EMAILS` et `HEALTH_TOKEN`, refaire le test sur le serveur cible
R-15	🟠	Temps réel par interrogation de la base toutes les 2 s (suffisant jusqu'à quelques milliers de connectés)	Passer à PostgreSQL LISTEN/NOTIFY ou Redis au-delà
R-16	🟠	Calcul des prochains créneaux à chaque recherche	Mise en cache au-delà de quelques centaines de médecins
R-17	🟠	Autres langues nationales (pulaar, sérère, diola…)	Ajouter un fichier de traduction par langue, avec des traducteurs natifs
R-18	🟠	Données restées sur l'ancienne plateforme du prototype	Décider de leur reprise (script d'import) ou de leur suppression, puis fermer les anciens comptes
R-19	🔴 ⚖️	Assistant IA de prise de notes : texte de consultation envoyé à un fournisseur d'IA hors Sénégal	Autorisation CDP et contrat avec le fournisseur (ou IA hébergée au Sénégal) avant d'activer en production ; sinon `AI_NOTES_ENABLED=false` (mise en forme locale sans IA)

5.2 Plan d'action proposé

Avant tout lancement commercial : R-01 à R-06 ; hébergement de production au Sénégal, HTTPS, sauvegardes chiffrées testées ; contrats Twilio, agrégateur USSD et PayDunya en production.

Dans les 3 mois suivant le lancement : R-07, R-08, R-09, R-11, R-12, R-14.

Amélioration continue : R-15 à R-18.

5.3 Risques traités depuis la version 1 du dossier

Contrôle d'accès appliqué par le serveur et testé ; journal d'audit visible par le patient ; accès des médecins aux documents limité au partage explicite ; double authentification ; connexion par code SMS ; limites de débit ; en-têtes de sécurité et CSP stricte ; cookies HttpOnly ; mots de passe de 10 caractères ; export et suppression du compte ; reversement aux médecins, commission et remboursements ; tests automatisés et intégration continue ; déploiement reproductible ; contrôle du type réel des fichiers déposés ; chiffres de la page d'accueil issus de la base (plus d'allégations écrites en dur) ; code et données indépendants de toute plateforme propriétaire.

Depuis la version 2.0 : double authentification obligatoire pour tous les professionnels et administrateurs (R-13) ; suppression de la connexion par mot de passe seul de la console technique ; suspension de comptes ; purge nocturne des données techniques (R-12, partie technique) ; supervision avec alertes et test de restauration mensuel automatique (R-14, partie technique).

Version 2.4 : chiffrement des fichiers sur le disque par l'application ; antivirus sur tous les fichiers déposés ; déconnexion des professionnels après 30 minutes d'inactivité ; alerte de connexion depuis un nouvel appareil (y compris contre le vol de puce) ; contrôle automatique des failles connues des bibliothèques serveur.

6. Informations pour une cession (due diligence)

Ce chapitre rassemble ce qu'un acquéreur ou un investisseur vérifie en priorité. Les points ⚖️ relèvent d'un juriste ; les montants sont des ordres de grandeur à confirmer par devis.

6.1 Propriété et actifs cédés

Actif	Contenu	Point à vérifier
Code source	Backend Django, frontend React, scripts de déploiement, tests, ce dossier	⚖️ Chaîne de droits : contrats ou cessions de droits d'auteur de chaque contributeur (y compris code produit avec des outils d'assistance)
Marque et nom de domaine	« Fajma », `fajma.sn` (référencé dans la configuration)	⚖️ Dépôt de marque (OAPI) et titulaire du domaine
Données	Comptes, rendez-vous, dossiers médicaux, paiements	⚖️ Une cession de base de données de santé suppose l'accord de la CDP et l'information des personnes
Comptes prestataires	Hébergeur, PayDunya, Twilio, agrégateur USSD, fournisseur IA, SMTP, Google Play	Transfert des comptes ou re-création au nom de l'acquéreur ; les clés sont hors du code (§ 2.7)
Application Android	Configuration Trusted Web Activity (`twa-manifest.json`)	Clé de signature Play Store : à conserver et transférer (sa perte empêche toute mise à jour)

Le code ne contient **aucun secret** et **aucune dépendance** à une plateforme propriétaire : il s'installe sur n'importe quel serveur Linux avec PostgreSQL, et rien n'attache l'acquéreur à un fournisseur donné.

6.2 Licences des composants libres

Synthèse de l'inventaire complet du chapitre 7 (généré par `tools/inventaire_licences.py`, dépendances directes et indirectes, liste détaillée en annexe CSV).

Licence	Composants	Conséquence pour une exploitation commerciale
MIT, BSD, ISC, Apache 2.0, PSF	Django, Django REST Framework, React, TanStack, Tailwind, Leaflet, Recharts, pdf-lib, gunicorn, cryptography, requests… (les 49 composants envoyés aux navigateurs ; 35 paquets Python sur 42)	Usage commercial libre ; conserver les mentions de licence
LGPL 3.0	`psycopg` (connexion PostgreSQL), `recurring-ical-events`, `x-wr-timezone` (lecture des agendas)	Utilisables dans un produit propriétaire sans publier le code de Fajma, tant que ces bibliothèques ne sont pas modifiées ; en cas de modification, publier les modifications de la bibliothèque
MPL 2.0	`certifi`, `pywebpush`, `py-vapid`	Usage libre ; les fichiers de ces bibliothèques modifiés restent sous MPL

Aucune licence « contaminante » (GPL, AGPL) n'impose de publier le code de Fajma. Le code propre de Fajma n'est pas publié sous licence libre. ⚖️ Régénérer l'inventaire au moment de la cession et le faire confirmer par le conseil juridique de l'acquéreur.

Chiffres d'activité. L'administration produit un rapport d'activité mensuel (patients, médecins, consultations, ordonnances, paiements, chiffre d'affaires, fidélité), téléchargeable en tableur ou imprimable en PDF, sans aucune donnée nominative : c'est la pièce à joindre au dossier de cession avec ce document.

6.3 Dépendance aux prestataires

Prestataire	Remplaçable ?	Effort de remplacement
Hébergeur	Oui : Docker Compose standard, aucun service propriétaire	Faible (déploiement + restauration d'une sauvegarde)
PayDunya	Oui : un seul module (`backend/payments/paydunya.py`)	Moyen (nouveau module + contrat)
Twilio (SMS, WhatsApp)	Oui : un seul module d'envoi (`backend/notifications/sms.py`)	Moyen (opérateur SMS local, fournisseur WhatsApp Business)
Agrégateur USSD	Oui : protocole simple, point d'entrée unique	Faible à moyen
Jitsi	Oui : logiciel libre, auto-hébergeable (`JITSI_DOMAIN`)	Faible
Fournisseur IA	Oui : toute API compatible OpenAI (variable d'environnement)	Nul

6.4 Coûts d'exploitation (ordres de grandeur, à confirmer)

Poste	Démarrage	Remarque
Serveur (4 vCPU, 8 Go, 100 Go SSD)	Quelques dizaines d'euros par mois hors Sénégal ; à chiffrer auprès d'un hébergeur sénégalais	Un seul serveur suffit pour le lancement (§ 4.7)
Stockage des sauvegardes hors site	Quelques euros par mois	Obligatoire (copie hors du serveur)
SMS et WhatsApp	À l'unité (tarif Twilio vers le Sénégal)	Principal coût variable : rappels 24 h et 2 h ; les notifications push sont gratuites
Paiement	Commission par transaction (contrat PayDunya)	Répercutée dans la commission de la plateforme
Jitsi auto-hébergé	Un second serveur selon le volume de téléconsultations	
Assistant IA	Au volume de requêtes	Désactivable
Test d'intrusion	Prestation ponctuelle, puis annuelle recommandée	
Nom de domaine, Play Store	Faible (annuel / unique)	

6.5 Reprise par une autre équipe

- **Compétences** : Python/Django et React/TypeScript, technologies très répandues ; aucun cadre propriétaire.
- **Documentation** : `README.md` (installation), ce dossier (architecture, sécurité, exploitation), commentaires en français dans le code, décrivant les règles métier.
- **Filets de sécurité** : 429 tests automatisés de l'API, typage TypeScript strict, analyse de code (ESLint, Prettier), intégration continue sur chaque modification.
- **Données de démonstration** : `python manage.py seed_demo --accounts --activity` crée des comptes de test pour chaque rôle et 12 semaines d'activité simulée.
- **Délai de prise en main estimé** : quelques jours pour un développeur Django/React expérimenté.

6.6 Points ouverts à connaître avant une offre

Voir le registre des risques. En résumé : autorisation CDP et cadre juridique (CGU, encaissement pour le compte des médecins, transferts de données) non encore obtenus ; téléconsultation sur le serveur Jitsi public ; pas encore de test d'intrusion externe ; intégrations PayDunya, Twilio et USSD testées en simulation, sans compte de production ; virements aux médecins exécutés manuellement.

7. Inventaire des licences

Inventaire généré le 08/10/2026 par `tools/inventaire_licences.py` à partir des fichiers de dépendances du dépôt (`backend/requirements.txt` et environnement installé, `package-lock.json`). Il couvre les dépendances directes **et indirectes**. Liste complète, avec la source de chaque composant : `annexes/licences.csv` (ouvrable dans un tableur). À régénérer avant toute cession pour refléter la version livrée.

7.1 Synthèse

Origine	Composants	Permissive	Copyleft faible	Copyleft fort	À vérifier
Serveur (Python)	47	40	7	0	0
Application web — envoyée aux navigateurs	49	49	0	0	0
Outils de construction et de développement — non livrés	439	415	24	0	0

- **Permissive** (MIT, BSD, ISC, Apache 2.0, PSF…) : usage commercial libre, y compris dans un logiciel vendu ; seule obligation, conserver les mentions de copyright et de licence.
- **Copyleft faible** (MPL 2.0, LGPL) : le composant peut être utilisé dans un logiciel propriétaire ; seules les modifications apportées **au composant lui-même** devraient être publiées. Fajma n'en modifie aucun.
- **Copyleft fort** (GPL, AGPL) : imposerait de publier le code de Fajma. **Aucun composant de ce type.**
- **À vérifier** : licence non déclarée dans les métadonnées ; à contrôler à la main.

7.2 Composants à signaler

Origine	Composant	Licence	Catégorie
Serveur (Python)	certifi 2026.7.22	MPL-2.0	faible
Serveur (Python)	psycopg 3.3.6	LGPL-3.0-only	faible
Serveur (Python)	psycopg-binary 3.3.6	LGPL-3.0-only	faible
Serveur (Python)	py-vapid 1.9.4	MPL-2.0	faible
Serveur (Python)	pywebpush 2.5.0	MPL-2.0	faible
Serveur (Python)	recurring-ical-events 3.8.2	LGPL-3.0-or-later	faible
Serveur (Python)	x-wr-timezone 2.0.1	GNU Lesser General Public License v3 or later (LGPLv3+)	faible
Outil de construction	lightningcss (et 11 variantes par système)	MPL-2.0	faible

Analyse.

- **Serveur — copyleft faible** (certifi, psycopg, psycopg-binary, py-vapid, pywebpush, recurring-ical-events, x-wr-timezone) : bibliothèques utilisées telles quelles, sans modification, et appelées par le code de Fajma (pilote PostgreSQL `psycopg`, certificats racines `certifi`, notifications Web Push, lecture d'agendas iCal). La LGPL et la MPL autorisent cet usage dans un logiciel propriétaire ; elles n'imposeraient de publier que des modifications de ces bibliothèques elles-mêmes, et le serveur n'est pas redistribué (service en ligne).
- **Application web livrée** : uniquement des licences permissives.

- **Outils de construction — copyleft faible** (lightningcss) : servent à compiler l'application, ne sont ni livrés ni modifiés : aucune obligation.
- **Copyleft fort** : aucun composant. Rien n'oblige à publier le code source de Fajma, qui reste propriétaire.

⚖️ Faire confirmer par le conseil juridique de l'acquéreur, qui peut relancer l'outil sur le dépôt.

7.3 Obligations à respecter

1. Conserver les fichiers de licence des composants (présents dans les paquets installés) et une page « Mentions et licences » accessible aux utilisateurs si l'application est redistribuée (application Android publiée sur le Play Store, par exemple).
2. Ne pas modifier les composants sous MPL / LGPL sans publier ces modifications, ou les remplacer.
3. Régénérer cet inventaire à chaque ajout de bibliothèque (commande en tête du fichier de l'outil).

7.4 Serveur (Python) — liste complète

Composant	Version	Licence	Catégorie
aiohappyeyeballs	2.7.1	PSF-2.0	permissive
aiohttp	3.14.3	Apache-2.0 AND MIT	permissive
aiosignal	1.4.0	Apache-2.0	permissive
asgiref	3.12.1	BSD	permissive
attrs	26.1.0	MIT	permissive
cbor2	6.1.5	MIT	permissive
certifi	2026.7.22	MPL-2.0	faible
cffi	2.1.1	MIT-0	permissive
charset-normalizer	3.5.1	MIT	permissive
click	8.5.0	BSD-3-Clause	permissive
cryptography	50.0.1	Apache-2.0 OR BSD-3-Clause	permissive
Django	6.1.1	BSD-3-Clause	permissive
django-stubs-ext	6.1.1	MIT	permissive
django-tasks-db	0.13.0	BSD-3-Clause	permissive
djangorestframework	3.18.1	BSD-3-Clause	permissive
frozenlist	1.8.0	Apache-2.0	permissive
gunicorn	26.2.0	MIT	permissive
h11	0.16.0	MIT	permissive
http_ece	1.2.1	MIT	permissive
icalendar	7.3.0	BSD-2-Clause	permissive
idna	3.20	BSD-3-Clause	permissive
multidict	6.9.1	Apache License 2.0	permissive
propcache	0.5.4	Apache-2.0	permissive
psycopg	3.3.6	LGPL-3.0-only	faible
psycopg-binary	3.3.6	LGPL-3.0-only	faible

Composant	Version	Licence	Catégorie
py-vapid	1.9.4	MPL-2.0	faible
pyasn1	0.6.4	BSD-2-Clause	permissive
pyasn1_modules	0.4.2	BSD	permissive
pycparser	3.0	BSD-3-Clause	permissive
pyOpenSSL	26.4.0	Apache-2.0	permissive
python-dateutil	2.9.0.post0	BSD OR Apache-2.0	permissive
python-dotenv	1.2.3	BSD-3-Clause	permissive
pywebpush	2.5.0	MPL-2.0	faible
recurring-ical-events	3.8.2	LGPL-3.0-or-later	faible
requests	2.34.2	Apache-2.0	permissive
sentry-sdk	2.71.0	MIT	permissive
six	1.17.0	MIT	permissive
sqlparse	0.6.0	BSD	permissive
typing_extensions	4.16.0	PSF-2.0	permissive
tzdata	2026.4	Apache-2.0	permissive
urllib3	2.8.0	MIT	permissive
uvicorn	0.54.0	BSD-3-Clause	permissive
uvicorn-worker	0.4.0	BSD-3-Clause	permissive
webauthn	3.0.1	BSD-3-Clause	permissive
whitenoise	6.12.0	MIT	permissive
x-wr-timezone	2.0.1	GNU Lesser General Public License v3 or later (LGPLv3+)	faible
yarl	1.25.1	Apache-2.0	permissive

7.5 Application web livrée — liste complète

Composant	Version	Licence	Catégorie
@pdf-lib/standard-fonts	1.0.0	MIT	permissive
@pdf-lib/upng	1.0.1	MIT	permissive
@tanstack/history	1.162.0	MIT	permissive
@tanstack/query-core	5.101.4	MIT	permissive
@tanstack/react-query	5.101.4	MIT	permissive
@tanstack/react-router	1.170.18	MIT	permissive
@tanstack/react-start	1.168.32	MIT	permissive
@tanstack/react-start-client	1.168.16	MIT	permissive
@tanstack/react-store	0.9.3	MIT	permissive
@tanstack/router-core	1.171.15	MIT	permissive
@tanstack/start-client-core	1.170.14	MIT	permissive

Composant	Version	Licence	Catégorie
@tanstack/store	0.9.3	MIT	permissive
clsx	2.1.1	MIT	permissive
d3-array	3.2.4	ISC	permissive
d3-color	3.1.0	ISC	permissive
d3-format	3.1.2	ISC	permissive
d3-interpolate	3.0.1	ISC	permissive
d3-path	3.1.0	ISC	permissive
d3-scale	4.0.2	ISC	permissive
d3-shape	3.2.0	ISC	permissive
d3-time	3.1.0	ISC	permissive
d3-time-format	4.1.0	ISC	permissive
decimal.js-light	2.5.1	MIT	permissive
dijkstrajs	1.0.3	MIT	permissive
eventemitter3	4.0.7	MIT	permissive
fast-equals	5.4.1	MIT	permissive
internmap	2.0.3	ISC	permissive
leaflet	1.9.4	BSD-2-Clause	permissive
lodash	4.18.1	MIT	permissive
lucide-react	0.575.0	ISC	permissive
pako	1.0.11	(MIT AND Zlib)	permissive
pdf-lib	1.17.1	MIT	permissive
prop-types	15.8.1	MIT	permissive
qrcode	1.5.4	MIT	permissive
react	19.2.8	MIT	permissive
react-dom	19.2.8	MIT	permissive
react-is	18.3.1	MIT	permissive
react-smooth	4.0.4	MIT	permissive
recharts	2.15.4	MIT	permissive
recharts-scale	0.4.5	MIT	permissive
scheduler	0.27.0	MIT	permissive
seroval	1.6.8	MIT	permissive
seroval-plugins	1.5.6	MIT	permissive
sonner	2.0.7	MIT	permissive
tiny-invariant	1.3.3	MIT	permissive
tslib	2.8.1	0BSD	permissive
use-sync-external-store	1.6.0	MIT	permissive
victory-vendor	36.9.2	MIT AND ISC	permissive

Composant	Version	Licence	Catégorie
zod	3.25.76	MIT	permissive

Les 439 outils de construction et de développement (Vite, TypeScript, Tailwind, ESLint, Prettier et leurs dépendances) ne sont pas envoyés aux navigateurs ; ils figurent dans `annexes/licences.csv`.

8. Guide fonctionnel de A à Z

Ce chapitre décrit, rôle par rôle, tout ce que permet Fajma, dans l'ordre où chaque utilisateur le rencontre, puis les automatismes (messages, rappels, tâches) et les règles de fonctionnement. Il complète la vue technique du chapitre 1 et les règles de sécurité du chapitre 2.

8.1 Les acteurs et leurs espaces

Acteur	Espace	Connexion	Ce qu'il voit
Visiteur	Pages publiques	Aucune	Recherche, fiches des médecins, cliniques, pharmacies, tarifs, aide, vérification d'ordonnance
Patient	« Mon espace », « Mon dossier », messagerie	Code SMS (par défaut) ou email + mot de passe	Ses rendez-vous, son dossier et celui de ses proches
Médecin	Espace médecin (7 onglets)	Email + mot de passe + **double authentification obligatoire**	Son agenda, ses patients (avec RDV confirmé ou terminé), ses finances
Secrétariat	Agenda de la clinique ou du cabinet	Idem (2FA obligatoire)	Agendas, prise de RDV, fichier patients — **jamais** les dossiers médicaux
Responsable de clinique	Espace clinique	Idem	Établissement, équipe, agenda commun
Pharmacien	Espace pharmacie	Idem	Ordonnances qu'on lui adresse, demandes de disponibilité, horaires et garde
Laboratoire	Espace laboratoire	Idem	Analyses qu'on lui adresse ; dépôt des résultats
Administration Fajma	Administration	Idem	Validation, support, modération, finances, journal d'audit, pilotage
Secours	Fiche d'urgence (QR code)	Aucune	Seulement les informations que le patient a choisi de rendre visibles

Après connexion, chacun arrive directement dans son espace. Un professionnel sans double authentification est d'abord conduit à l'activer ; il est déconnecté après 30 minutes sans activité.

8.2 Patient

Créer son compte et se connecter

1. Saisir son numéro de téléphone, recevoir un code à 6 chiffres par SMS (3 codes au plus par 10 minutes), le saisir : le compte est créé. L'email et le mot de passe restent possibles.
2. Compléter son profil (nom, téléphone, **email**, ville, langue : français, wolof ou anglais) et ajouter ses proches (enfants, parents) pour prendre rendez-vous et tenir leur carnet à leur nom. Proches et assurances se corrigent à tout moment (crayon). L'email s'ajoute ou se change dans « Mes coordonnées » : un lien est envoyé à la nouvelle adresse, qui n'est enregistrée qu'à son ouverture.
3. Chaque connexion depuis un appareil jamais utilisé déclenche une alerte (email, ou SMS sans email).

Trouver un médecin et réserver

1. Rechercher par spécialité, nom, ville ou quartier (ou « autour de moi »), avec des filtres : disponible aujourd'hui ou cette semaine, vidéo, visite à domicile, langue, assurance acceptée, prix ; en liste ou sur

une carte. Les spécialités et les pages des cliniques permettent aussi d'y accéder.
2. Ouvrir la fiche : présentation, tarifs par motif, lieux (avec itinéraire), assurances acceptées et tiers payant, avis, prochains créneaux.
3. Choisir le mode (cabinet, vidéo, domicile si proposé), le motif, le lieu, un créneau, le proche concerné, son assurance ; écrire un motif libre.
4. **Questions du médecin** : si le médecin en a rédigé, elles s'affichent sous le motif. Y répondre est **facultatif** ; on peut aussi répondre plus tard depuis son espace.
5. Pour certains motifs (kinésithérapie, pansements…), réserver une **série de séances** en une fois.
6. Confirmer. Le rendez-vous est confirmé tout de suite ou après validation du médecin, selon son choix.
7. Aucun créneau ? S'inscrire sur la **liste d'attente** : un SMS prévient dès qu'un créneau se libère.

Avant et pendant le rendez-vous

- Rappels automatiques 24 h et 2 h avant ; ajout à son agenda (fichier `.ics`).
- Déplacer ou annuler en ligne jusqu'au délai fixé par le médecin ; un rendez-vous payé en ligne puis annulé est remboursé intégralement.
- Payer en ligne (Wave, Orange Money, Free Money, carte) ou au cabinet ; reçu téléchargeable, qui sert de feuille de soins.
- Téléconsultation : bouton « Rejoindre » à l'heure du rendez-vous, sans application à installer.

Après la consultation

- Le compte-rendu et l'ordonnance arrivent dans « Mon dossier », avec notification et SMS.
- **Ordonnance** : PDF signé avec QR code de vérification ; envoi à une pharmacie partenaire en un clic, suivi de sa préparation (reçue, en préparation, prête, retirée).
- **Analyses** : choisir un laboratoire partenaire ; les résultats arrivent dans le dossier.
- **Certificats et arrêts de travail** : dans le dossier, en PDF vérifiable.
- **Avis** sur le médecin (une fois la consultation terminée).

Suivre sa santé au quotidien

- **Renouvellement d'ordonnance** : sous chaque ordonnance de moins d'un an, « Demander le renouvellement » avec un message facultatif. Pour les traitements longs, un SMS rappelle 7 jours avant la fin de validité. Le médecin renouvelle (nouvelle ordonnance) ou refuse en expliquant pourquoi.
- **Rappels de médicaments** : heures de prise (1 à 6 par jour), durée, à partir d'une ordonnance ou en saisie libre.
- **Suivi à domicile** : tension, glycémie, poids, avec courbe et repères. Une valeur dangereuse, ou élevée 3 fois en une semaine, prévient les médecins qui suivent le patient (désactivable).
- **Carnet de santé** : vaccins de chaque enfant selon le calendrier PEV (à faire, en retard, fait) ; suivi de grossesse (terme, consultations prénatales) ; rappels par SMS.
- **Disponibilité d'un médicament** : interroger jusqu'à 5 pharmacies partenaires, qui répondent sans connaître l'identité du patient.
- **Mes médecins** : les médecins déjà consultés, pour reprendre rendez-vous en un clic.
- **Messagerie** avec ses médecins, avec photos ou PDF.

Son dossier médical

- Profil de santé (groupe sanguin, allergies, antécédents, traitements, vaccinations, personne à prévenir).
- Documents déposés (PDF, photos), partagés seulement avec les médecins que le patient choisit.
- « Qui a consulté mon dossier » : chaque accès d'un professionnel est listé.
- **Télécharger mon dossier (PDF)** : tout le dossier en un document, à remettre à un médecin.
- **Fiche d'urgence** (pour soi et pour chaque proche : enfant, parent âgé) : à activer ; **alertes vitales** affichées en gros en tête (diabétique sous insuline, diabétique, épileptique, drépanocytaire, sous

anticoagulant, maladie du cœur, hypertension, asthme, dialyse, allergie grave, hémophile, enceinte, troubles de la mémoire, handicap) ; jusqu'à **3 personnes à prévenir** (nom, lien, téléphone) — pour un proche, le titulaire du compte est toujours prévenu en premier ; appareils médicaux ; note pour les secours ; le patient choisit ce qui est visible (aussi médecin traitant avec son téléphone, assurance, poids). Page des secours en **français, wolof ou anglais**, avec SAMU 1515, pompiers 18, police 17, et pour chaque proche « Appeler », « WhatsApp » et « Envoyer la position » (lien de carte par SMS). QR code en image de fond d'écran ou **carte de portefeuille** à imprimer (format carte bancaire, recto-verso). Chaque consultation est journalisée et le titulaire est prévenu par SMS (une fois par jour). Un nouveau lien rend l'ancien QR code inutilisable. Option **« Résumé de mes médecins »** (décochée par défaut) : conclusions des 3 dernières consultations (12 mois) et ordonnances en cours ; jamais les notes privées des médecins ni les diagnostics sensibles (codes VIH, IST, santé mentale, ou mots correspondants). Fajma propose d'ajouter les médicaments des ordonnances en cours à « Traitements en cours » (un clic, rien d'automatique), signale les informations cochées mais vides, rappelle par SMS tous les 6 mois de vérifier la fiche, et indique aux secours une fiche vieille de plus d'un an. Le QR code n'expire pas (un accident n'a pas de date ; carte et fond d'écran restent valables) : il reste révocable à tout moment et chaque consultation est signalée par SMS.

- Télécharger toutes ses données (JSON) ou supprimer son compte.

Sans smartphone : prendre rendez-vous par **WhatsApp** ou par le menu **USSD** (tout téléphone, sans internet).

8.3 Médecin

Démarrer

1. Créer son compte, puis sa fiche dans l'espace médecin (nom, spécialité, ville, tarif). La double authentification est activée à la première connexion.
2. Le guide **« Bien démarrer sur Fajma »** affiche 7 étapes, avec un bouton qui ouvre le bon onglet : compléter sa fiche publique (photo, présentation, adresse) ; déposer ses justificatifs (Ordre, pièce d'identité) ; définir son emploi du temps ; vérifier ses motifs et tarifs ; compléter l'en-tête des ordonnances ; sécuriser son compte ; attendre la validation. Il disparaît quand tout est fait.
3. L'équipe Fajma vérifie les justificatifs et publie la fiche ; le médecin est prévenu par SMS et email (pièces exigées : § 8.12).

Onglet « Emploi du temps »

- Semaine type : ajouter une plage (par exemple 8 h – 13 h) à plusieurs jours d'un coup, choisir la durée des créneaux, le lieu, ou en faire une plage de visites à domicile. Un clic sur une plage la modifie ou la supprime ; deux plages qui se chevauchent sont refusées.
- Aperçu de ce que voient les patients sur les 7 prochains jours.
- Absences (congés, formation), règles de réservation (confirmation automatique — **activée par défaut** —, nouveaux patients, délai minimal, horizon, délai d'annulation, consignes, visites à domicile), motifs et tarifs (dont séries), lieux de consultation, synchronisation avec Google Agenda / Outlook / iPhone.

Onglet « Rendez-vous » (la journée)

- Agenda en liste ou en semaine. **En semaine, glisser un rendez-vous** pour le déplacer ou tirer son bord pour changer sa durée ; une confirmation est demandée et le patient est prévenu.
- Confirmer, marquer « arrivé », « terminé » ou « absent », annuler avec un motif, déplacer, ajouter des séances.
- « Nouveau RDV » : rendez-vous pris au téléphone, y compris pour un patient sans compte.
- Ouvrir la consultation : fiche patient (profil, mesures, documents partagés, historique, réponses au questionnaire, notes privées), compte-rendu, ordonnance structurée, analyses, certificat ou arrêt de

travail, vaccin inscrit au carnet, « réglé au cabinet ».

- **Assistant de prise de notes** : dicter ou taper ses notes, puis « Rédiger le compte-rendu » range le texte dans Résumé / Conclusion / Traitement. Le médecin relit toujours avant d'enregistrer.
- **Demandes de renouvellement** : renouveler ou refuser avec un motif.
- **Alertes** : une mesure dangereuse d'un patient suivi arrive dans les notifications.

Les autres onglets

- **Profil et cabinet** : fiche publique et photo, justificatifs, assurances acceptées (tiers payant), **questionnaire patient** (questions par défaut ou par motif, jamais obligatoires pour le patient), avis (réponse, signalement), module de réservation à intégrer à son propre site.
- **Ordonnances** : en-tête (n° d'Ordre, cabinet, signature tracée, cachet) et **aperçu d'une ordonnance spécimen** ; aucune ordonnance ni certificat n'est possible tant que l'en-tête est incomplet.
- **Secrétariat et remplacements** : donner l'accès à sa secrétaire ; proposer un remplacement à un confrère, qui reçoit les patients et signe à son nom pendant la période.
- **Finances** : solde, demande de virement dès 5 000 F, historique, formule (Essentiel gratuite, Pro, Clinique), exports tableur (rendez-vous, bordereau de tiers payant, revenus).
- **Sécurité** : notifications sur le téléphone, **clés d'accès** (se connecter avec son empreinte, son visage ou le code de son téléphone — un faux site ne peut pas s'en servir, contrairement au code à six chiffres), double authentification par code, mot de passe. Un professionnel ne peut pas retirer sa dernière seconde étape de connexion.
- **Télé-expertise** et **messagerie** avec les confrères et les patients.

8.4 Secrétariat et clinique

- **Responsable** : crée l'établissement, invite les médecins et la secrétaire, modifie les informations, retire un médecin qui part, change le titre affiché d'un médecin (« Chef de service »…) ou le rôle d'un membre du secrétariat (secrétaire / gestionnaire), dépose les justificatifs de l'établissement (§ 8.12). La clinique est publiée après vérification par Fajma.
- **Secrétaire** : agenda de tous les médecins par semaine, prise de RDV au guichet ou au téléphone (même pour un patient sans compte, avec son téléphone pour les rappels), créneaux libres proposés, déplacement, annulation, « venu », séances, fichier patients avec détection et fusion des doublons, export de l'agenda. Aucun accès aux dossiers médicaux.

8.5 Pharmacie

- Ordonnances reçues en trois colonnes (reçues, en préparation, prêtes) : préparer, indiquer le prix, signaler une rupture, marquer « retirée » (le nombre de délivrances autorisées est contrôlé). Le patient est prévenu par SMS quand son ordonnance est prête ou indisponible.
- Répondre aux demandes de disponibilité d'un médicament.
- Gérer ses horaires, jours d'ouverture et la **garde** (avec date de fin).
- **Justificatifs de l'officine** (§ 8.12) : tant qu'ils ne sont pas validés, la pharmacie ne reçoit ni ordonnances ni demandes de disponibilité.

8.6 Laboratoire

- Demandes d'analyses reçues : patients attendus, « prélèvement effectué », dépôt des résultats (PDF ou image, avec commentaire). Les résultats rejoignent le dossier du patient ; patient et médecin prescripteur sont prévenus. Recherche par référence ou par nom.
- **Fiche du laboratoire** : quartier, adresse, téléphone et horaires affichés aux patients (le nom et la ville sont corrigés par l'équipe Fajma).

- **Justificatifs du laboratoire** (§ 8.12) : tant qu'ils ne sont pas validés, le laboratoire n'est pas proposé aux patients.

8.6 bis Sécurité de la prescription, imagerie, actes et export international

Contrôle de l'ordonnance (médecin). Pendant la rédaction, chaque médicament est confronté au dossier du patient : allergie déclarée (au médicament ou à sa famille, avec les allergies croisées pénicillines – céphalosporines), interaction avec un traitement en cours (lu dans le profil de santé **et** dans les ordonnances encore valables) ou avec un autre médicament de la même ordonnance, contre-indication liée à l'état du patient (grossesse — reconstituée depuis le carnet de santé —, allaitement, asthme, maladie rénale, insuffisance cardiaque, hypertension, diabète, épilepsie, drépanocytose, **déficit en G6PD**, ulcère, maladie du foie, trouble de la coagulation, glaucome), limite d'âge (aspirine avant 16 ans, cyclines avant 8 ans, codéine et tramadol avant 12 ans…) et prudence après 75 ans. Trois niveaux : alerte majeure, précaution, information. Une alerte majeure **arrête l'enregistrement** tant que le médecin n'a pas écrit pourquoi il maintient sa prescription ; la justification est conservée et journalisée. Catalogue : environ 100 médicaments de la liste nationale (dénominations communes et noms commerciaux courants), reconnus même écrits avec une faute d'accent ou sous leur nom de marque.

Imagerie médicale. Même circuit que les analyses : le médecin prescrit (type d'examen, examens courants proposés, préparation remplie automatiquement, produit de contraste), le patient choisit son centre — seuls ceux qui réalisent l'examen demandé lui sont proposés —, le centre dépose les résultats dans le dossier. Alertes propres à l'imagerie : **grossesse et rayons X**, **appareil implanté et IRM** (pacemaker, valve, éclat métallique), **produit de contraste** chez un patient sous metformine, insuffisant rénal ou allergique à l'iode. Un établissement déclare lui-même ce qu'il fait : analyses, imagerie, ou les deux.

Actes et feuille de soins. Le médecin code les actes réalisés selon la nomenclature des lettres-clés (C, CS, K, B, Z, SF, AMI, D…) : le tarif de base est la valeur de la lettre multipliée par le coefficient. Son prix reste libre ; les actes donnent la **base opposable** à l'organisme. Le patient télécharge une **feuille de soins** (même en-tête et même bas de page que l'ordonnance) indiquant les actes cotés, la base de remboursement, la somme payée, un éventuel dépassement non remboursable, la part de l'organisme et son reste à charge. Les valeurs des lettres-clés se modifient dans « Administration > Système » ; un acte déjà facturé garde son montant.

Export au format international. Dans son dossier, le patient télécharge « Format international (FHIR) » : son dossier complet en HL7 FHIR R4, avec les codes reconnus partout (CIM-10 pour les diagnostics, LOINC pour les mesures). Il peut le remettre à un hôpital ou à une autre application sans ressaisie.

8.6 Générique d'ouverture

À la première ouverture de l'application dans une visite, un générique de **sept secondes** précède la page d'accueil : un tracé d'électrocardiogramme traverse l'écran dans un halo vert, les battements s'accélèrent, un éclat révèle le logo, puis l'écran s'efface sur l'accueil. Il ne se joue **qu'une fois par visite**, jamais entre les pages ; un bouton « Passer » (ou la touche Échap) l'interrompt immédiatement ; et il est entièrement ignoré pour qui a demandé à son appareil de réduire les animations — la page d'accueil s'affiche alors tout de suite. Code : `src/components/OpeningSplash.tsx`.

8.6 bis bis Haut de page du site public

Deux lignes : le logo, un **champ de recherche permanent** (nom, spécialité, ville — il mène à l'annuaire) et, à droite, le thème, la langue, « Je suis pro » et « Connexion » ; en dessous, les rubriques (trouver un médecin, assistant, pharmacies, partenaires, téléconsultation). Chercher un médecin est le geste le plus fréquent : il est

accessible sans redescendre dans la page. L'entrée « Professionnels », qui faisait doublon avec « Je suis pro », est supprimée.

Sur téléphone, les rubriques n'apparaissaient pas du tout : elles étaient simplement masquées en dessous de 1024 px, sans menu de remplacement. Un bouton de menu les ouvre désormais, avec « Je suis pro » et le choix de la langue ; le champ de recherche laisse la place au bloc de recherche de la page d'accueil.

8.6 bis ter Retour en arrière

Une **flèche de retour** figure dans l'en-tête de chaque page. Elle ramène à la page précédente ; quand il n'y en a pas — page ouverte depuis un SMS, une notification, un favori ou un nouvel onglet — elle mène à la page parente (espace du patient, accueil), pour ne jamais laisser l'utilisateur dans une impasse.

8.6 ter Dossier du patient : quatre rubriques

Le dossier était une page unique de plus de 10 000 pixels : quatorze sections à la file, sans menu. Il est rangé en quatre rubriques — **Mes soins** (comptes-rendus, ordonnances, analyses et imagerie, certificats et courriers), **Mon suivi** (rappels de médicaments, mesures à domicile, carnet de santé), **Mes informations** (profil de santé, fiche d'urgence, documents, assurances) et **Mon compte** (sécurité, journal des accès, mes données). La page la plus longue fait désormais 2 600 pixels. Les liens déjà envoyés aux patients (`/dossier#analyses` , `#medicaments` , `#carnet`) ouvrent la bonne rubrique et font défiler jusqu'à la section.

8.7 Administration Fajma

- **Menu par rubriques** (à gauche ; en haut sur téléphone), avec le nombre de choses en attente : tableau de bord, à valider, utilisateurs, réseau de soins, finances, santé publique, communication, support, système, ma sécurité. Chaque membre de l'équipe ne voit que les rubriques de son **rôle** (validations, support, finances, santé publique, communication, super-administrateur), donné dans « Système > Équipe et rôles ».
- **Recherche globale** (en haut) : nom, téléphone, email, n° de l'Ordre, référence d'ordonnance, numéro de reçu ; un médecin ouvre sa **fiche 360°** (coordonnées, justificatifs et pièces manquantes, activité sur 90 jours, avis, solde et virements, établissements ; valider, corriger, suspendre), sans contenu médical.
- **À valider** : uniquement ce qui attend, justificatifs à côté. **Réseau de soins** : un onglet par acteur (médecins filtrables, établissements, pharmacies, laboratoires, relais) ; plus de doublons.
- **Annonces** à un groupe (ville facultative) : notification, SMS et email au choix, nombre de destinataires affiché avant l'envoi, historique ; SMS limité à 5 000 destinataires et 300 caractères.
- **Réglages** sans technicien : message en haut du site, email et téléphone de contact, horaires, code USSD, numéro de déclaration des maladies, minimum de virement aux médecins ; valeurs vérifiées, journalisées.
- **Journal d'audit** : filtres (action, personne, patient, dates), 100 par page, export tableur.
- Bandeau **« À traiter »** : médecins et établissements à valider, justificatifs à vérifier, justificatifs expirés ou qui expirent dans les 30 jours, avis signalés, virements et remboursements, demandes d'aide, SMS en échec.
- **Correction d'une fiche médecin vérifiée** (nom, spécialité) sur justificatif : crayon dans « Validation des médecins », motif obligatoire, journalisé, médecin prévenu. **Laboratoires** : fiche corrigible (crayon).
- **Justificatifs** : une seule liste (filtre médecins, cliniques, pharmacies, laboratoires), ouvrir la pièce, la vérifier à la source, valider ou refuser avec un motif envoyé au professionnel.
- Validation des médecins, cliniques, pharmacies et laboratoires : refusée tant qu'une pièce obligatoire manque, est en attente, refusée ou expirée (le message indique laquelle).
- **Comptes** : recherche, suspension (sessions coupées) ou réactivation, réinitialisation de la double authentification, avec motif journalisé.

- **Support** : demandes reçues par la page « Aide et contact », réponse par email ou téléphone, puis « traitée » avec une note interne.
- Pharmacies (ajout, correction), laboratoires, rattachement des pharmaciens et biologistes.
- Finances : virements aux médecins et remboursements (exécutés manuellement, référence saisie).
- Modération des avis, suivi des SMS, journal d'audit, pilotage hebdomadaire.
- **Rapport d'activité** mensuel : patients, médecins, partenaires, consultations, ordonnances, paiements, chiffre d'affaires, fidélité ; tableur ou PDF ; aucune donnée nominative.

8.8 Visiteurs et secours

- **Aide et contact** : numéros d'urgence (SAMU 1515, sapeurs-pompiers 18), questions fréquentes avec recherche, formulaire de contact ; une personne connectée y retrouve ses demandes et leur état (en cours, traitée).
- **Tarifs** des professionnels, **vérification d'une ordonnance** par sa référence ou son QR code (sans contenu médical).
- **Fiche d'urgence** (QR code) : identité, âge et informations choisies par le patient, bouton « Appeler le SAMU », appel de la personne à prévenir ; page lisible en toutes conditions.

8.9 Automatismes

Événement	Moment	Destinataire	Canal
Demande ou confirmation de RDV	À la réservation / à la confirmation	Patient ; médecin (nouveau RDV)	Notification, SMS (confirmation), email
Rappel de RDV	24 h et 2 h avant	Patient	SMS ou WhatsApp
RDV déplacé ou annulé	Immédiat	Patient ou médecin	Notification, SMS
Créneau libéré	Immédiat	5 premiers inscrits sur la liste d'attente	SMS
Nouvelle ordonnance, compte-rendu	À l'enregistrement	Patient	Notification, SMS (ordonnance)
Ordonnance prête en pharmacie	À la préparation	Patient	Notification, SMS
Résultats d'analyses	Au dépôt	Patient et médecin	Notification
Prise de médicament	Aux heures choisies	Patient	Notification (SMS en option)
Ordonnance d'un traitement long bientôt expirée	7 jours avant	Patient	Notification, SMS
Demande de renouvellement / réponse	Immédiat	Médecin / patient	Notification, email / SMS
Vaccin d'un enfant, consultation prénatale	À l'échéance	Parent, future mère	SMS
Mesure dangereuse ou répétée	Immédiat (1 par 24 h)	Médecins qui suivent le patient	Notification, email si dangereuse
Connexion depuis un nouvel appareil	Immédiat	Titulaire du compte	Email ou SMS
Fiche d'urgence consultée	Immédiat (1 par jour)	Patient	Notification
Fiche publiée, compte rattaché	À la validation	Médecin, pharmacien, biologiste	SMS, email
Demande d'aide	Immédiat	Équipe Fajma	Email (`ALERT_EMAILS`)

Événement	Moment	Destinataire	Canal
Synchronisation des agendas, supervision	Toutes les 10 minutes	— / équipe technique	Alerte email en cas de problème
Purge des données techniques	Chaque nuit	—	—
Sauvegarde chiffrée / test de restauration	Chaque jour / le 1er du mois	—	Alerte en cas d'échec

8.10 Règles de fonctionnement

Règle	Détail
Créneaux	Calculés par le serveur : plages − absences − RDV existants − délai minimal ; jamais deux RDV sur le même horaire (contrainte en base)
Rendez-vous à venir	4 au plus par patient et par médecin (hors séances d'une série)
Nouveaux patients	Un médecin peut les refuser ; ses patients connus restent acceptés
Itinéraire	Sur un rendez-vous au cabinet, « Voir l'itinéraire » affiche une carte (OpenStreetMap) avec le lieu de consultation, la position du patient s'il l'autorise, le **trajet routier tracé**, la distance et le temps de route. Boutons Google Maps et Waze pour la navigation guidée. Le calcul du trajet utilise OSRM (logiciel libre) : serveur public par défaut, `VITE_ROUTING_URL` pour le sien. Service indisponible ou hors ligne : trajet direct en pointillés et distance à vol d'oiseau, l'écran reste utile
Confirmation	**Un créneau libre réservé en ligne est confirmé immédiatement** : le serveur a déjà vérifié qu'il est libre, faire attendre le patient n'apporte rien. Un médecin qui préfère examiner chaque demande décoche « Confirmer automatiquement » dans ses règles de réservation ; le patient le voit sur sa fiche avant de réserver
Annulation	**Toujours possible par le patient** tant que le rendez-vous n'a pas eu lieu. Passé le délai fixé par le médecin, elle est acceptée mais marquée **« annulation tardive »** : le cabinet est prévenu aussitôt par SMS et le créneau redevient réservable. Empêcher une annulation tardive ne fait pas venir le patient, elle produit une absence que le médecin découvre sur place. Déplacer en ligne, en revanche, reste fermé hors délai. Remboursement intégral d'un RDV payé en ligne ; les inscrits de la liste d'attente sont prévenus
Historique d'un RDV	Chaque prise, confirmation, déplacement (ancien → nouvel horaire), annulation (avec motif), arrivée et fin de consultation est enregistrée avec son auteur ; bouton « Historique » sur chaque RDV pour le patient, le médecin et le secrétariat (le patient voit le rôle des membres du cabinet, pas leur nom)
Absences du médecin	Congés et absences bloquent les créneaux en ligne ; les agendas personnels importés aussi
RDV pour un proche	Le patient réserve pour un enfant ou un parent enregistré dans « Mes proches »
Questionnaire	Jamais obligatoire ; questions figées sur le RDV à la réservation ; réponses visibles du seul médecin
Ordonnance et certificat	Impossibles sans en-tête complet (n° d'Ordre, signature) ; en-tête figé à l'émission ; vérifiables par QR code
Renouvellement	Ordonnance de moins d'un an, une demande en cours à la fois, décision du seul prescripteur, refus motivé
Accès d'un médecin au dossier	RDV confirmé ou terminé avec le patient ; documents seulement s'ils sont partagés ; chaque accès journalisé
Fiche d'urgence	Désactivée par défaut ; informations choisies par le patient ; lien révocable

Règle	Détail
Alertes de mesures	3 médecins au plus, une alerte par médecin, patient et type de mesure toutes les 24 h
Sécurité des comptes	Bouton « Déconnecter mes autres appareils » (page Sécurité) en cas de téléphone perdu ; 10 mots de passe faux en 15 min : compte verrouillé 15 min ; code SMS : 3 envois par 10 minutes ; double authentification et déconnexion après 30 min d'inactivité pour les professionnels
Argent	Commission selon la formule (Essentiel 8 %, Pro 3 %, Clinique 2 %) ; virement dès 5 000 F ; paiements vérifiés auprès de PayDunya
Avis	Seulement après une consultation terminée ; modération par Fajma
SMS « STOP »	Répondre STOP (SMS ou WhatsApp) arrête tous les SMS automatiques ; START les réactive ; les codes de connexion demandés restent envoyés
Reçus	Numéro légal continu par année (FJ-2026-000001…), attribué à l'encaissement et imprimé sur le reçu
Exports	Réservés à leur titulaire (médecin, clinique, patient, administration) et journalisés

8.11 Glossaire

Terme	Signification
2FA / double authentification	Code à 6 chiffres d'une application (Google Authenticator…), demandé en plus du mot de passe
CDP	Commission de protection des données personnelles du Sénégal
CPN	Consultation prénatale
IPM	Institution de prévoyance maladie (assurance santé d'entreprise)
PEV	Programme élargi de vaccination
PWA	Application web installable sur le téléphone, utilisable en partie hors ligne
QR code	Code à scanner (vérification d'ordonnance, fiche d'urgence)
Tiers payant	Le patient ne paie que sa part ; le médecin facture le reste à l'organisme
USSD	Menu par code (`#...#`) utilisable sur tout téléphone, sans internet

8.12 Pièces justificatives exigées

Aucun professionnel n'est publié (fiche médecin réservable, clinique dans l'annuaire, pharmacie qui reçoit des ordonnances, laboratoire proposé aux patients) sans **toutes ses pièces obligatoires validées par l'équipe Fajma et en cours de validité**.

Professionnel	Pièces obligatoires	Pièces facultatives
Médecin (y compris indépendant)	Inscription à l'Ordre des médecins ; pièce d'identité*	Diplôme de médecine ou de spécialité ; autre
Clinique, centre de santé	Autorisation d'ouverture et d'exploitation du ministère de la Santé* ; NINEA et RCCM ; pièce d'identité du responsable* ; désignation du médecin responsable (directeur médical)	Autre
Pharmacie	Autorisation d'exploitation de l'officine* ; inscription du pharmacien titulaire à l'Ordre des pharmaciens	NINEA ; autre
Laboratoire	Agrément du laboratoire d'analyses médicales* ; inscription du biologiste responsable à son Ordre	NINEA ; autre

* Pièce à durée limitée : sa date de fin de validité est demandée au dépôt (une pièce déjà expirée est refusée). Rappel au professionnel (notification, email) 30 jours avant l'échéance puis après l'échéance ; une pièce expirée ne compte plus et apparaît dans « À traiter ». Une fiche déjà publiée n'est pas retirée automatiquement : l'administration voit ce qui manque et décide.

- Dépôt : PDF ou image, chiffré, analysé par l'antivirus ; visible du seul titulaire et de l'administration. Une pièce validée ne peut plus être supprimée par le professionnel.
- Le cabinet d'un médecin seul ne demande pas de pièces d'établissement : ce sont celles du médecin qui comptent.
- Pharmacies et laboratoires déjà partenaires avant cette règle restent en ligne ; leurs pièces sont à demander.
- La liste est à faire valider par un juriste et les Ordres professionnels ; elle se modifie en un seul endroit (`backend/directory/requirements.py`), écrans et contrôles suivent automatiquement.

8.13 Audit « saisir et corriger » (5 octobre 2026)

Contrôle de chaque information enregistrée (75 tables) : peut-elle être saisie et corrigée par la bonne personne, dans son espace ? Chaque adresse de l'API est reliée à un écran. Manques trouvés et corrigés :

Interface	Manque	Correction
Patient	Impossible de saisir ou changer son email	« Mes coordonnées » : email confirmé par lien (§ 2.4) ; aussi dans « Sécurité du compte » des professionnels
Patient	Un proche mal saisi devait être supprimé puis recréé ; téléphone du proche non saisissable	Crayon « Modifier », champ téléphone
Patient	Assurance non modifiable (n° d'adhérent, taux, date de fin)	Crayon « Modifier »
Patient, professionnels	Aucun suivi des demandes d'aide envoyées	« Mes demandes » sur la page Aide et contact
Médecin	Lieu de consultation non modifiable	Crayon « Modifier » (position GPS conservée)
Laboratoire	Horaires, téléphone, adresse non modifiables par le laboratoire	Fiche du laboratoire dans son espace
Clinique	Rôle du secrétariat et titre des médecins non modifiables	Liste « Rôle » et crayon « Titre »
Administration	Fiche d'un laboratoire non corrigible ; nom ou spécialité d'un médecin vérifié non corrigible alors que le médecin est renvoyé vers l'équipe	Crayons de correction (motif obligatoire pour le médecin)

Restent volontairement non modifiables : ordonnances, certificats et comptes-rendus émis (documents médicaux et légaux : on en émet un nouveau), reçus, journal d'audit, organisme et bénéficiaire d'une assurance (on la supprime et on la recrée), avis publiés.

8.15 Entraide familiale (« Je paie la santé de mes parents »)

Pour la diaspora et les familles : un proche aide un parent au Sénégal, avec son accord.

Proche aidant (espace « Famille », `/famille`)

1. « Ajouter un proche » : nom, comment il l'appelle (« Maman »), numéro au Sénégal, langue du SMS et droits demandés : payer ses consultations (toujours), prendre ses rendez-vous, voir ses ordonnances et comptes-rendus.

2. Le parent reçoit un SMS qui annonce exactement ces droits et un code à 6 chiffres (valable 24 h). En le donnant au téléphone, il donne son accord ; aucun smartphone n'est nécessaire. Son compte Fajma est créé si besoin (connexion par code SMS) et son numéro est vérifié du même coup.
3. Crédit santé : recharge de 10 000, 25 000, 50 000, 100 000 F ou d'un autre montant, par carte bancaire ou mobile money (PayDunya), montant affiché aussi en euros (parité fixe 1 € = 655,957 F). Reçu numéroté.
4. Paiement d'une consultation du parent avec le crédit (immédiat) ou directement par carte ; le parent est prévenu qu'il n'a rien à régler au cabinet ; le reçu porte le nom du proche qui a payé.
5. « Prendre un rendez-vous pour Maman » : recherche normale, la fiche du médecin réserve au nom du parent (rappels SMS au parent, qui est prévenu).
6. Nouvelles : rendez-vous pris, confirmé, annulé ; consultation payée ; alerte quand le crédit passe sous un seuil choisi ; rappel mensuel de recharge facultatif. Comptes-rendus et ordonnances si le droit est accordé.

Parent (bénéficiaire) : carte « Entraide familiale » de son espace : qui l'aide, crédit offert, accepter ou refuser une invitation, cocher / décocher chaque droit, retirer tout l'accès. Il peut aussi payer lui-même ses consultations avec le crédit offert (choix « Crédit santé » au paiement).

Règles

- Le proche ne peut que retirer un droit ; un droit nouveau est accordé par le parent depuis son espace.
- 5 invitations par jour, 3 codes par invitation, 5 essais par code.
- Annulation d'une consultation payée avec le crédit : le montant revient aussitôt sur le crédit (remboursement enregistré, part du médecin retirée).
- Crédit restant après l'arrêt de l'entraide : remboursé au proche sur demande à l'équipe Fajma.
- Chaque consultation du dossier par le proche est inscrite au journal d'audit, visible du patient.

8.16 WhatsApp : demandes en phrases libres

- Au lieu de taper des numéros, la personne écrit ce qu'elle veut, en wolof, français ou anglais : « Sama doom dafa am yaram » (mon enfant a de la fièvre), « je veux un pédiatre à Thiès », « quand est mon rendez-vous », « pharmacie de garde ».
- Fajma reconnaît la demande (rendez-vous, mes rendez-vous, annulation, pharmacies), la spécialité (y compris par les mots du quotidien : enfant, dents, yeux, cœur, grossesse…) et la ville, puis le menu reprend directement à la bonne étape. La réponse est en wolof si la personne a écrit en wolof. Sans IA : mots-clés, à faire relire par un locuteur.

8.17 Avis médical écrit (consultation asynchrone)

Pour les zones où la vidéo passe mal, ou pour une question qui ne justifie pas un déplacement.

Médecin : onglet « Avis écrits » de l'espace médecin — activer l'offre, prix, délai de réponse (24 ou 48 h), consignes aux patients. Les demandes payées arrivent avec leur échéance (SMS au médecin) : motif, symptômes, depuis quand, température, tension, poids, traitements en cours, photos. Il répond par écrit et conclut : conseils, ordonnance (médicaments ajoutés directement, en-tête et signature habituels), consultation en personne conseillée, ou urgence (le patient est invité à appeler le SAMU, 1515).

Patient : sur la fiche du médecin, « Demander un avis écrit » ; description, mesures facultatives, jusqu'à 4 photos ; paiement en ligne (mobile money, ou crédit santé offert par un proche — pas d'espèces). Suivi et réponse dans la carte « Avis écrits » de son espace ; ordonnance dans son dossier, envoyable en pharmacie.

Règles

- Chaque demande est un rendez-vous sans durée : paiement, reçu, reversement au médecin, compte-rendu et ordonnance fonctionnent comme une consultation, sans bloquer de créneau ; elle n'apparaît pas dans l'agenda.
- Le délai démarre au paiement ; sans réponse à l'échéance, la demande est annulée et le patient remboursé (aussitôt sur le crédit santé s'il l'avait utilisé), puis prévenu.
- Photos visibles du seul médecin concerné, et seulement une fois la demande payée.
- Deux demandes en cours au plus par patient et par médecin ; annulation possible avant la réponse.

8.18 Relais communautaires

Pour faire entrer dans Fajma les personnes sans smartphone ni internet (personnes âgées, mères et jeunes enfants, malades chroniques), avec les relais de santé qui les connaissent déjà.

- **Habilitation** : l'administration habilite un compte (structure : poste de santé, ONG, district ; zone couverte ; 300 personnes au plus par défaut). Le relais arrive sur son espace « Relais » (`/relais`).
- **Ajouter une personne** : nom, date de naissance, sexe, quartier ou village, téléphone d'un proche, repère (accès à la maison, sans donnée médicale) et **accord obligatoire** : oral devant témoin, formulaire signé, ou accord du tuteur ; chaque ajout est journalisé.
- **Suivre** : chaque personne est un « proche » du compte du relais ; il prend ses rendez-vous (choix « Pour qui »), reçoit les rappels, note tension, glycémie, poids et vaccins avec les outils habituels.
- **Alertes du jour**, personnes les plus urgentes en tête : tension ≥ 180/110 ou glycémie ≥ 3 g/L ou < 0,6 g/L (orienter aujourd'hui), tension ≥ 140/90 ou glycémie élevée (consultation à prévoir), vaccins de l'enfant en retard ou à faire, rendez-vous dans les 2 jours (prévenir, accompagner).
- **Transfert du dossier** : quand la personne a son téléphone, le relais saisit son numéro ; elle reçoit un code par SMS et le lui donne (son accord). Tout son dossier passe sur son propre compte (rendez-vous, comptes-rendus, ordonnances, vaccins, mesures, assurances, analyses), qui est créé si besoin ; elle se connecte avec son numéro. Le transfert couvre automatiquement toute table liée aux proches.

8.19 Diagnostic codé, déclaration des maladies et veille épidémiologique

Pour aider l'État (Direction de la Prévention, districts sanitaires) à repérer et contenir les épidémies.

Médecin — compte-rendu (et avis écrit)

- En plus du texte libre, il choisit le **diagnostic principal** dans une liste avec recherche (44 maladies, codes CIM-10), regroupée comme la Surveillance intégrée de la maladie et la riposte (SIMR) :
  - **à déclaration immédiate** : choléra, rougeole, méningite, fièvre jaune, dengue, chikungunya, fièvres hémorragiques (Ebola, Marburg, Crimée-Congo, vallée du Rift), paralysie flasque aiguë (polio), tétanos néonatal, diphtérie, mpox, grippe d'un nouveau sous-type, rage, charbon ;
  - **surveillance hebdomadaire** : paludisme, dysenterie, diarrhée aiguë, typhoïde, pneumonie, syndrome grippal, COVID-19, coqueluche, varicelle, tuberculose, **hépatites A/E, B et C**, VIH, IST, bilharziose, lèpre, conjonctivite, malnutrition aiguë de l'enfant, morsure de serpent ;
  - **maladies chroniques** : hypertension, diabète, drépanocytose, asthme, maladie rénale, cancer, santé mentale, anémie ; **santé de la mère** : grossesse à risque ; « autre ».
- Il précise **suspect / probable / confirmé** et le **résultat du test** proposé (TDR palu, test rapide AgHBs, anti-VHC, VIH, NS1 dengue, GeneXpert…). Un test négatif écarte le cas de la veille.
- **Maladie à déclaration immédiate** : message rouge « déclarez ce cas au district sanitaire dès maintenant » (avec le numéro d'alerte réglé par `EPIDEMIC_HOTLINE`), l'équipe Fajma est prévenue aussitôt, et le cas apparaît en haut de son espace dans « Déclarations à faire » jusqu'à ce qu'il clique « J'ai déclaré ce cas » (à qui, référence).

Administration — section « Veille épidémiologique »

- Cas par maladie, **par région** et par semaine (12 semaines), à partir du diagnostic codé (mots-clés du motif et du diagnostic écrit en secours ; la part codée est affichée). Cases de moins de 5 : « <5 ».
- **Signaux** : un seul cas de maladie à déclaration immédiate est toujours signalé ; pour les autres, semaine au-dessus de la moyenne + 2 écarts-types des 8 précédentes (au moins 5 cas, 1,5 fois l'habitude).
- **Déclarations** : liste des cas à déclaration immédiate (maladie, certitude, ville, région, date, médecin et son téléphone pour l'enquête du district), déclarés ou non ; compteur dans « À traiter ».
- **Exports** : tableur anonymisé (cases masquées) et **rapport hebdomadaire SIMR** (dernière semaine complète, région × maladie, CIM-10, suspects / confirmés, comptes exacts) à transmettre aux autorités dans le cadre d'une convention, après accord de la CDP.
- Jamais d'identité de patient ni de texte médical dans la veille ; chaque consultation ou export est journalisé. La liste des maladies se modifie en un seul endroit (`backend/medical/conditions.py`), à faire valider par la Division de la surveillance épidémiologique.

8.20 Partenaires et campagnes sponsorisées

Pour les visiteurs : la campagne apparaît **sous la promesse de Fajma**, pas au-dessus : le visiteur voit d'abord « Votre santé, simplifiée » et la recherche, puis une bande compacte aux couleurs de la campagne (vignette, titre, phrase, bouton), de 96 pixels de haut, encore dans le premier écran sur ordinateur. Le titre de la campagne n'est volontairement pas un titre de page : le premier titre de l'accueil reste celui de Fajma. S'il y a plusieurs campagnes « Accueil » actives (5 au plus, ordre tiré au hasard), elles défilent toutes les 7 secondes (points de pagination, barre de progression, pause au survol ; animations coupées si l'appareil le demande). Bande « Nos partenaires » sur l'accueil (logos qui défilent) et lien « Partenaires » dans le menu ; page « Nos partenaires » (`/partenaires`) — assurances, opérateurs, pharmacies et laboratoires, institutions, ONG ; encarts marqués « Sponsorisé » sur l'accueil, la recherche de médecins (encart séparé, au-dessus des résultats, qui ne change jamais leur ordre) et l'espace patient.

Administration (section « Partenaires et campagnes ») :

- ajouter un partenaire (nom, type, description, site, logo, affichage public ou non) ;
- créer une campagne (partenaire, catégorie : prévention, assurance, service de santé, produit sans ordonnance ; titre, texte, bouton et lien ; emplacements ; villes et langues ; dates) : enregistrée en brouillon, diffusée seulement après « Valider » et confirmation de la conformité à la charte ; toute modification la remet en brouillon ;
- suspendre une campagne ; affichages, clics et taux de clic ; rapport tableur pour l'annonceur (par jour et emplacement).

Charte publicitaire (CGU, article 11) : seulement prévention et santé publique, assurances et mutuelles, services de santé, produits sans ordonnance autorisés ; interdits : médicament sur ordonnance, promesse de guérison, médecin mis en avant contre paiement, contenu sponsorisé dans le dossier médical, une ordonnance ou une téléconsultation. Les textes contenant des mots interdits (« ordonnance », « antibiotique », « miracle », « guérison garantie »…) sont refusés automatiquement. Ciblage par ville et langue seulement, jamais par les données de santé ; statistiques agrégées, aucune donnée personnelle transmise. Charte à faire relire par un juriste et l'Ordre des médecins.

8.21 Guide d'utilisation dans l'application

- Page **« Guide d'utilisation »** (`/guide`), un chapitre par espace : patient, famille (entraide), médecin, clinique et secrétariat, pharmacie, laboratoire, relais communautaire, administration.

- Chaque chapitre : introduction, sommaire, sections avec **étapes numérotées**, points clés et **astuces** ; recherche dans tous les chapitres à la fois (« ordonnance », « annuler », « crédit »…) ; bouton « Imprimer ce guide ».
- Le lien **« Aide »** de l'en-tête de chaque espace ouvre directement le chapitre de cet espace ; le guide renvoie vers « Aide et contact » pour écrire à l'équipe. Liens aussi depuis la page « Aide et contact » et le pied de page de l'accueil.
- Contenu : `src/lib/guide-content.ts`, à tenir à jour à chaque évolution d'un écran.

9. Audit global du code (5 octobre 2026)

Audit critique de l'ensemble du projet (interface, serveur, base de données, configuration) en quinze volets. Chaque point a été vérifié dans le code et, quand c'est possible, par un test automatique ajouté à la suite. Les problèmes sont classés par gravité : **Bloquant** (à corriger avant toute mise en ligne), **Important** (risque réel en exploitation), **Mineur** (sans conséquence pour les utilisateurs). Tous les problèmes bloquants et importants relevés ont été corrigés (volets 1 à 6 : version 3.2 du dossier ; volets 7 à 15 : version 3.4).

9.1 Synthèse

Gravité	Problème	Volet	État
Bloquant	Le serveur de production démarrait en mode développement si le réglage `DJANGO_DEBUG` était oublié (pages de débogage, accès démo sans mot de passe)	1, 3	Corrigé
Important	Force brute répartie : la limite de connexion était comptée par adresse IP seulement	1, 4	Corrigé
Important	Recherche de médecins : environ 6 requêtes SQL par médecin affiché (« N+1 »)	4	Corrigé
Important	Base de données injoignable : page d'erreur brute au lieu d'un message clair	5	Corrigé
Important	Aucun historique des rendez-vous : auteur précis d'une annulation et ancien horaire d'un déplacement perdus	6	Corrigé
Important	Reçus de paiement sans numérotation continue (obligation légale)	9	Corrigé
Important	Réponse « STOP » aux SMS non prise en compte	10	Corrigé
Important	Rappel SMS pouvant partir deux fois si deux exécutions du planificateur se chevauchent	10	Corrigé
Important	Aucune purge des comptes inactifs	11	Corrigé (désactivée tant que la durée légale n'est pas fixée)
Important	Contrastes de couleurs insuffisants (WCAG AA), listes sans libellé, débordement de l'accueil sur tablette	13	Corrigé
Important	Flux temps réel : connexions à la base gardées ouvertes (risque d'épuisement)	15	Corrigé
Mineur	Pas de bouton pour déconnecter ses autres appareils (seule l'administration pouvait le faire)	7	Corrigé
Mineur	Un médecin pouvait réserver chez lui-même	8	Corrigé
Mineur	Réservation renvoyée après une coupure réseau : message d'erreur trompeur	15	Corrigé
Mineur	`/api/health` sans détail des composants	14	Corrigé
Mineur	Mot de passe des comptes de démonstration écrit dans le script de démonstration	3	Accepté (démonstration seulement)

9.2 Volet 1 — Sécurité et permissions

Question	Constat	Preuve / correctif
Un utilisateur peut-il lire ou modifier les données d'un autre en changeant un identifiant (IDOR/BOLA) ?	Non. Chaque route filtre sur l'utilisateur connecté (patient, médecin, clinique) ; identifiants UUID non devinables	Test `tests/test_idor_sweep.py` : un autre patient, un autre médecin et un visiteur tentent une quarantaine de routes (RDV, documents, ordonnances, paiements, proches, mesures, analyses, renouvellements, assurances) : toutes refusées (401/403/404), aucune donnée modifiée
Les réponses publiques laissent-elles fuir des données ?	Non. Les fiches publiques (médecins, cliniques, pharmacies) n'exposent que des champs choisis ; jamais d'email ou de téléphone de patient	Revue des fonctions de sérialisation
Injection SQL / XSS ?	Aucune requête SQL écrite à la main (ORM Django partout) ; React échappe les contenus, aucun `dangerouslySetInnerHTML` sur une donnée utilisateur ; CSP stricte	Revue du code
Secrets et `.env` ?	`.env` exclu de Git ; clés lues dans les variables d'environnement ; clé secrète obligatoire en production	`.gitignore`, `settings.py`
Mode développement en production	**Bloquant** : `DJANGO_DEBUG` valait « vrai » par défaut	Corrigé : le mode développement n'est actif sans réglage que pour les commandes `manage.py` sur un poste ; gunicorn démarre toujours en mode sécurisé ; `docker-compose.yml` impose `DJANGO_DEBUG: "false"`
Force brute sur les mots de passe	**Important** : limite par IP contournable avec de nombreuses adresses	Corrigé : verrou par compte, 10 échecs en 15 minutes → connexion refusée 15 minutes (test dans `tests/test_security.py`)

9.3 Volet 2 — Concurrence et fiabilité des créneaux

Question	Constat	Preuve / correctif
Deux patients qui réservent le même créneau à la même seconde ?	Impossible. Vérification dans une transaction, puis **contrainte d'exclusion PostgreSQL** (aucun chevauchement de deux RDV actifs d'un même médecin) ; le second reçoit une erreur 409 « Ce créneau vient d'être réservé »	Tests existants de double réservation ; nouveau test `tests/test_overlap_constraint.py` qui contourne l'application et vérifie le refus par la base (exécuté sous PostgreSQL en intégration continue)
Fuseaux horaires et heure d'été	Dates stockées en UTC (`USE_TZ = True`, colonnes `timestamp with time zone`) ; le Sénégal est à UTC+0 sans heure d'été ; l'interface affiche toujours l'heure de Dakar, quel que soit le réglage du téléphone	`settings.py`, `src/lib/datetime.ts`

9.4 Volet 3 — Portabilité, propreté du code et installation

Question	Constat
Chemins écrits en dur ?	Aucun : chemins calculés depuis le dossier du projet ou lus dans l'environnement
Installation standard ?	`pip install -r requirements.txt`, `migrate`, `seed_demo`, `runserver` ; `npm install`, `npm run dev` ; ou `docker compose up` ; `Lancer-Fajma.bat` sous Windows

Question	Constat
`console.log` / `print` oubliés, code mort ?	Aucun ; journaux via `logging` ; ESLint et TypeScript strict dans l'intégration continue
Données de test en dur ?	Mineur : mot de passe des comptes de démonstration dans `seed_demo` (commande réservée à la démonstration, accès démo impossible en production)

9.5 Volet 4 — Performance, requêtes et coûts

Question	Constat	Preuve / correctif
Requêtes en cascade (N+1) ?	**Important** sur la recherche de médecins (91 requêtes pour 14 médecins)	Corrigé : prochaine disponibilité de tous les médecins en 4 requêtes (`next_available_many`), aussi sur les pages des cliniques. Test `tests/test_query_counts.py` : le nombre de requêtes de la recherche, des RDV du patient et de l'agenda du médecin ne grandit pas avec le nombre de lignes
Index SQL ?	Index sur (médecin, date, statut) des RDV, sur les dates de début et de fin, sur le journal d'audit et le nouvel historique	Migrations
Limites d'envoi (SMS, email, connexion) ?	Connexion 10/min par adresse + verrou par compte ; codes SMS 10/h par adresse et 3 par numéro toutes les 10 minutes ; réservations 20/h ; formulaire d'aide 5/h	`DEFAULT_THROTTLE_RATES` , `accounts/views.py`
Simulation en développement ?	Sans compte Twilio, aucun SMS n'est envoyé (aucun coût) et le code s'affiche en développement ; emails affichés dans la console par défaut	`notifications/sms.py` , `EMAIL_BACKEND`

9.6 Volet 5 — Robustesse et gestion des erreurs

Question	Constat	Preuve / correctif
Base de données en panne ?	**Important** : page d'erreur brute	Corrigé : réponse 503 « Service momentanément indisponible. Réessayez dans quelques minutes. », détail dans les journaux (test dans `tests/test_query_counts.py`)
Service externe en panne (paiement, SMS, IA) ?	Délais d'attente sur chaque appel, erreurs capturées, message clair (502/503) ; SMS remis en file et réessayés	`payments/paydunya.py` , `notifications/sms.py` , `medical/ai_notes.py`
Message à l'écran ?	« Serveur injoignable. Vérifiez votre connexion. » sans réseau ; message du serveur sinon ; jamais d'erreur technique	`src/api/client.ts`
Validation des formulaires ?	Contrôles dans l'interface **et** sur le serveur (types, longueurs, choix autorisés, dates, téléphone, fichiers) ; le serveur ne fait jamais confiance à l'interface	`sunusante/api.py` (`get_str` , `get_int` , `get_choice` , `get_uuid`)

9.7 Volet 6 — Oublis métier et cycle de vie d'un rendez-vous

Question	Constat
Réserver pour un proche ?	Oui : enfants et parents enregistrés dans « Mes proches », choisis au moment de la réservation
Congés et absences du médecin ?	Oui : ils bloquent les créneaux en ligne, comme les occupations importées de son agenda personnel
Annulation tardive ?	Délai fixé par chaque médecin ; passé ce délai, l'annulation en ligne est fermée et le patient appelle le cabinet ; remboursement intégral d'un RDV payé ; le créneau libéré redevient réservable et la liste d'attente est prévenue
Traçabilité (qui a créé, modifié, annulé) ?	**Important**, corrigé : table `appointments_appointmentevent`, remplie automatiquement à chaque modification, quelle que soit son origine (patient, médecin, secrétariat, clinique, WhatsApp, USSD, tâches automatiques). Elle enregistre l'action, l'auteur, l'ancien et le nouvel horaire ou statut et le motif. Bouton « Historique » sur chaque RDV pour le patient, le médecin et le secrétariat. Test `tests/test_appointment_history.py`

9.8 Volet 7 — Sessions et authentification avancée

Question	Constat	Preuve / correctif
JWT ou sessions ? Où est le jeton ?	**Sessions Django côté serveur**, pas de JWT. Le navigateur ne garde qu'un identifiant de session dans un cookie `HttpOnly` (illisible par JavaScript, donc hors de portée d'une faille XSS), `Secure` (HTTPS seulement) et `SameSite=Lax`, avec jeton CSRF. Rien n'est stocké dans `localStorage`	`settings.py`
Révoquer tous les accès d'un compte ?	Oui, immédiatement : la session est en base, la supprimer coupe l'accès. Suspension par l'administration = toutes les sessions fermées ; changement ou réinitialisation du mot de passe = autres appareils déconnectés. **Ajouté** : bouton « Déconnecter mes autres appareils » (page Sécurité, tous les comptes)	`accounts/security.py` (`end_sessions`), `POST /api/auth/sessions/logout-others`, test `tests/test_audit_part2.py`
Mots de passe et double authentification ?	Mots de passe : 10 caractères minimum, refus des mots de passe courants, entièrement numériques ou proches de l'identité ; stockage haché (PBKDF2). **Double authentification (TOTP) obligatoire** pour médecins, pharmaciens, laboratoires, cliniques, secrétariat et administration ; déconnexion après 30 min d'inactivité ; alerte de connexion depuis un nouvel appareil	`accounts/security.py`, `AUTH_PASSWORD_VALIDATORS`

9.9 Volet 8 — Vérification d'identité et annuaire

Question	Constat
N'importe qui peut-il se déclarer médecin ?	Non. Une fiche médecin créée reste **invisible et non réservable** tant que l'administration ne l'a pas vérifiée (justificatif d'inscription à l'Ordre des médecins du Sénégal, n° d'Ordre) ; même règle pour les cliniques (autorisation du ministère, NINEA/RCCM, responsable, médecin responsable), les pharmacies (autorisation, pharmacien titulaire inscrit à l'Ordre) et les laboratoires (agrément, biologiste responsable) : publication impossible sans toutes leurs pièces obligatoires validées et en cours de validité (§ 8.12). Une pièce d'identité est aussi exigée du médecin. Nom et spécialité figés après vérification ; suspension = fiche retirée. (RPPS et Adeli sont des identifiants français ; l'équivalent sénégalais est le n° d'inscription à l'Ordre.)

Question	Constat
Un médecin peut-il être patient d'un confrère ?	Oui : un seul compte, le rôle « médecin » s'ajoute au rôle « patient » sans conflit (rendez-vous et dossier patient d'un côté, agenda de l'autre). **Ajouté** : un médecin ne peut pas prendre rendez-vous avec lui-même (il bloque un horaire dans son agenda). Tests `tests/test_audit_part2.py`

9.10 Volet 9 — Paiement, facturation et remboursements

Question	Constat	Correctif
Empreinte bancaire et frais de non-présentation ?	Non applicable : au Sénégal le paiement se fait surtout par mobile money (Wave, Orange Money, Free Money via PayDunya) ou en espèces, sans pré-autorisation possible. Alternative en place : **prépaiement obligatoire** des téléconsultations au choix du médecin, et suivi des absences (statut « absent »)	Décision commerciale si besoin : prépaiement de certains motifs
Numérotation légale des reçus ?	**Important**, corrigé : les reçus portaient une référence aléatoire. Chaque encaissement (consultation ou abonnement) reçoit maintenant un **numéro continu, sans trou ni doublon**, par année (`FJ-2026-000001`), attribué au passage à « payé » sous verrou de base de données ; les paiements déjà encaissés ont été numérotés dans l'ordre chronologique ; numéro imprimé sur le reçu PDF	`payments/models.py` (`ReceiptCounter`), test `tests/test_audit_part2.py`
Remboursement automatique si le médecin annule ?	Oui pour la décision : toute annulation d'un RDV payé en ligne (patient, médecin, secrétariat) crée automatiquement le remboursement intégral. Le versement lui-même est fait par l'administration (PayDunya ne propose pas encore de remboursement automatique par API)	`payments/ledger.py` (`open_refund`)

9.11 Volet 10 — Communications, rappels et anti-spam

Question	Constat	Correctif
Statuts d'échec Twilio ?	Webhook `twilio-status` authentifié : le statut du SMS est mis à jour en base (livré, échec et code) en une requête, sans bloquer le serveur ; les envois partent d'une file de tâches	`notifications/views.py`
Réponse « STOP » ?	**Important**, corrigé : rien n'était prévu. Désormais STOP / ARRÊT par SMS (nouveau webhook `twilio-inbound`) ou sur WhatsApp désinscrit le numéro ; un numéro que Twilio signale désinscrit (code 21610) l'est aussi ; plus aucun SMS automatique ensuite (rappels, alertes), seuls les codes de connexion demandés par la personne partent encore ; START réactive	`notifications/optout.py` , table `notifications_smsoptout` , tests
Rappels envoyés plusieurs fois si le script plante ?	**Important**, corrigé : un rappel est désormais « réservé » (statut « en cours d'envoi ») avant l'appel à Twilio ; deux exécutions simultanées ne peuvent pas envoyer le même rappel, et un envoi interrompu n'est jamais renvoyé (mieux vaut un rappel manquant qu'un doublon). Un seul rappel par RDV et par type (contrainte en base)	`send_reminders.py` , tests

9.12 Volet 11 — Confidentialité et RGPD santé

Question	Constat	Correctif
Contenu des SMS sur l'écran verrouillé ?	Neutre : « rendez-vous avec Dr X, date, au cabinet / en vidéo ». Jamais la spécialité, le motif ou un résultat ; « résultats déposés dans votre dossier » sans contenu	`notifications/sms.py`
Export des données en un clic ?	Oui : export complet en JSON (compte, proches, rendez-vous, paiements, comptes-rendus…) et dossier médical en PDF, depuis « Mon dossier »	`GET /api/auth/export`, `GET /api/patient/medical-record`
Purge des comptes inactifs ?	**Important**, corrigé : seules les données techniques étaient purgées. Ajout d'une purge des comptes patients sans connexion ni rendez-vous depuis N jours : **préavis par email**, puis anonymisation 30 jours plus tard si la personne ne s'est pas reconnectée (comptes-rendus conservés chez le médecin). **Désactivée par défaut** (`RETENTION_INACTIVE_ACCOUNT_DAYS=0`) tant que la durée n'est pas fixée avec un juriste et la CDP ⚖️	`accounts/erasure.py`, `purge_data`, tests

9.13 Volet 12 — Fichiers joints

Question	Constat
Stockage chiffré, accès temporaire ?	Chaque fichier est **chiffré sur le disque** (Fernet, clé hors du serveur de fichiers), stocké hors du dossier public et servi uniquement par une route qui vérifie à chaque téléchargement la session et le droit d'accès (patient, médecin à qui le document est partagé) et journalise la consultation : il n'existe aucun lien public, donc rien à signer ni à faire expirer
Exécutables, taille ?	Type réel lu dans le contenu du fichier (pas l'extension) : seuls PDF, JPEG, PNG et WebP sont acceptés (un `.exe` ou un `.sh` renommé est refusé) ; 6 Mo maximum ; analyse antivirus ClamAV avant stockage

9.14 Volet 13 — Accessibilité et écrans

Contrôle automatique **axe-core (WCAG 2.1 A et AA)** sur 9 pages clés (accueil, recherche, connexion, espace patient, dossier, espace médecin et agenda, clinique, administration), en thème clair et en thème sombre, et contrôle de mise en page sur portable 13" (1280 × 800), tablette (1024 × 768) et tablette portrait (768 × 1024).

Constat	Correctif
Important : contrastes insuffisants (texte blanc sur le vert en mode sombre 3,8:1 ; textes gris secondaires 3 à 4,2:1 ; petits libellés verts sur fond vert pâle 4,2:1)	Vert du mode sombre éclairci et texte foncé sur les boutons colorés (7:1) ; opacité minimale des textes secondaires ; nuances de texte légèrement plus foncées du vert et du turquoise (les boutons gardent le vert du drapeau). Résultat : **0 violation** sur les 9 pages, dans les deux thèmes
5 listes déroulantes de l'espace clinique sans nom pour les lecteurs d'écran	Libellés ajoutés
Accueil en tablette portrait : barre de navigation plus large que l'écran (198 px)	Menu complet à partir de 1024 px ; aucun débordement sur les 8 pages × 3 tailles
Agenda	Utilisable au clavier et au toucher ; boutons d'action nommés ; couleurs des motifs validées pour les daltoniens, avec texte (jamais la couleur seule)

9.15 Volet 14 — Journaux et supervision

Question	Constat	Correctif
Traçabilité des actions sensibles ?	Journal d'audit inaltérable : horodatage, identifiant de l'utilisateur, adresse IP, navigateur, pour chaque consultation de fiche patient, document, ordonnance, export, connexion (et échec), action d'administration ; historique de chaque rendez-vous (création, déplacement, annulation et auteur). Les journaux techniques ne contiennent ni nom ni contenu médical (identifiants seulement, numéros de téléphone masqués)	`audit/`, `appointments/history.py`
Route `/api/health` ?	Existait (base de données seulement). **Ajouté** : détail de chaque composant (base, antivirus, rappels en retard, échecs SMS, sauvegarde, disque, SMS et paiement configurés) pour l'équipe Fajma connectée ou la supervision externe munie du jeton `HEALTH_TOKEN` ; le public ne voit que `{"status": "ok"}`	`sunusante/views.py`, test

9.16 Volet 15 — Ingénierie et architecture

Question	Constat	Correctif
Validation stricte des entrées ?	Chaque route lit ses champs avec des fonctions de validation typées (`get_str`, `get_int`, `get_uuid`, `get_choice` : longueurs, bornes, listes de valeurs autorisées) plutôt qu'un schéma Pydantic ; le serveur ne fait jamais confiance au navigateur (prix, durées, droits recalculés). JSON corrompu ou type invalide : réponse 400 propre, jamais d'erreur 500	Test « JSON corrompu » ajouté
Idempotence ?	Paiement : un même RDV réutilise le même paiement (jamais deux encaissements) ; webhooks Twilio, WhatsApp, USSD et PayDunya rejoués sans effet ; double réservation impossible (contrainte en base). **Ajouté** : une réservation renvoyée après une coupure réseau (réponse perdue) retrouve le RDV déjà créé au lieu d'afficher une erreur	`appointments/views.py`, test
Transactions ?	Opérations sur plusieurs tables (réservation, séries, paiement et journal comptable, suppression de compte, purge) dans des transactions atomiques, annulées en entier en cas d'échec ; SMS et emails envoyés seulement après validation de la transaction	`transaction.atomic`, `on_commit`
Connexions à la base ?	Connexions réutilisées 60 s avec contrôle de validité. **Corrigé** : le flux temps réel gardait une connexion ouverte par fil d'exécution (risque d'épuisement avec beaucoup de navigateurs connectés) ; il rend désormais la connexion après chaque lecture. PostgreSQL réglé à 200 connexions (API 3 × 8 fils, flux, tâches : large marge)	`notifications/stream.py`, `docker-compose.yml`
Tâches lentes ?	SMS, emails et notifications passent par une file de tâches traitée par un service à part (`worker`) ; les PDF (ordonnances, reçus, dossier, rapports) sont fabriqués dans le navigateur, sans charge pour le serveur ; le flux temps réel tourne sur un serveur asynchrone séparé	`TASK_BACKEND`, service `events`
En-têtes de sécurité et CORS ?	nginx : CSP stricte (empreintes des scripts, sans `unsafe-inline` pour les scripts), HSTS 1 an, `X-Frame-Options: DENY`, `nosniff`, `Referrer-Policy`, `Permissions-Policy` ; Django ajoute redirection HTTPS et cookies sécurisés. Aucun CORS ouvert : l'API ne répond qu'au site lui-même (même origine)	`deploy/security-headers.conf`

9.17 Recette de l'interface (version de production)

La version compilée pour la production, servie comme en ligne, a été parcourue page par page : 19 pages publiques (dont page inconnue, lien de vérification invalide, fiche d'urgence invalide) et toutes les pages des 7

rôles (patient, médecin et ses 7 onglets, secrétariat, clinique, pharmacie, laboratoire, administration), sur téléphone (375 px) et sur ordinateur (1366 px), soit 78 affichages. Relevés : erreurs JavaScript et console, appels à l'API en échec, débordement horizontal, page vide, texte non traduit, poids du JavaScript chargé.

Constat	Gravité	Correctif
Page blanche au rechargement répété d'une page de l'espace connecté (7 fois sur 16) : le flux temps réel, ouvert dès le démarrage, occupait des connexions dont le navigateur avait besoin pour charger un morceau de l'application (limite de 6 connexions par site en HTTP/1.1)	**Important**	Flux ouvert 2,5 s après l'affichage et fermé explicitement au départ de la page : 0 page blanche sur 30 rechargements ; alerte de nouveau message toujours reçue en temps réel. Recommandation : HTTP/2 sur le point d'entrée HTTPS
Page « introuvable » (404) : erreur React #418 au premier chargement	Mineur	Page 404 rendue comme une page ordinaire (route attrape-tout), titre et `noindex`
Retour de paiement ouvert sans référence : erreur technique dans la console	Mineur	Message « Paiement introuvable » avec lien vers l'espace
Débordements sur téléphone (recherche de médecins, agenda du médecin, aperçu des créneaux)	Mineur	Mises en page corrigées
Poids : la bibliothèque PDF et celle des graphiques étaient chargées à l'ouverture des pages, même sans téléchargement	Important (réseau 3G)	Chargées seulement au clic ou à l'affichage d'une courbe : dossier patient 483 → 309 Ko, espace médecin 413 → 238 Ko (JavaScript compressé) ; accueil 172 Ko

Autres contrôles : compilation de production sans erreur, aucune faille connue dans les bibliothèques (`npm audit`), typage TypeScript sans erreur, traductions complètes (246 textes en français, wolof et anglais pour les pages publiques ; espaces professionnels en français). Résultat final : **0 problème sur les 78 affichages**.

9.18 Base de données sur un vrai PostgreSQL

Vérification complète de la base sur PostgreSQL 17.6 réel (sans Docker), avec un utilisateur sans droits d'administration, puis test de volume (200 000 rendez-vous), sauvegarde, restauration, transfert depuis SQLite et déménagement des fichiers. Détail des mesures et des procédures : chapitre 4, § 4.5.

Constat	Gravité	Correctif
Les tests PostgreSQL de l'intégration continue échouaient depuis la première mise en ligne du code (les étapes suivantes, contrôles de sécurité Django et failles des bibliothèques Python, ne tournaient donc jamais). Les versions précédentes de ce dossier affirmaient à tort que les tests passaient aussi sous PostgreSQL	**Bloquant**	Corrigé : 404 tests au vert sur PostgreSQL ; contrôles de sécurité Django et `pip-audit` exécutés (aucune faille, un avertissement volontaire : HSTS preload) ; nouvelle étape « migration manquante »
Erreur PostgreSQL « verrou impossible sur une jointure facultative » : accepter ou refuser un remplacement et décider d'un renouvellement d'ordonnance auraient planté en production (invisible sous SQLite)	**Bloquant**	Verrous limités à la ligne concernée
Suppression d'un compte ou d'une fiche médecin depuis la console technique : comptes-rendus, ordonnances, paiements, messages effacés en cascade	**Important**	Liens protégés (refus de la suppression), testé ; l'effacement légal reste l'anonymisation
Secret de double authentification stocké en clair dans la base	**Important**	Chiffré (clé des fichiers, hors base et hors sauvegardes), secrets existants chiffrés par migration, testé
Recherche de comptes (administration) : 404 requêtes pour 50 résultats	Important	11 requêtes ; 424 → 40 ms

Constat	Gravité	Correctif
Journal d'audit sans index de date (5 ans de conservation)	Important	Index ajoutés ; 312 → 33 ms
Annuaire sans pagination (333 Ko pour 500 médecins, 3 Mo pour 5 000)	Important	60 médecins par page, total affiché, bouton « Voir plus » vérifié dans le navigateur
Agenda du médecin renvoyant tout l'historique (grossit chaque année)	Important	RDV à venir + 90 derniers jours (réglable)
Rapport d'activité : 222 requêtes, 2,4 s	Mineur	35 requêtes, 1,3 s, résultats identiques vérifiés
Index manquants sur les dates (paiements, rendez-vous pris)	Mineur	Ajoutés
Transfert SQLite → PostgreSQL : échec sur la liste des assurances, puis 20 faux événements d'historique créés par le chargement	Important	Procédure corrigée (vidage avant chargement) ; le chargement n'invente plus d'historique (testé) ; transfert vérifié objet par objet
Sauvegarde une seule fois par jour (jusqu'à 24 h de données perdues) ; test de restauration non surveillé	Important	Fréquence réglable (6 h conseillé) ; test mensuel une seule fois ; alerte si aucun test réussi depuis 35 jours
Six tests fermaient une connexion en cours de test, et dix utilisaient un raccourci qui fausse l'heure de fin des rendez-vous	Mineur (tests)	Corrigés

9.19 Vérifications après correction

- 404 tests automatisés de l'API, tous au vert sur SQLite **et sur PostgreSQL 17** (vérifié en local ; l'intégration continue exécute les deux).
- Typage TypeScript et analyse ESLint sans erreur ; 0 violation d'accessibilité WCAG AA sur les 9 pages contrôlées ; recette de l'interface de production : 0 problème sur 78 affichages (§ 9.17).
- Points restant hors code : test d'intrusion par un prestataire externe, test de charge, durées légales de conservation (comptes inactifs, données médicales) à fixer ⚖️ (voir chapitre 5).

9.20 Administration (version 6.1)

Revue de l'interface d'administration : page unique de 15 000 pixels, doublons pharmacies et laboratoires, listes de validation mélangées, pas de recherche globale ni de vue d'ensemble d'un médecin, journal limité aux 200 derniers évènements, réglages réservés au technicien, tous les administrateurs avec tous les droits. Les 9 corrections sont faites (voir 8.7) ; les rôles sont vérifiés par le serveur, pas seulement masqués à l'écran. 4 tests automatisés ajoutés (rôles, réglages, annonces, recherche, fiche 360°, journal).

9.21 Audit de la base de données (version 6.2)

Nouvel audit complet de la base sur PostgreSQL 17 réel, après les ajouts des versions 5.x et 6.x (78 tables, 139 clés étrangères, 33 contraintes d'unicité ou de cohérence).

Contrôle	Résultat
Migrations à jour, contrôle de production de Django	Conformes (seul avertissement : inscription HSTS « preload », choix volontaire)
Injection SQL	Aucune requête SQL écrite à la main (hors « SELECT 1 » de surveillance)
Effacement accidentel	Dossiers, ordonnances, rendez-vous, paiements, écritures comptables, messages : suppression refusée par la base. Comptes jamais supprimés par l'application (anonymisation)

Contrôle	Résultat
Double réservation d'un créneau	Impossible : contrainte d'exclusion PostgreSQL sur la plage horaire du médecin
Doublons	Un seul compte par email (casse ignorée) et par numéro vérifié, imposé par la base ; aucun doublon dans les données
Clés étrangères	Toutes validées
Liens publics (fiche d'urgence, vérification d'ordonnance)	Jetons aléatoires de 256 bits, uniques ; nombre d'essais limité ; aucune identité de patient
Purge	Sessions expirées, codes SMS, conversations, notifications anciennes : chaque nuit

Constat	Gravité	Correctif
L'application se connectait avec le compte administrateur de PostgreSQL : une faille applicative aurait donné la main sur tout le serveur de base	**Important**	Compte `fajma_app` sans droits d'administrateur, créé au premier démarrage ; testé : migrations et application fonctionnent, opérations dangereuses refusées
Sauvegardes en clair si la phrase secrète était oubliée (données de santé)	**Important**	Phrase secrète obligatoire
Connexion à une base hébergée ailleurs non chiffrée par défaut	Moyen	Chiffrement exigé par défaut hors machine locale
Supprimer le compte du responsable d'une clinique (console technique) effaçait la clinique	Mineur	Suppression refusée par la base
Conséquence du compte limité : après restauration d'une sauvegarde, l'application n'avait plus accès à ses propres données (objets rendus au compte d'administration). Reproduit : `permission denied for table accounts_user`	**Critique**	`deploy/restore.sh` (une commande : déchiffre, restaure, rend les objets à `fajma_app`, remet les fichiers) ; le test mensuel relit désormais la sauvegarde **avec le compte de l'application**, donc cette panne ne peut plus passer inaperçue
Une annonce à des milliers de personnes partait dans une seule requête web : expiration, envoi à moitié fait, aucune trace enregistrée, et un nouvel essai prévenait deux fois les mêmes	**Important**	Annonce enregistrée d'abord, envoi en arrière-plan par paquets de 500, reprise possible sans doublon (test automatisé)

Mesures sur base chargée (20 508 comptes, 200 000 rendez-vous, 75 091 ordonnances) : recherche globale 86–103 ms (12 requêtes), liste des médecins 28 ms, journal d'audit 37 ms, fiche 360° 62 ms, estimation des destinataires d'une annonce 14 ms. À dix fois ce volume, la recherche globale approcherait la seconde : il faudra alors un index de recherche textuelle (`pg_trgm`), prévu mais inutile aujourd'hui.

Reste à la charge de l'hébergement : chiffrement du disque du serveur (les contenus des dossiers sont en clair dans la base, comme dans tout logiciel médical consultable ; les fichiers joints sont déjà chiffrés).

9.24 Haut de page du site public (version 6.9)

Constat	Gravité	Correctif
Aucun menu sur téléphone : en dessous de 1024 px, toutes les rubriques disparaissaient de l'en-tête sans remplacement — un visiteur sur mobile ne pouvait atteindre ni les pharmacies, ni l'assistant, ni les partenaires	Important	Bouton de menu et panneau dépliant (rubriques, « Je suis pro », choix de la langue)
« Professionnels » et « Je suis pro » menaient au même endroit	Mineur	Doublon supprimé
La recherche de médecin, geste le plus fréquent, n'était accessible qu'en redescendant dans la page	Moyen	Champ de recherche permanent dans l'en-tête ; les rubriques passent sur une seconde ligne

Aucun débordement horizontal à 390 px, aucune violation d'accessibilité.

9.23 Revue des interfaces (version 6.7)

Tour de toutes les interfaces, écran par écran.

Constat	Gravité	Correctif
La page publique de recherche de médecins n'avait aucun titre principal : rien annoncé au lecteur d'écran, et rien pour les moteurs de recherche sur la page la plus importante du site	Important	Titre `h1` ajouté (lu par les lecteurs d'écran, en français, wolof et anglais)
Un centre d'imagerie se voyait réclamer les justificatifs d'un laboratoire d'analyses (agrément de laboratoire, inscription du biologiste) : sa validation aurait été bloquée	Important	Les pièces exigées suivent ce que l'établissement déclare faire : autorisation d'exploitation du centre d'imagerie et inscription du médecin radiologue ; **autorisation de radioprotection seulement s'il utilise des rayonnements ionisants** (une échographie n'en produit pas). Un établissement mixte cumule les deux séries
« Aide » et « Déconnexion » collés dans l'en-tête des espaces pharmacie et laboratoire	Mineur	Espacement corrigé
Dossier du patient : 10 685 pixels, quatorze sections sans menu	Moyen	Quatre rubriques (voir 8.6 ter) ; page la plus longue : 2 639 pixels

404 tests automatisés au vert ; aucune violation d'accessibilité ; aucun débordement horizontal sur téléphone.

9.22 Audit complet après les ajouts médicaux (version 6.4)

Revue de l'application entière après l'ajout du contrôle de prescription, de l'imagerie, des actes et de l'export FHIR.

Contrôle	Méthode	Résultat
Droits de **toutes** les adresses de l'API	Test automatique qui balaie les 190 adresses (`tests/test_permissions_sweep.py`) pour un visiteur, un patient et un médecin	Aucune adresse protégée ouverte. Les adresses publiques (annuaire, catalogue des organismes, vérification d'ordonnance…) sont listées explicitement ; une nouvelle adresse est contrôlée automatiquement
Fuite de données par une adresse « professionnelle »	Le test exige une réponse **vide**, pas seulement un accès autorisé	Conforme (agenda, disponibilités, fiche : vides hors de son espace)
Performances sur base chargée (20 508 comptes, 200 000 rendez-vous)	Mesure à chaud	Catalogue des actes 12 ms, contrôle d'une ordonnance 53 ms, feuille de soins 31 ms, export FHIR 23 ms, catalogue des médicaments 5 ms (328 ms au tout premier appel : chargement du catalogue en mémoire)
Accessibilité (WCAG 2.1 AA)	axe-core sur les pages clés, en 1280, 1024 et 768 px, puis sur téléphone (390 px) formulaires ouverts	Aucune violation
Tenue sur téléphone	Mesure du débordement horizontal réel	Corrigé (voir ci-dessous)
Bibliothèques du site et du serveur	`npm audit` , `pip-audit`	Aucune faille connue

Contrôle	Méthode	Résultat
Base de données	Migrations, contraintes, clés étrangères	Conformes

Constat	Gravité	Correctif
La page du médecin défilait horizontalement sur téléphone dès l'ouverture d'un compte-rendu : la liste des maladies (libellés longs) et celle des actes imposaient leur largeur à toute la page	Important	`min-w-0` sur la carte de rendez-vous, le sélecteur de diagnostic et celui des actes ; les actions qui ouvrent un formulaire prennent toute la largeur de la carte. Débordement mesuré : 327 px → 0
Boutons « Déconnexion », « Aide » et « Contacter l'équipe » réduits à une icône sur téléphone : aucun nom pour la synthèse vocale	Moyen	Nom accessible ajouté (4 écrans)
Le formulaire de prescription d'imagerie était écrasé dans une colonne de 190 px	Mineur	Pleine largeur de la carte
Alerte d'imagerie affichant le code interne (« scanner ») au lieu du libellé	Mineur	Libellé complet
Le filtre des centres par examen utilisait une recherche JSON au comportement différent sur SQLite et PostgreSQL	Moyen	Filtrage en Python : identique sur les deux bases (exigence de portabilité)

404 tests automatisés au vert sur SQLite et sur PostgreSQL.

10. Que faire en cas d'incident

Ce chapitre est écrit pour être lu **le jour de l'incident**, par quelqu'un qui n'est pas ingénieur. Chaque situation donne les gestes dans l'ordre, et dit lesquels sont urgents. Aucune commande n'est à inventer : tout ce qui est écrit ici existe dans l'application ou dans `deploy/`.

> **Règle générale** : on coupe d'abord l'accès, on comprend ensuite. Un compte suspendu à tort se réactive en dix secondes ; des données volées ne se récupèrent jamais.

10.1 À préparer **avant** le premier incident

Sans ces quatre choses, le reste de ce chapitre ne sert à rien.

À faire	Pourquoi
Renseigner `ALERT_EMAILS` **et** `ALERT_PHONES`	Sans numéro de téléphone, une attaque de nuit n'est découverte que le matin
Mettre en place une surveillance **externe** (UptimeRobot, Better Stack, gratuits) qui appelle `https://www.fajma.sn/api/health` chaque minute	Si le serveur entier tombe, la supervision interne ne peut plus prévenir personne
Conserver la clé `FILE_ENCRYPTION_KEYS` **hors du serveur et hors des sauvegardes** (coffre, papier dans un endroit sûr)	Sans elle, les documents et les sauvegardes sont illisibles — y compris par vous
Noter qui appelle qui : votre prestataire technique, l'hébergeur, le délégué à la protection des données	Chercher un numéro pendant l'incident coûte des heures

---

10.2 « Un compte de médecin est compromis »

Signes : le médecin signale des rendez-vous qu'il n'a pas pris, une alerte « connexion depuis un nouvel appareil » qu'il ne reconnaît pas, ou des consultations de dossiers qu'il n'a pas faites.

Dans les cinq minutes

1. Administration → **Utilisateurs** → chercher le médecin → **Suspendre**, avec le motif. La suspension ferme immédiatement toutes ses sessions sur tous les appareils et retire sa fiche de l'annuaire. Personne ne peut plus se connecter à ce compte.
2. Administration → **Système** → **Journal des actions** → filtrer sur ce compte, sur les dernières 48 heures. Noter tout ce qui a été consulté : dossiers patients, ordonnances, documents. Exporter la liste.

Dans l'heure

3. Appeler le médecin par téléphone (jamais par email : la boîte peut être compromise aussi) et vérifier son identité avant de faire quoi que ce soit d'autre.
4. Administration → **Utilisateurs** → **Réinitialiser la double authentification** (motif obligatoire, journalisé). Cela retire à la fois le code à six chiffres **et** les clés d'accès, donc l'appareil volé ne sert plus à rien.
5. Demander au médecin de changer son mot de passe depuis un appareil sûr, puis **Réactiver** le compte.
6. Lui faire enregistrer une **clé d'accès** sur son nouvel appareil (Sécurité → Clés d'accès). C'est ce qui empêchera que cela recommence.

Dans les 72 heures, si des dossiers de patients ont été consultés

7. Le journal dit exactement quels patients. La notification des personnes concernées et la déclaration à la CDP sont une **obligation légale** ⚖️ : voir le chapitre 3. Ne pas attendre d'être certain de l'ampleur pour prendre conseil.

10.3 « J'ai reçu une alerte : mots de passe essayés en masse »

C'est la supervision (`manage.py monitor`) qui l'envoie, par email et par SMS.

1. **Ne rien couper.** L'application se défend déjà seule : au-delà de 10 essais ratés en 15 minutes sur un même compte, les tentatives sont refusées pendant 15 minutes, même si elles viennent d'adresses différentes. Une attaque qui échoue n'est pas une urgence.
2. Administration → **Système** → **Journal des actions** → échecs de connexion. Regarder **une seule chose** : y a-t-il une *réussite* après la série d'échecs ? Si oui, ce compte est compromis → section 10.2.
3. Si l'attaque dure plus d'une heure, demander à l'hébergeur ou au service en frontal (Cloudflare) de filtrer les adresses concernées. L'application ne peut pas le faire à sa place.
4. Si des comptes professionnels n'ont pas encore de clé d'accès, c'est le moment de le leur demander : elle rend ce type d'attaque sans objet.

10.4 « Le site ne répond plus »

1. Ouvrir `https://www.fajma.sn/api/health?token=…` (le jeton est dans `HEALTH_TOKEN`). La réponse dit quel composant est en cause : base, antivirus, SMS, sauvegarde, disque.
2. **Base injoignable** → redémarrer PostgreSQL chez l'hébergeur. Les données ne sont pas perdues : elles sont sur le disque, et la sauvegarde de la nuit existe.
3. **Disque plein** → c'est la cause la plus fréquente. Vérifier le dossier des sauvegardes : il grossit sans limite si personne ne retire les anciennes.
4. **Rien ne répond du tout** → le serveur lui-même est à terre : c'est l'hébergeur qu'il faut appeler, pas un développeur.
5. Pendant la panne, les rendez-vous déjà pris ne sont pas perdus et les SMS de rappel repartiront d'eux-mêmes une fois le service rétabli (la file reprend sans doublon).

10.5 « Il faut restaurer les données »

Suppression accidentelle, données incohérentes, serveur perdu.

1. **Ne pas écrire dans la base** en attendant : chaque minute d'activité complique la restauration.
2. `deploy/restore.sh` restaure une sauvegarde en une commande. Le test mensuel de restauration prouve qu'elle est relisible ; s'il n'a pas tourné depuis plus de 35 jours, la supervision l'a déjà signalé.
3. Les sauvegardes sont chiffrées : la clé `FILE_ENCRYPTION_KEYS` est indispensable. C'est le moment où l'on découvre si elle a bien été conservée ailleurs.
4. Détail des commandes : chapitre 4.5 bis.

10.6 « Une clé secrète a fuité »

Une clé envoyée par email, affichée dans une capture d'écran, laissée à un ancien prestataire.

Clé	Conséquence de la fuite	Geste
`DJANGO_SECRET_KEY`	Sessions falsifiables	La changer, puis redémarrer : tout le monde est déconnecté, c'est normal
`FILE_ENCRYPTION_KEYS`	Documents et secrets de 2FA lisibles par le voleur	`python manage.py encrypt_files --rotate` : rotation **sans coupure**, l'ancienne clé reste acceptée le temps de la bascule
`PAYDUNYA_*`	Paiements détournés	Les révoquer chez PayDunya **en premier**, avant tout le reste
`TWILIO_*`	SMS envoyés à vos frais	Les révoquer chez Twilio, vérifier la facture

Dans tous les cas, noter dans le journal interne **qui** a eu accès, **quand**, et **ce qui a été changé**.

10.7 Ce qui n'est pas un incident

Pour éviter les réveils inutiles :

- **Un patient ne reçoit pas son SMS** → le numéro a peut-être répondu STOP, ou le crédit Twilio est épuisé. Administration → **Support** → rappels SMS, avec relance.
- **Un médecin ne peut pas se connecter** → neuf fois sur dix, c'est l'heure de son téléphone qui a dérivé et le code à six chiffres qui ne tombe plus juste. La clé d'accès n'a pas ce problème.
- **Une alerte « sauvegarde vieille de 30 h »** → le planificateur n'a pas tourné une nuit. À regarder le matin, pas à 3 heures.

10.8 Rythme à tenir

Quand	Quoi
Chaque semaine	Valider les propositions de mise à jour des bibliothèques (ouvertes automatiquement, déjà testées par l'intégration continue)
Chaque mois	Vérifier que le test de restauration est passé ; parcourir le journal des actions d'administration
Chaque année	Test d'intrusion externe par un prestataire indépendant, et correction de ce qu'il trouve

Ce rythme est ce qui remplace un ingénieur sécurité à plein temps. Il ne le remplace pas entièrement : voir § 2.9, « Ce qui n'est pas couvert, et pourquoi ».